

# Security Awareness Training, Gamification and Memory

Heriot-Watt University: MSc Dissertation (F21MP)

15/08/2021

Word count: 18,097

Supervisor: Prof. Mike Just

Kirwan, Peter H00359723  
pdk2000@hw.ac.uk

## Contents

|                                                                              |           |
|------------------------------------------------------------------------------|-----------|
| <b>Declaration of Authorship.....</b>                                        | <b>4</b>  |
| <b>Acknowledgements .....</b>                                                | <b>5</b>  |
| <b>List Of Figures .....</b>                                                 | <b>6</b>  |
| <b>List Of Tables .....</b>                                                  | <b>7</b>  |
| <b>Abstract .....</b>                                                        | <b>8</b>  |
| <b>1 Introduction .....</b>                                                  | <b>9</b>  |
| 1.1 Project Aims And Objectives.....                                         | 9         |
| 1.2 Background: What Is Phishing?.....                                       | 10        |
| 1.3 Motivation.....                                                          | 10        |
| 1.3.1 The Scale Of The Phishing Problem .....                                | 10        |
| 1.3.2 Why Is Phishing So Successful?.....                                    | 12        |
| <b>2 Literature Review: Why Training Is Part Of The Solution .....</b>       | <b>14</b> |
| 2.1 Why Technical Solutions Alone Will Not Save Us .....                     | 14        |
| 2.2 Nudging: An Alternative Human Factors Approach .....                     | 16        |
| 2.3 Does Training Work?.....                                                 | 18        |
| 2.3.1 Increasing Skills Versus Increasing Awareness .....                    | 18        |
| 2.3.2 Evidence That Training Works .....                                     | 19        |
| 2.3.3 Criticism Of Training .....                                            | 21        |
| 2.4 Who Most Needs Training?.....                                            | 22        |
| 2.4.1 Age And Phishing Susceptibility (R1) .....                             | 23        |
| 2.4.2 Gender And Phishing Susceptibility (R2).....                           | 23        |
| 2.4.3 Technical Skill And Phishing Susceptibility (R3) .....                 | 24        |
| 2.4.4 Country Of Origin (R4) .....                                           | 24        |
| 2.5 Games And Gamification In Training.....                                  | 25        |
| 2.5.1 What Are Serious Games and What Is Gamification?.....                  | 25        |
| 2.5.2 Advantages And Disadvantages Of Games And Gamification In General..... | 25        |
| 2.5.3 A Review Of Phishing Games .....                                       | 27        |
| 2.5.3.1 Smells Phishy .....                                                  | 29        |
| 2.5.3.2 Anti-Phishing Phil .....                                             | 30        |
| 2.5.3.3 NoPhish .....                                                        | 31        |
| 2.5.3.4 What.Hack.....                                                       | 32        |
| 2.5.3.5 Phishy.....                                                          | 33        |
| 2.5.3.6 A Bird's Life.....                                                   | 34        |
| 2.5.3.7 Securix .....                                                        | 35        |
| 2.5.4 Are Phishing Games Effective? .....                                    | 37        |
| 2.5.4.1 Learning Outcomes And Methods Of Evaluation In Phishing Games.....   | 37        |
| 2.5.4.2 Do Users Enjoy Phishing Games? .....                                 | 38        |

|          |                                                                                            |           |
|----------|--------------------------------------------------------------------------------------------|-----------|
| 2.5.5    | Some Worries About Phishing Games .....                                                    | 39        |
| 2.5.5.1  | Underrepresentation Of People Of Retirement Age .....                                      | 39        |
| 2.5.5.2  | Problematic Comparisons To Traditional Training .....                                      | 39        |
| 2.5.5.3  | Retention: Do Users Remember The Content Of Games? .....                                   | 41        |
| 2.6      | <i>The Contribution Of This Study</i> .....                                                | 41        |
| <b>3</b> | <b>Methodology</b> .....                                                                   | <b>42</b> |
| 3.1      | <i>Methodology Overview</i> .....                                                          | 42        |
| 3.2      | <i>Experimental Conditions</i> .....                                                       | 43        |
| 3.2.1    | Traditional Training Condition .....                                                       | 43        |
| 3.2.2    | Gamified Training Condition .....                                                          | 44        |
| 3.2.3    | Awareness Condition .....                                                                  | 47        |
| 3.3      | <i>Pre-Training Assessment, Post-Training Assessment And Retention Assessment</i> .....    | 48        |
| 3.4      | <i>Recruitment Of Subjects</i> .....                                                       | 49        |
| 3.5      | <i>Demographics</i> .....                                                                  | 51        |
| 3.6      | <i>Measuring Enjoyment</i> .....                                                           | 55        |
| 3.7      | <i>Method Of Evaluation</i> .....                                                          | 55        |
| <b>4</b> | <b>Results Of Our Study</b> .....                                                          | <b>56</b> |
| 4.1      | <i>Overall Learning Outcomes</i> .....                                                     | 56        |
| 4.1.1    | Overall Correctness Of URL Classification (Hypothesis H1) .....                            | 56        |
| 4.1.2    | False Positives And False Negatives (Hypothesis H1) .....                                  | 58        |
| 4.2      | <i>Retention Learning Outcomes (Hypothesis H2)</i> .....                                   | 60        |
| 4.3      | <i>Participant Enjoyment</i> .....                                                         | 61        |
| 4.4      | <i>Sample Demographic Correlations With Phishing Susceptibility</i> .....                  | 63        |
| 4.4.1    | Age (R1).....                                                                              | 63        |
| 4.4.2    | Gender (R2).....                                                                           | 63        |
| 4.4.3    | Technical Skill (R3) .....                                                                 | 63        |
| 4.4.4    | Country Of Origin (R4) .....                                                               | 64        |
| 4.4.5    | Student Or Recent Graduate .....                                                           | 64        |
| 4.4.6    | Previous Training .....                                                                    | 64        |
| <b>5</b> | <b>Discussion</b> .....                                                                    | <b>65</b> |
| 5.1      | <i>Anti-Phishing Training Works</i> .....                                                  | 65        |
| 5.2      | <i>Users Seem To Remember Training</i> .....                                               | 65        |
| 5.3      | <i>Why Didn't We See Better Short Term Learning Outcomes With Gamification? (H1)</i> ..... | 65        |
| 5.4      | <i>Why Didn't We See Better Learning Retention For The Gamified Condition?</i> .....       | 67        |
| 5.5      | <i>Why Mere Awareness Is Not Enough</i> .....                                              | 68        |
| 5.6      | <i>Demographic Correlations With Phishing Susceptibility</i> .....                         | 68        |
| 5.6.1    | Age (R1).....                                                                              | 68        |
| 5.6.2    | Gender (R2).....                                                                           | 69        |

|          |                                                                                    |            |
|----------|------------------------------------------------------------------------------------|------------|
| 5.6.3    | Technical Skill (R3)                                                               | 69         |
| 5.6.4    | Country of Origin (R4)                                                             | 70         |
| 5.6.5    | Previous Training                                                                  | 70         |
| <b>6</b> | <b>Conclusion, Reflections And Suggestions For Future Research</b>                 | <b>71</b>  |
| 6.1      | Conclusion                                                                         | 71         |
| 6.2      | Reflections                                                                        | 71         |
| 6.2.1    | Potentially Confounding Variables                                                  | 71         |
| 6.2.2    | Changes From The Proposal                                                          | 72         |
| 6.2.2.1  | Removal Of Police From The Story                                                   | 72         |
| 6.2.2.2  | Change Of Retention Period From Two Weeks To One                                   | 73         |
| 6.2.2.3  | Removal Of Lookalike Domains From Training And Focus On Malicious Sub-domains      | 73         |
| 6.2.2.4  | Removal Of Answer Dependent Feedback From The Traditional Condition                | 73         |
| 6.2.2.5  | Removal Of “Experts” Who Scored 100% On The Pre-Training Assessment                | 74         |
| 6.2.3    | Mistakes And Missed Opportunities                                                  | 74         |
| 6.2.3.1  | Formulation Of Hypotheses And Research Question                                    | 74         |
| 6.2.3.2  | Possible Sampling Bias From The Scams Group                                        | 74         |
| 6.2.3.3  | Not Asking About Previous Training Timelines                                       | 75         |
| 6.2.3.4  | Not Asking How Participants Enjoyed Their Training Condition                       | 75         |
| 6.2.3.5  | Not Testing Participants’ Sentiments Towards IT Security Before And After Training | 75         |
| 6.3      | Summary Of Main Suggestions For Future Research                                    | 76         |
| 6.3.1    | Do More Training Retention Research (H2)                                           | 76         |
| 6.3.2    | Test Gamified Training With Actual Phish                                           | 76         |
| 6.3.3    | A Meta-Analysis Of Gender And Phishing Susceptibilities (R2)                       | 76         |
| 6.3.4    | More Studies Involving People Of Retirement Age (R1)                               | 77         |
| 6.3.5    | More Research On Integrating Security Training With Digital Inclusion              | 77         |
| 6.3.6    | More International Research                                                        | 77         |
| <b>7</b> | <b>Appendices</b>                                                                  | <b>78</b>  |
| 7.1      | Consent Letter And Form                                                            | 78         |
| 7.2      | Traditional Training Content                                                       | 80         |
| 7.2.1    | Traditional Training Educational Content                                           | 80         |
| 7.2.2    | Traditional Training Practice And Feedback (Example)                               | 83         |
| 7.3      | Awareness Training Educational Content                                             | 85         |
| 7.4      | Gamified Training Condition Content                                                | 86         |
| 7.4.1    | Gamified Intro                                                                     | 86         |
| 7.4.2    | Gamified Training Condition Educational Content                                    | 88         |
| 7.4.3    | Gamified Training Practice And Feedback (Example)                                  | 92         |
| 7.4.4    | Gamified Win Condition (if player classifies both example URLs correctly)          | 97         |
| 7.4.5    | Gamified Lose Condition (if player failed to correctly classify both example URLs) | 98         |
| 7.5      | Assessment Questions                                                               | 99         |
| <b>8</b> | <b>References</b>                                                                  | <b>104</b> |

## Declaration of Authorship

"I, Peter Kirwan, confirm that this work submitted for assessment is my own and is expressed in my own words. Any use made of the works of other authors in any form (e.g. ideas, equations, figures, text, tables, programs) is properly acknowledged. A list of the references employed is included." (Heriot-Watt University (Edinburgh Campus), 2020)

Signed

A handwritten signature in black ink, appearing to read 'Peter Kirwan'. The signature is stylized, with the first name 'Peter' written in a cursive script and the last name 'Kirwan' in a more legible, slightly cursive font.

Date 15/08/2021

## Acknowledgements

I would like to thank a number of people. I'm grateful to Moira and Frank for their support throughout the duration of the MSc. My supervisor Dr. Mike Just's time, patience and helpful suggestions on background literature and experimental methods were invaluable. I would also like to mention Rachana for her moral support, recommendation of statistics resources and help recruiting participants. I was humbled by the number of people who not only took part in the experiment but shared it with their networks. They have my gratitude.

## List Of Figures

|                                                                                 |    |
|---------------------------------------------------------------------------------|----|
| Figure 1: IBM graphic showing cost of breaches by sector (IBM 2020) .....       | 11 |
| Figure 2: Commonly used words in email subjects (Ferreira and Teles, 2019)..... | 13 |
| Figure 3: Gmail nudge example (Tidy, 2020a) .....                               | 17 |
| Figure 4: Outlook nudge example (Peswani, 2018).....                            | 18 |
| Figure 5: Awareness raising poster (“Cyber Awareness Posters,” 2019) .....      | 19 |
| Figure 6: Smells Phishy gameplay example 1 (Baslyman and Chiasson, 2016).....   | 29 |
| Figure 7: Smells Phishy gameplay example 2 (Baslyman and Chiasson, 2016).....   | 29 |
| Figure 8: Anti-Phishing Phil gameplay example (Sheng et al., 2007) .....        | 30 |
| Figure 9: NoPhish gameplay example (Canova et al., 2014) .....                  | 31 |
| Figure 10: What.Hack gameplay example (Wen et al., 2019) .....                  | 32 |
| Figure 11: Phishy gameplay example 1 (Gokul et al., 2018).....                  | 33 |
| Figure 12: Phishy gameplay example 2 (Gokul et al., 2018).....                  | 33 |
| Figure 13: A Bird’s Life gameplay example 1 (Weanquoi et al., 2018) .....       | 34 |
| Figure 14: A Bird’s Life gameplay example 2 (Weanquoi et al., 2018).....        | 34 |
| Figure 15: Securix Level 1 (Onashoga et al., 2019) .....                        | 35 |
| Figure 16: Securix URL tutorial (Onashoga et al., 2019) .....                   | 35 |
| Figure 17: Securix email test (Onashoga et al., 2019) .....                     | 36 |
| Figure 18: Securix website test (Onashoga et al., 2019) .....                   | 36 |
| Figure 19: Traditional training practice example.....                           | 44 |
| Figure 20: Feedback in the gamified condition .....                             | 45 |
| Figure 21: Gamified training condition structure .....                          | 46 |
| Figure 22: Assessment example.....                                              | 48 |
| Figure 23: Assessment scores before and immediately after training.....         | 57 |
| Figure 24: False positives .....                                                | 59 |
| Figure 25: False negatives.....                                                 | 59 |
| Figure 26: Retention of knowledge .....                                         | 61 |
| Figure 27: Feedback by Condition .....                                          | 62 |
| Figure 28: Enjoyment.....                                                       | 62 |

## List Of Tables

|                                                                                            |    |
|--------------------------------------------------------------------------------------------|----|
| Table 1: Cialdini's six principles of influence .....                                      | 13 |
| Table 2: Overview of phishing games .....                                                  | 28 |
| Table 3: Days to complete retention stage.....                                             | 49 |
| Table 4: Participant completion at each stage across conditions .....                      | 50 |
| Table 5: Demographic breakdown of participants .....                                       | 53 |
| Table 6: Selected Essential Digital Skills For Life.....                                   | 54 |
| Table 7: Essential Digital Skills Framework correlations with phishing susceptibility..... | 63 |



## Abstract

In 2015 an IT worker received an email and opened the MS Word attachment, starting a chain of events leading to Ukraine's power grid going down. A year later, in 2016, Clinton Campaign chair John Podesta clicked a link in an email claiming he needed to reset his Gmail password. Attacks like these are often the cornerstone of breaches costing billions every year. Sadly, purely technical solutions are impossible and so hardening of the human factor through training is essential. Contemporary methods are effective but studies show room for improvement that should lead us to consider unorthodox training. Gamified training promises better learning outcomes through increased user engagement, decreased user resentment and less security fatigue. In this study we use an A/B test to explore whether an anti-phishing game provides better learning outcomes than traditional training in the short and longer term. This makes it the first study to examine the retention of learning outcomes from an anti-phishing game. To promote the targeting and customisation of training, we also examine the correlations which demographic factors including age, gender, technical skill and country of origin might have with phishing susceptibility.

# 1 Introduction

## 1.1 Project Aims And Objectives

Our Project aimed to investigate both the effects of gamification on anti-phishing training and whether certain demographic variables are related to phishing susceptibility. We used an A/B experiment to investigate how the gamification of training materials affected users' ability to spot phishing and legitimate URLs in the short and long term. Specifically, we looked at the impact on their conceptual knowledge (i.e. knowing that) regarding the difference between root and sub-domains as well as their procedural knowledge (i.e. knowing how) identifying root-domains in URLs. Participants were assigned to either a gamified, traditional or awareness (control) training condition. After this training, their ability to classify URLs was, as detailed in 3.7, measured in the short term by the difference between their scores on pre and post-training URL classification assessments. To assess longer term learning outcomes, a retention assessment was carried out after approximately one week. To address the demographic questions, pre-training assessment scores were also assessed for correlation with demographic data.

Our aims can be enumerated in the following hypotheses and research questions.

**H1 (Gamification Immediate Learning Outcomes):** Participants exposed to gamified anti-phishing training will show better short term learning outcomes (in terms of overall correctness, false positives and false negatives) than those exposed to traditional training.

**H2 (Gamification and Memory):** Participants exposed to gamified anti-phishing training will show better learning retention (in terms of overall correctness) than those exposed to traditional training.

**R1 (Age):** Is there are a relationship between age and phishing susceptibility?

**R2 (Gender):** Is there a relationship between gender and phishing susceptibility?

**R3 (Technical):** Is there a relationship between technical skill and phishing susceptibility?

**R4 (Country):** Is there a relationship between country of origin and phishing susceptibility?

## 1.2 Background: What Is Phishing?

What distinguishes phishing from other types of attack? In a phishing attack the attacker attempts to trick users into taking an action that threatens their security or the security of their company. The preferred medium is email but many attackers are now switching to alternative channels like mobile chat apps.<sup>1</sup>

Our concern here is, however, with email phishing specifically, though much of our discussion will carry over to other variants. Sometimes the email contains a link which, when clicked, leads the user to a lookalike website impersonating some trusted brand e.g. FedEx. Here the user is typically tricked into entering sensitive details like credit card information. Alternatively, though, the user may be tricked into downloading an attachment which deploys malware on the system. Importantly, not all phishing emails contain links or attachments. In Business Email Compromise (BEC) phishing attacks, the email may contain nothing but text that persuades the recipient to transfer money. Some phishing attacks use a scattergun approach to targeting where the same email is sent to many people while other, “spear phishing”, campaigns are laser-focused on a particular organisation or individual.

## 1.3 Motivation

### 1.3.1 The Scale Of The Phishing Problem

Security incidents are unfortunately widespread with a 2021 Sophos survey finding 34% of organisations had experienced malware, 29% exposed data, 28% ransomware, 25% account compromise and 17% cryptojacking (Sophos, 2021a).

These security incidents are also expensive. Surveys with sobering numbers abound and are usually focused on mean statistics.

---

<sup>1</sup> Conventionally these alternative channels have different names with SMS phishing, for example, being referred to as “smishing” but for simplicity we refer to all these as phishing regardless of channel.

IBM, for example, estimates that the mean data breach in 2020 cost \$3.8 million in remediation (IBM, 2021). While some industries, like healthcare, are disproportionately targeted, Figure 1 shows the range of sectors experiencing breaches.

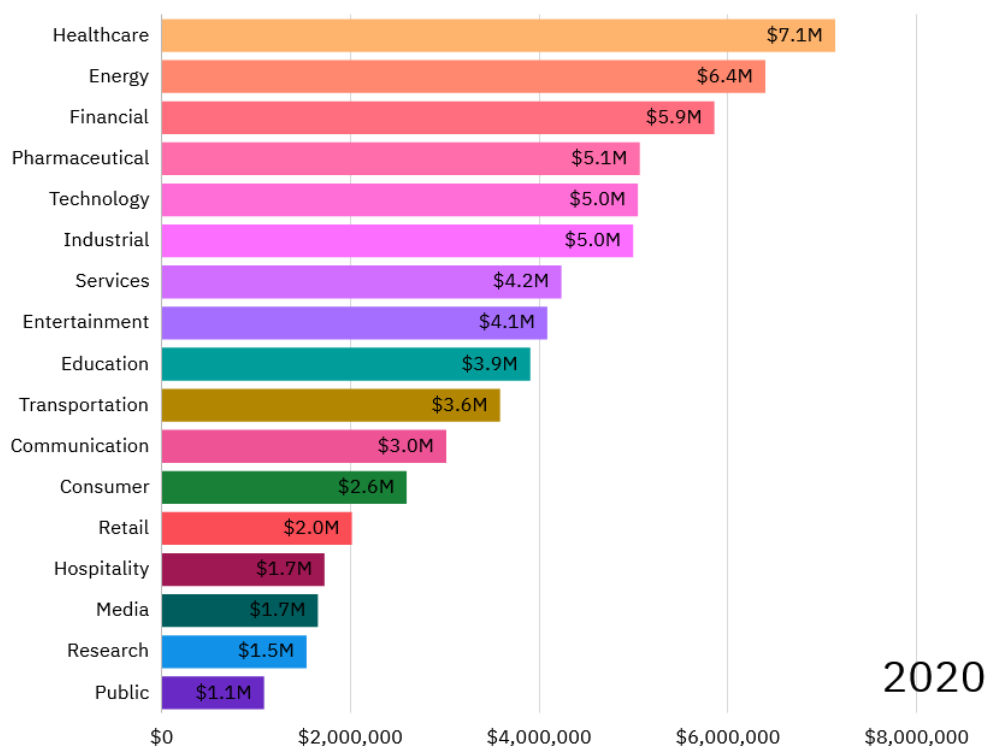


Figure 1: IBM graphic showing cost of breaches by sector (IBM 2020)

Simply losing access to your data can also be costly, with Sophos estimating the average global remediation cost of a 2021 ransomware attack at \$1.85m (Sophos, 2021b).

These statistics risk being misleading for two reasons. Non-response bias means many companies will want to avoid talking about their failures, even in an anonymous survey. Use of the mean without the context of data distribution also leaves the worry that the mean may have been overly influenced by outlier costs. Sadly, in their otherwise excellent reports, neither IBM nor Sophos opt to provide the original dataset or median costs.

Even if complete and accurate data about breach remediation costs is opaque, we can gain a conservative sense of the problem's scale by looking at related statistics like total cyber security

budgets and total ransom payments. According to Gartner, Cyber Security spending worldwide totalled over \$133 billion in 2020, with this expected to rise 12.4% in 2021 (Moore, 2021).

While the cryptocurrencies that ransoms are paid in are theoretically anonymous, the amounts and destinations are public record so we know that in 2020 ransoms paid to ransomware attackers totalled almost \$350m (Chainalysis, 2021). While exact figures are elusive, it seems clear that security incidents are expensive.

So how have attackers been so successful? Contrary to public perception, not all exploits are high-tech and often simple phishing attacks are at the root of incidents. With attackers typically using a combination of methods, we should be wary of talking about the sole cause of any incident. Nevertheless, Verizon reported phishing as the second most common threat action in 2020 at 15% of total actions and the most common threat action for breaches where it was involved 22% of the time (Verizon, 2020).<sup>2</sup>

### 1.3.2 Why Is Phishing So Successful?

Phishing emails are successful because they target people not software. People, like software, have vulnerabilities whereby their behaviour can be manipulated through inputs. Unlike software, however, these vulnerabilities are widely known and there is nothing analogous to a “patch”. Manipulating people in this way is “social engineering” of which phishing is one delivery method. Human factor vulnerabilities include, but are not limited to, one of Cialdini’s six principles (Cialdini, 2007) shown in Table 1.<sup>3</sup> A phishing email will usually attempt to exploit one or more of them.

| Human Vulnerability    | Definition                                                                     | Example of Exploitation                                     |
|------------------------|--------------------------------------------------------------------------------|-------------------------------------------------------------|
| Authority              | People are more inclined to comply with authority figures.                     | Phisher pretends to be the CEO of the company.              |
| Consistency/Commitment | People are more inclined to comply if they feel they or their company normally | Phisher pretends colleagues have approved similar requests. |

<sup>2</sup> The estimates from other sources vary widely with Verizon’s numbers very much on the conservative end of the scale.

<sup>3</sup> Though Cialdini’s is the most popular model, alternative models are (Gragg, 2003) or (Stajano and Wilson, 2011). An attempt to consolidate all three into one model is (Ferreira and Teles, 2019).

|                   |                                                                                                                   |                                                                                                                                                             |
|-------------------|-------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                   | complies with this type of request.                                                                               |                                                                                                                                                             |
| Reciprocity       | People are more inclined to do things for people who they feel have done things for them.                         | Phisher appears to do some small favour for the target.                                                                                                     |
| Liking/Similarity | People are more inclined to comply with things or people that are beautiful or familiar.                          | The phishing site the user is sent to is aesthetically very pleasing.                                                                                       |
| Scarcity          | People are more inclined to take an action if they feel there is a limited window of opportunity for that action. | Most commonly seen as urgency. Phisher pretends an action must be completed within the next hour in order not to hold up an important deal for the company. |
| Social Proof      | People are more inclined to trust things that are endorsed by friends or crowds of people similar to them.        | The phishing email may come from a trusted friend after their account has been hacked or impersonated.                                                      |

Table 1: Cialdini's six principles of influence

Many of these vulnerabilities are apparent in Figure 2, a wordcloud from Ferreira and Teles, showing the most commonly used terms in email subject lines.



Figure 2: Commonly used words in email subjects (Ferreira and Teles, 2019)

## 2 Literature Review: Why Training Is Part Of The Solution

To motivate an investment in end user training, it is not enough to show phishing is a problem. It must also be established that training is one of the indispensable puzzle pieces of prevention. Let us look, first, at the limitations of other phishing defences. We will begin with technical solutions like filters, two factor authentication and password managers before investigating other ways, like nudging, to harden the human factor.

Having established the problem and the insufficiency of alternative solutions, we will then examine evidence for the efficacy of security training. Finally, we will explore where there is room for improvement in traditional training, whether games and gamification can deliver these improvements and how our study helps answer this question.

### 2.1 Why Technical Solutions Alone Will Not Save Us

Technical solutions play an important role in phishing defences with the most notable being filters, two factor authentication and password managers. Filter solutions, like firewalls and email gateways, literally filter out undesirable emails. This is normally done using block or allow rules based on things like email subjects, contents or senders. Second authentication factor is something that is required besides a password to authenticate a user. This can be something you know (e.g. a pin), something you have (e.g. a hardware token or smartcard), something you are (e.g. biometrics, fingerprints etc.), somewhere you are (e.g. geofencing) or something you do (e.g. how you type). Password managers are encrypted vaults that securely store credentials for users and typically provide an autofill function. Their inherent scalability will always make technical solutions tempting and these provide an important first line of defence. Firewalls, email gateways and other technical filter solutions stop the vast majority of phishing emails from ever reaching users (Dou et al., 2017).

Traditionally, however, filter solutions have sorted emails and senders according to a series of predetermined rules that have left them always one step behind attackers. In order for an attack to be filtered out and a block rule set for the sender, IP address, links, attachment etc., it had to have been seen before. There was no way to filter out “zero day” phishes where no aspect of the email or sender had been seen before. Business Email Compromise attacks were

also hard to filter. Not only do they typically lack links or attachments but they are often sent from a trusted but compromised internal account whose greetings, signatures and writing style they may mimic.

Recently, machine learning approaches have shown great promise in filling this zero day gap with adaptive filters and algorithms that may be able to spot minor divergence from a sender's expected writing style (Lee et al., 2020). As with other areas of machine learning in security, however, this will inevitably lead to the creation of adversarial machine learning algorithms that practise against systems similar to the defending AI. Ultimately, no technical filter will ever catch 100% of attacks, so our defensive model needs additional layers.

Many recognise the limitations of filters but offer second factor authentication (2FA) as a panacea for phishing attacks. 2FA certainly offers some extra protection. A successful attacker might capture a username and password through phishing but be unable to login as the victim without their second factor. Often the second factor will generate time based onetime codes so that, even if a code is compromised, the attack window is usually limited to around sixty seconds. Such 'real time' phishing hacks are possible but are rare due to their lack of scalability. Using Universal Second Factor (U2F) hardware tokens like the Yubikey or Titan provides even more protection. These tokens use site domain as a variable in the generation of their cryptographic keys and so, regardless of user intention, will simply not work on a phishing domain.

Nevertheless, the protection provided by 2FA is often overstated. Regardless of the strength of the second factor, the attacker can use phishing to launch a man-in-the-middle or man-in-the-endpoint attack in which they steal the session cookie. This is the bit of data which allows users to remain logged in to an account even after closing the browser. Assuming the user does not log out, the session cookie remains valid and can be reused by the attacker to simply bypass login.<sup>4</sup>

---

<sup>4</sup> For this and other 2FA hacks see <https://www.knowbe4.com/hubfs/KB4-11WaystoDefeat2FA-RogerGrimes.pdf>



Like hardware 2FA tokens, password managers provide some extra protection because they are designed to only work on a webpage if the domain matches the record for that username/password. A user attempting to autofill on a phishing domain in a browser cannot do so and should be alerted to the attack.

Password managers are, though, not without their vulnerabilities. Not only can they be bypassed with session cookie stealing attacks but they also give users the opportunity to manually cut and paste credentials on to any webpage regardless of domain. Perhaps most alarmingly, a study by Carr and Shahandashti found that, on mobile devices, two out of five well known password managers allowed phishing apps to impersonate a real app and trigger the autofill simply by copying the original package name (Carr and Shahandashti, 2020).

While technical solutions can help, defence in depth requires also enabling users to better defend themselves against the emails that reach them. We must look to harden the human factor.

## 2.2 Nudging: An Alternative Human Factors Approach

Training is one way to harden the human factor but, first, another human factors approach called “nudging” should be addressed. The idea of nudging originates with Cass Sunstein and Richard Thaler who defined it in their book of the same name as a change to the user’s context or “choice architecture” in a way that predictably but non-coercively changes user behaviour. This restriction to non-coercive changes is illustrated with an example: “putting fruit at eye level counts as a nudge. Banning junk food does not” (Sunstein and Thaler, 2008). With nudging users are free to make ‘wrong’ choices but are gently (and usually unconsciously) guided or “nudged” towards the ‘right’ choice by changing the context within which a choice is framed. We can extend the fruit analogy to distinguish nudging from training, where a training approach would focus on conscious decision making by teaching people about nutrition and ways to quickly create healthy meals.

Nudging is now a popular and mainstream technique with successful examples outside of security including traffic light labelling on food (VanEpps et al., 2016), requesting pre-commitments regarding savings (Thaler and Benartzi, 2004) and comparing behaviour (e.g.

electrical usage) to local social norms (Costa and Kahn, 2013). Some governments even have nudging institutes like the Nudge Unit, established by David Cameron in 2010, which has been involved in the UK government's response to Coronavirus (Rutter, 2020). The idea is also widespread within security where we find it, for example, in password strength meters (Komanduri et al., 2014; Ur et al., 2012). Many email clients already include nudges to protect users from phishing attacks. In Figure 3 we have an example from Gmail, which is presented before the user clicks anything and, in Figure 4, an example from Outlook, which is presented after clicking a suspicious link.

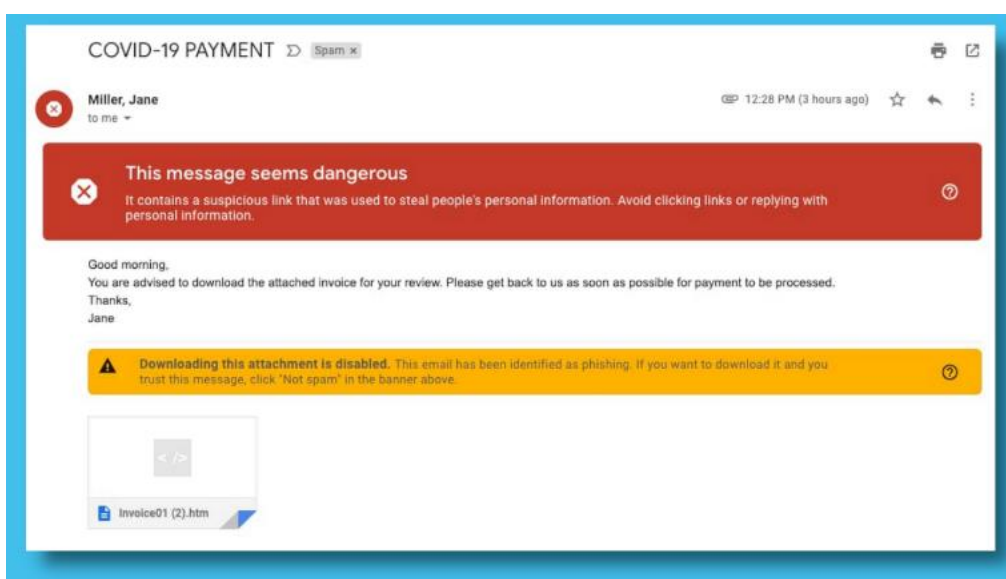


Figure 3: Gmail nudge example (Tidy, 2020a)

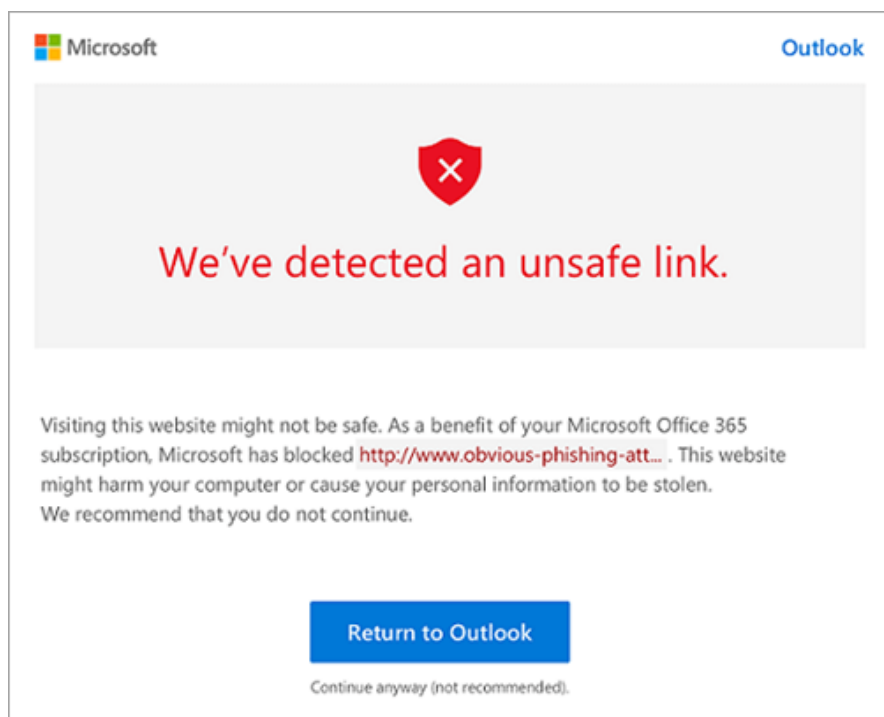


Figure 4: Outlook nudge example (Peswani, 2018)

So how effective is nudging against phishing? Yang et al. found just over a quarter of users ignoring a phish warning bar and proceeding to interact with the phish (Yang et al., 2017). Akhawe and Felt, meanwhile, found only around 10% of malware and phishing warnings ignored on Mozilla Firefox and 25% ignored on Google Chrome (Akhawe and Felt, 2013). While these numbers are heartening, they show this approach is no silver bullet. Nudging is an effective human factors approach but a supplement to user training, not its replacement.

## 2.3 Does Training Work?

### 2.3.1 Increasing Skills Versus Increasing Awareness

Unlike nudging, which focuses primarily on the unconscious, training looks to improve users' conscious decision making by engaging them in an activity that gives them conceptual (knowing that) or procedural (skills/knowing how) knowledge. Some conceptual knowledge will also increase skill but some will merely increase awareness. A poster campaign with generic slogans like Figure 5, for example, might increase user awareness but will not increase anyone's ability to identify phishing emails.

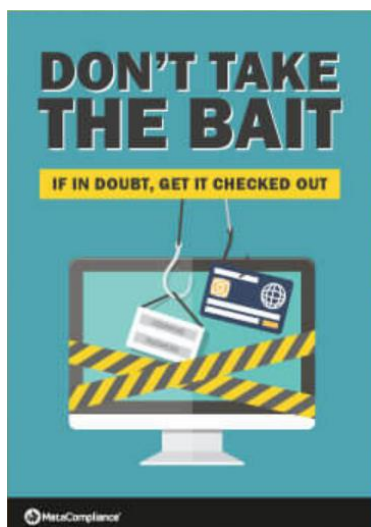


Figure 5: Awareness raising poster (*"Cyber Awareness Posters," 2019*)

Simulated phishing tests of employees measure user vulnerability and do not, by themselves, increase awareness or skills. These are, however, typically paired with notification of testing and individual failures both of which may raise awareness. Furthermore, when a user clicks on a simulated phish, they will usually be presented with “embedded” training which may increase their skills **and** awareness.

Nevertheless, the distinction between skills and awareness is important and we should often ask whether a reduction in phishing susceptibility resulted from increased skills or increased awareness. This is, however, a hard question because it is impossible to increase skills without simultaneously increasing awareness. That an increase in awareness alone can reduce susceptibility to phishing is supported by Halevi et al.’s field study looking at correlations between users’ personalities, their beliefs and their phishing risk. Specifically, they found “an inverse correlation between people’s internet-usage risk perception and their response to phishing” which they felt supported the case for awareness raising training (Halevi et al., 2015).

### 2.3.2 Evidence That Training Works

Despite a lot of early scepticism, there is now a widespread consensus that users can be trained effectively. The list of studies showing correlations between training and reduced phishing risk is extensive. Though Dodge et al. found no significant results in the lab 10 days after training, they did find additional training on the 10<sup>th</sup> day produced a significant reduction in phishing risk

after 63 days. Importantly, the training condition outperformed a condition where users received phishing test failure notifications but no training. This suggests that the benefits of training may include increasing skills and not just awareness (Dodge et al., 2012). Other lab studies by (Kumaraguru et al., 2007b), (Kumaraguru et al., 2009), (Mayhorn and Nyeste, 2012), (Zielinska et al., 2014), (Kumaraguru et al., 2007a) and (Carella et al., 2017) have also found a reduction in clicks on simulated phish after the application of training.

An early field study by Kumaraguru et al. in 2008 of around 100 users at a large Portuguese company found that among those who received training the percentage clicking simulated links and giving information decreased from 42% to 15% after two days (Kumaraguru et al., 2008). In a bigger and more recent field study looking at 4.5 years of phishing training at a US governmental research institution, Greene et al. noted lower click rates post-training (Greene et al., 2018). More evidence from the field comes from a study by Gordon et al. involving almost 3 million emails and 101 campaigns. Looking at phishing simulations across 6 US healthcare institutions, they found a consistent decrease in click rates following internal phishing simulations where user failure triggered embedded training (Gordon et al., 2019a). In a separate study looking in depth at 5416 users in one particular healthcare institution, with a similar pairing of phishing tests and embedded training, the same authors found a decrease in click rates over the course of 20 campaigns (Gordon et al., 2019b).

A connection between training and reduced click rates has also been found in studies by phishing training providers like PhishMe (now Cofense) who reported a reduction from 58% to as low as 5% after only four rounds of training (PhishMe, 2017). Competitor KnowBe4, meanwhile, looked at 4 million of their users in 17,000 companies receiving 9.5 million simulated phish and reported click rates reduced from 37.9% to 14.1% after 90 days of training and down to 4.7% after one year (KnowBe4, 2020). While the conflict in interest raises obvious red flags, we think their access to large real world samples justifies their inclusion in the conversation.

### 2.3.3 Criticism Of Training

Enthusiasm for these positive results should be tempered by some more mixed results that suggest unanswered questions. Most starkly, Caputo et al. found embedded training to have no effect on the click rates or reporting of suspect emails. Regardless of the training they received, 11% of participants were “all-clickers” clicking on almost every link, 22% were “non-clickers” never clicking on anything while 67% exhibited “no consistent clicking behaviour” (Caputo et al., 2014). These negative results echo older studies from when scepticism about training was more common. A small study by Jackson et al., for example, found that reading a help file about fraudulent sites only made participants “more likely to classify both real and fake web sites as legitimate” (Jackson et al., 2007). Similarly, Anandpara et al. found existing training only made users more concerned and no more able to distinguish legitimate emails from phish (Anandpara et al., 2007). In the public sphere beyond academia, Martin Overton, a security specialist then at IBM, notably declared user education “about as much use as nailing jelly to the wall” (Evers, 2006) while usability expert Jakob Nielsen stated that training simply “**doesn’t work**” [original emphasis] (Nielsen, 2004).

However, as has been pointed out by others like (Kumaraguru et al., 2010), early critical studies like (Jackson et al., 2007) and (Anandpara et al., 2007) used distinctly unengaging training materials. These often amounted to text files that were not “embedded” in the sense of being delivered immediately to the user upon failing a phishing test. Since these early studies there has been an emerging consensus, starting with (Kumaraguru et al., 2007b), that learning outcomes improve when training is embedded rather than delivered out of context.

Interestingly, this belief seems shared by users themselves (Caputo et al., 2014). Unembedded training does not, however, explain more recent sceptical results, like Caputo et al. 2014, where the training materials were embedded. Caputo et al.’s results may, however, again have resulted from poor quality training materials with most interviewed participants reporting that they ignored or skimmed most of the text on the training page which was described as “too dense”, “cartoonish” and insulting (Caputo et al., 2014).

Even some of the recent field studies that support the efficacy of embedded user training also highlight glaring room for improvement. Though Gordon et al. showed a significant decrease in

click rates over simulated phishing campaigns within US healthcare institutions, the median click rate was 16.7% in places where training was already taking place (Gordon et al., 2019a). The broader state of US healthcare beyond these studies also suggests problems with training. The HIPAA law demands that all US healthcare institutions “implement a security awareness and training program for all members of its workforce (including management)” (HHS.gov, 2009) and yet the sector continues to suffer serious incidents where phishing is one of the main causes. A recent example of this is the UCSF medical school paying out \$1.14 million to the Netwalker ransomware group who, like many ransomware operations, infiltrate networks through phishing (Tidy, 2020b).

We should also consider that, even if training has some effect, there may be multiple human factors that create user vulnerability and contemporary training may not affect all of them. Perhaps there are some parts of the mind that current education can’t reach. In this vein, Vishwanath et al. concluded that user vulnerability lay in “the conscious, cognitive factors, the preconscious influence of cyber-risk beliefs and the automatic, nonconscious actions.” A significant amount of contemporary training, they worry, targets only the user’s ability to “cognitively process and spot deceptive cues”, and so may leave untouched the equally important automatic/unconscious email habits (Vishwanath et al., 2018). Meanwhile, in looking for the personality traits associated with phishing vulnerability, Moody et al. found “curiosity”, “risk propensity” and over confidence (via experience) to be significant factors (Moody et al., 2017). It is unclear the extent contemporary training addresses these three factors and if curiosity is even something that could (or should) be trained.

## 2.4 Who Most Needs Training?

For the greatest impact and value for money, training should focus on those who need it most. So which demographics are most susceptible to phishing? Many demographic variables have been investigated with the most covered undoubtedly being age and gender. A discussion of all possible demographic variables is beyond our scope, though an excellent recent summary can be found in Jampen et al. (Jampen et al., 2020). Let us examine to what extent age, gender, technical skills and country of origin have previously correlated with phishing susceptibility.

#### 2.4.1 Age And Phishing Susceptibility (R1)

Regarding research question R1 on the relationship between age and phishing susceptibility, the literature is mixed. Half of the sixteen studies we surveyed found age to have no significant impact on phishing susceptibility (De Bona and Paci, 2020; Greitzer et al., 2021; Hanus et al., 2021; Kumaraguru et al., 2007b; Mohebzada et al., 2012; O'Connor et al., 2021; Sarno et al., 2020; Zielinska et al., 2014). Those that found age to have a significant impact on susceptibility are divided on whether older or younger participants are more vulnerable. Three studies found users under 25 to be the most vulnerable in their samples (Kumaraguru et al., 2009; Rastenis et al., 2019; Sheng et al., 2010). The remaining five studies found greater vulnerability in older participants (Gopavaram et al., 2021; Greitzer et al., 2021; Grilli et al., 2020; Li et al., 2020; Taib et al., 2019). For Greitzer et al. and Li et al. this increased susceptibility was found for participants 59 and over. Taib et al., however, found greater susceptibility of adults over 32 with little difference found between users aged 32-40 and users over 41 (Taib et al., 2019).

#### 2.4.2 Gender And Phishing Susceptibility (R2)

Regarding research question R2 on the relationship between gender and phishing susceptibility, studies are inconclusive but lean slightly towards finding female participants more vulnerable. Eleven find no significant correlation (Benenson et al., 2017; De Bona and Paci, 2020; Diaz et al., 2020; Gopavaram et al., 2021; Greitzer et al., 2021; Karumbaiah et al., 2016; Kumaraguru et al., 2009, 2007b; Rastenis et al., 2019; Taib et al., 2019; Zielinska et al., 2014). Another eleven found a significant correlation. Eight of these have found women more susceptible (Halevi et al., 2015; Hanus et al., 2021; Hong et al., 2013; Iuga et al., 2016; Jagatic et al., 2007; Lin et al., 2019; McGill and Thompson, 2021; Sheng et al., 2010). Among these, Lin et al. found older women to be the most susceptible demographic in their sample (Lin et al., 2019) though Hanus et al. found young women the most susceptible (Hanus et al., 2021). Another three have found men more susceptible (Li et al., 2020; Mohebzada et al., 2012; Waldo Rocha Flores et al., 2014).

This slight lean towards women being more vulnerable is sometimes explained by the combination of two things: research suggesting women have, as discussed in 2.4.3, less technological opportunities and research suggesting lower digital skills are correlated with



higher phishing susceptibility. The context is well summarised in a 2018 OECD report on the digital gender divide.

“The road ahead is uphill: today worldwide some 327 million fewer women than men have a smartphone and can access the mobile Internet. Women are under-represented in ICT jobs, top management and academic careers and, as shown in this report, men are four times more likely than women to be ICT specialists. At 15 years of age, on average, only 0.5% of girls wish to become ICT professionals, compared to 5% of boys.” (OECD, 2018)

#### 2.4.3 Technical Skill And Phishing Susceptibility (R3)

Regarding research question R3, the relationship between technical skill and phishing susceptibility, most studies have found lower technical skill to be correlated with higher phishing risk. Two studies (Gopavaram et al., 2021; Vishwanath et al., 2011) found no statistically significant correlation between technical skill and phishing susceptibility while another two found phishing vulnerability to rise with technicality (Kumaraguru et al., 2008; Parsons et al., 2013). Seven studies, however, have found people with higher technical skills to be less vulnerable (Anawar et al., 2019; Diaz et al., 2020; Flores et al., 2015; Gopavaram et al., 2021; Pattinson et al., 2012; Sheng et al., 2010; Waldo Rocha Flores et al., 2014).

#### 2.4.4 Country Of Origin (R4)

Regarding research question R4 on the relationship between country of origin and phishing susceptibility, the evidentiary base is thin. Given the existence of “information cultures” in groups that influence individuals approach to risk (Choo, 2013), it seems intuitive that, as Henshel et al. argue, a consideration of cyber security’s human vulnerabilities should include examination of “individuals’ national culture” (Henshel et al., 2016).

It is strange then how few studies directly compare phishing susceptibility between countries. Flores et al. found national culture had an “influence on the correlation between phishing determinants and employees observed phishing behavior [that] differs between Swedish, US and Indian employees” but they do not share the national breakdown of things like the click rate (Flores et al., 2015). Meanwhile, using a survey design, Al-Hamar et al. found residents of

Qatar to be more vulnerable to phishing than UK residents (Al-Hamar et al., 2011). Lest we think UK residents especially phish resilient, however, Gopavaram et al. found New Zealand and the United Kingdom to lag considerably behind Australia, Canada and the USA in both identifying phishing sites and legitimate sites. Australia had the highest median score for spotting legitimate websites with Canada and the United States in second place (Gopavaram et al., 2021).

## 2.5 Games And Gamification In Training

Given the need to reach different demographic groups and the room for improvement in modern embedded training, we should consider alternative modes of training and training delivery. There are many options beyond plain text and video but perhaps the fastest growing is serious games and gamification.

### 2.5.1 What Are Serious Games and What Is Gamification?

Before considering whether the existing literature supports hypothesis H1 or H2, let's consider the nature of serious games and gamification. A serious game is any game where the main objective is something beyond entertainment while gamification refers to training materials that may not constitute a fully fledged game but which incorporate game-like dynamics such as leaderboards, points, levels, achievements, spendable resources, instant feedback, work/reward cycles, social elements and "boss battles" (Francia et al., 2014). Regarding phishing training, serious games divide into multiplayer "tabletop" games and computer-based games which are normally single player.

### 2.5.2 Advantages And Disadvantages Of Games And Gamification In General

Employees unused to being monitored may perceive phishing tests as a "observation tool" and there is a danger they may react negatively (Jampen et al., 2020). Aside from its impact on learning, this tendency is deeply concerning given the well-established damage insider threats currently cause organisations.

With gamified training, however, users may be less likely to feel they are in an adversarial relationship with the employer, IT department or security awareness training vendor (Jampen et al., 2020). The entertainment value of a game or gamified activity can counterbalance

negative perceptions of phishing tests. It can also allow for an increase in employee training time without tipping over into the “security fatigue” experienced by many who feel bombarded by more traditional materials. As Roepke et al. observe, the atmosphere is safer and more relaxed for users than traditional embedded training (Roepke et al., 2020).

The hope is that the greater engagement caused by this enjoyment will lead to greater motivation, greater attention and so greater learning outcomes. This is certainly supported by the wider gamification education literature with a 2020 review of 46 gamification studies by Zainuddin et al. noting both that “the more engaged students are, the greater their achievement” and that most gamification studies showed improvements “not only in students’ motivation and engagement, but also in their learning achievement” (Zainuddin et al., 2020).

The competitive aspect of gamification where users try to “beat” each other and end up discussing materials can also encourage peer learning and feedback. That users welcome these competitive game mechanics is suggested by observations from field studies of phishing training. In these, many users have been observed spontaneously gamifying traditional training by trying “to beat their colleagues and be the first person to spot the training phishing email” (Greene et al., 2018). In their review of gamification studies in education, Zainuddin et al. concluded that they believed such “social comparison can explicitly promote social connectivity and a sense of relatedness amongst students” (Zainuddin et al., 2020).

Games and gamified security education materials, however, also come with some disadvantages. Many require too much time to allow delivery as immediate embedded training to users upon their failure of a phishing test. This is, given the benefits of immediate training, regrettable. Non-digital tabletop games that are delivered with the help of a facilitator have many benefits but, as Roepke et al. point out, are inherently unscalable with any significant increase in users requiring an increase in facilitators. Computer based single player games are, by contrast, scalable but are usually harder to update than tabletop games or traditional training materials (Roepke et al., 2020). This adds to their cost over time and is problematic in a world where phishing tactics are constantly evolving. Once useful advice often ends up

increasing user vulnerability e.g. advising users that phishing emails will always contain typos or poor grammar.

### 2.5.3 A Review Of Phishing Games

There are, at the time of writing, seven notable phishing games in the literature around phishing training. There have been regrettably few independent trials of commercially available phishing games with most published papers using a game created specifically for the experiment. One of the few exceptions to this is Anti-Phishing Phil which was made for research but has since been used by a commercial security awareness provider. For this thesis, research licenses for their games were requested from half a dozen major training providers. All of these either refused or failed to respond so our work focuses on games in the academic literature.

These seven games were identified using the following method. With over 558 citations, Anti-Phishing Phil is clearly the cornerstone of the phishing game literature so we used this as our starting point (Sheng et al., 2007). This anti-phishing game appeared to be the first of its kind but to confirm this we checked the titles of all studies cited by Sheng et al. as well as searching in Google scholar for **intitle:phishing game** pre-2008 which returned 58 results. After checking titles and abstracts, the only anti-phishing game was Anti-Phishing Phil. Then, looking forward, we examined the 558 studies that cite Anti-Phishing Phil, looking at titles and, where necessary, abstracts to determine which contained anti-phishing games. Of these, we then eliminated those who were not either published in peer-reviewed journals, conference proceedings or book chapters. Some of the remaining papers discussed the construction of a game but did not test it on users, so our set was further limited to only those where the game was evaluated using adult participants. This left the 7 shown in Table 2 and reviewed below.

| <b>Game</b>        | <b>Sample Size</b> | <b>Number of Conditions</b> | <b>Compares Game Against Traditional Training Condition?</b> |
|--------------------|--------------------|-----------------------------|--------------------------------------------------------------|
| Anti-Phishing Phil | 42                 | 3                           | Yes                                                          |
| Smells Phishy      | 21                 | n/a (usability testing)     | n/a                                                          |
| NoPhish            | 32                 | 1                           | No                                                           |
| What.Hack          | 39                 | 3                           | Yes                                                          |
| Phishy             | 8071               | 1                           | No                                                           |
| Birds Life         | 100                | 1                           | No                                                           |
| Securix            | 50                 | 1                           | No                                                           |

Table 2: Overview of phishing games

### 2.5.3.1 Smells Phishy

Smells Phishy, seen in Figure 6 and Figure 7, is a board game created by Baslyman and Chiasson where two to four players attempt to simultaneously fill a shopping list while avoiding phishing scams. The game ends when one player successfully fills their shopping list (Baslyman and Chiasson, 2016).

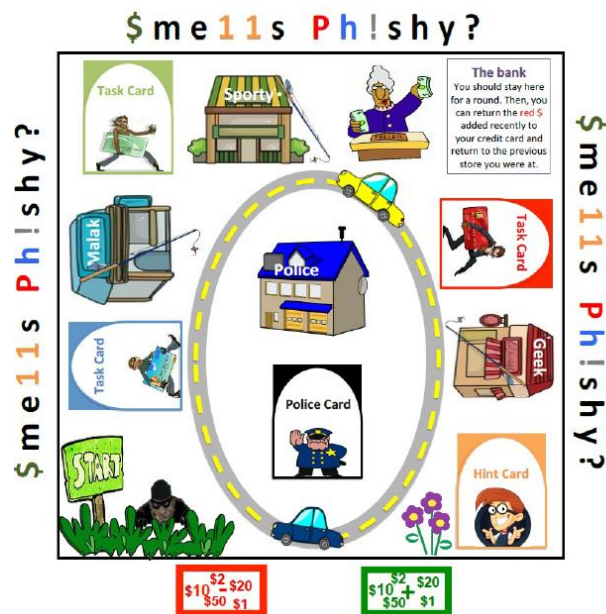


Figure 6: Smells Phishy gameplay example 1 (Baslyman and Chiasson, 2016)



Figure 7: Smells Phishy gameplay example 2 (Baslyman and Chiasson, 2016)

### 2.5.3.2 Anti-Phishing Phil

By far the most cited game is Anti-Phishing Phil where users play a small fish called Phil who tries to decide whether the URL next to a worm goes to a legitimate site or a phishing site. He then eats legitimate worms and rejects the fraudulent ones. Tips are provided throughout by Phil's father in the bottom right-hand corner of Figure 8 (Sheng et al., 2007).

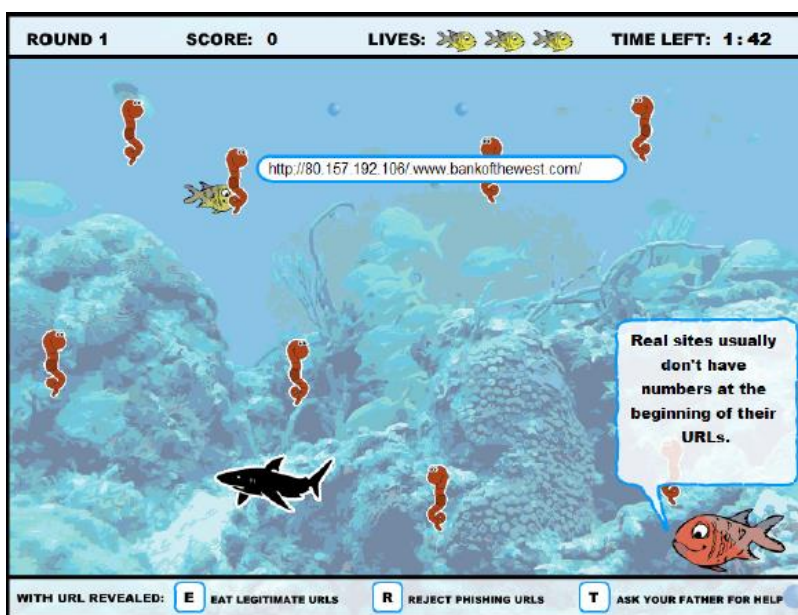


Figure 8: Anti-Phishing Phil gameplay example (Sheng et al., 2007)

### 2.5.3.3 NoPhish

Another mobile game is the Android App NoPhish, shown in Figure 9, where users start with 'lives', represented by hearts, and gain points for correctly assessing URLs. Successful identification not only leads to points but unlocks additional levels (Canova et al., 2014).

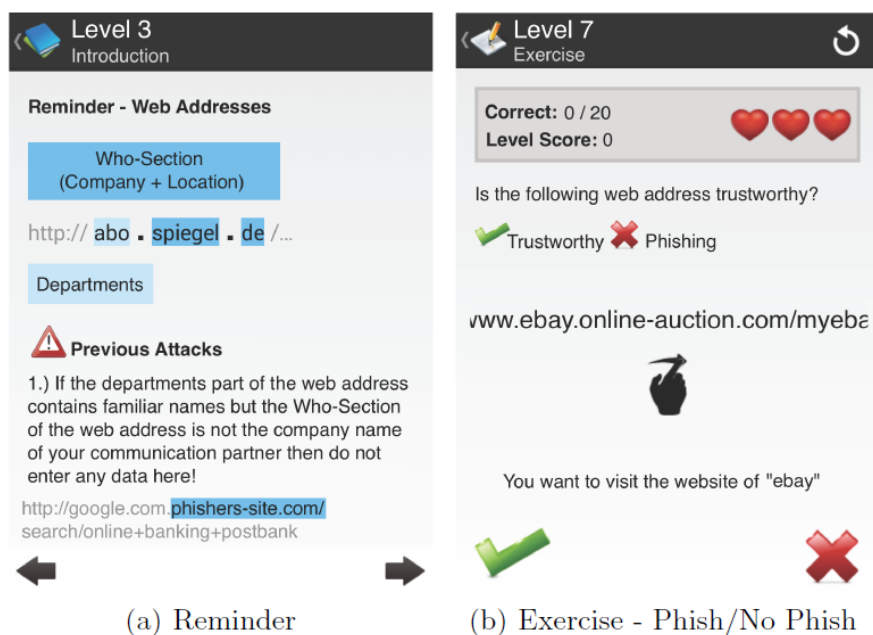


Figure 9: NoPhish gameplay example (Canova et al., 2014)



#### 2.5.3.4 What.Hack

What.Hack, shown in Figure 10, is an extremely immersive game where users play the role of a bank employee and win by getting contracts for the company, dealing with general work emails and not falling for phishing. The addition of these non-security goals is an important part of making simulation context as realistic as possible. The game is built around the encoding specificity theory: that we learn new skills best when the learning context is most similar to the context in which we will use the skill. In the real world users have responsibilities and goals that include but extend beyond not falling for phishing emails (Wen et al., 2019).

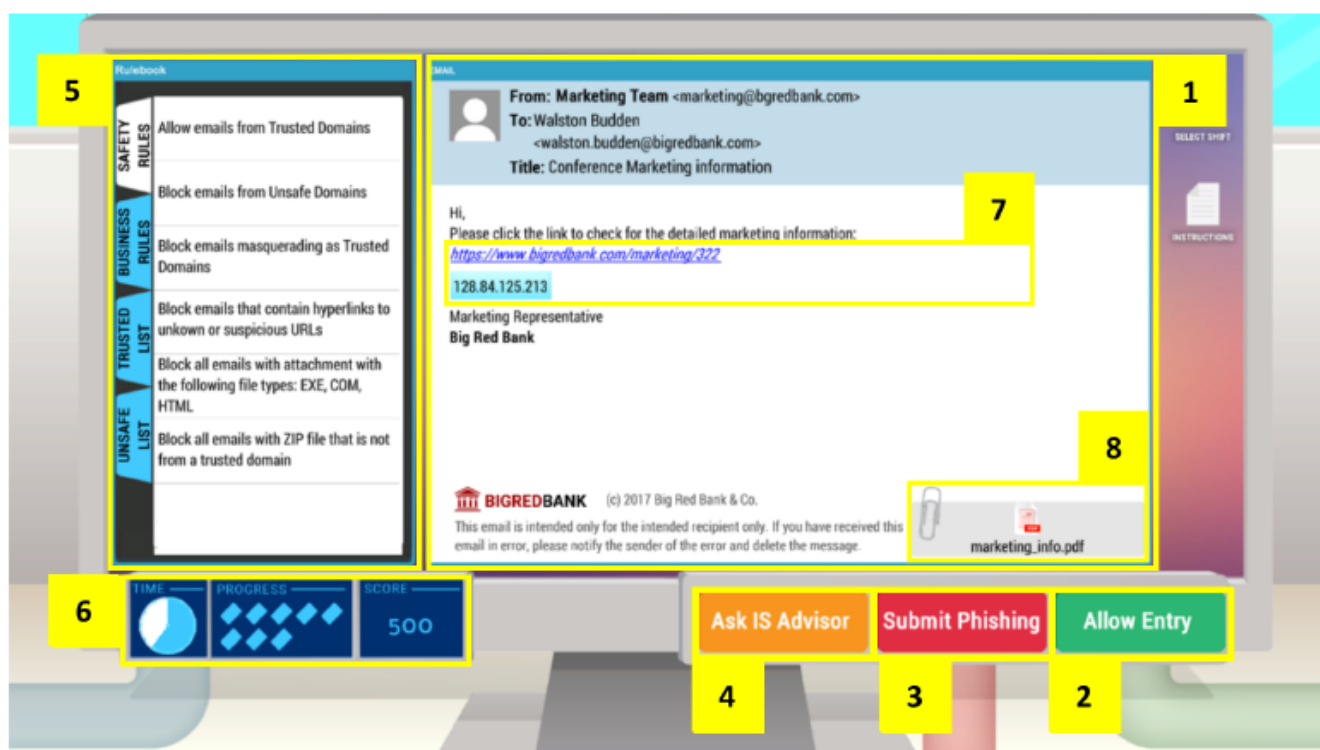


Figure 10: What.Hack gameplay example (Wen et al., 2019)

### 2.5.3.5 Phishy

Phishy, shown in Figure 11 and Figure 12, is a JavaScript, browser based single player game. Its intro consists of a comic strip showing Sam who receives an email telling him he has won \$5m and a cruise. The email instructs Sam to click a link and enter his bank details which he does. He then wakes up finding that criminals have taken all his money and left him on a boat with a hungry tiger. While finding his way back home, Sam must deal with the tiger and avoid other dangers like sharks and octopi. Sam must feed the tiger fish and each time he fails the tiger moves a step closer to him. To feed the tiger Sam hooks fish and then answers a question about URLs correctly. Tips for how to answer these questions are provided at the beginning of each level (Gokul et al., 2018).



Figure 11: Phishy gameplay example 1 (Gokul et al., 2018)



Figure 12: Phishy gameplay example 2 (Gokul et al., 2018)

### 2.5.3.6 A Bird's Life

A Bird's Life, shown in Figure 13 and Figure 14, is a 2D game where players control a red bird who tries to collect grey worms and avoid not only red worms but other obstacles such as wheels and yellow birds. Collecting three grey worms results in a security tip about phishing with five tips being required to pass the level (Weanquoi et al., 2018).



Figure 13: A Bird's Life gameplay example 1 (Weanquoi et al., 2018)



Figure 14: A Bird's Life gameplay example 2 (Weanquoi et al., 2018)

### 2.5.3.7 Securix

Securix, shown in Figure 15, Figure 16, Figure 17 and Figure 18 is an immersive 3D game where the user plays a new employee trying to gain promotion. In the course of the new employee's day, they are presented with URLs, emails and websites which they must classify as safe or unsafe. Correct classification results in points, level raises and promotions represented by moves to new 3D rooms (Onashoga et al., 2019).

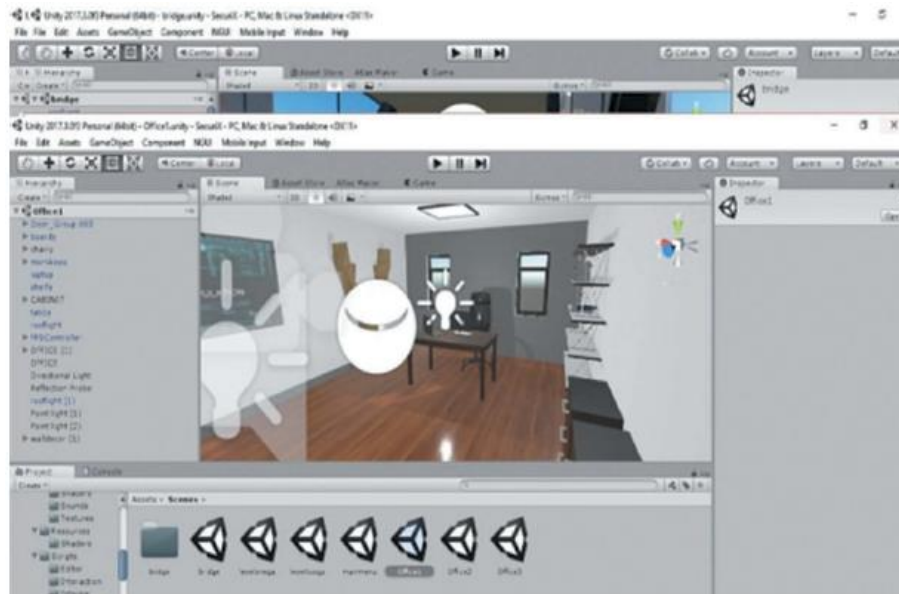


Figure 15: Securix Level 1 (Onashoga et al., 2019)



Figure 16: Securix URL tutorial (Onashoga et al., 2019)

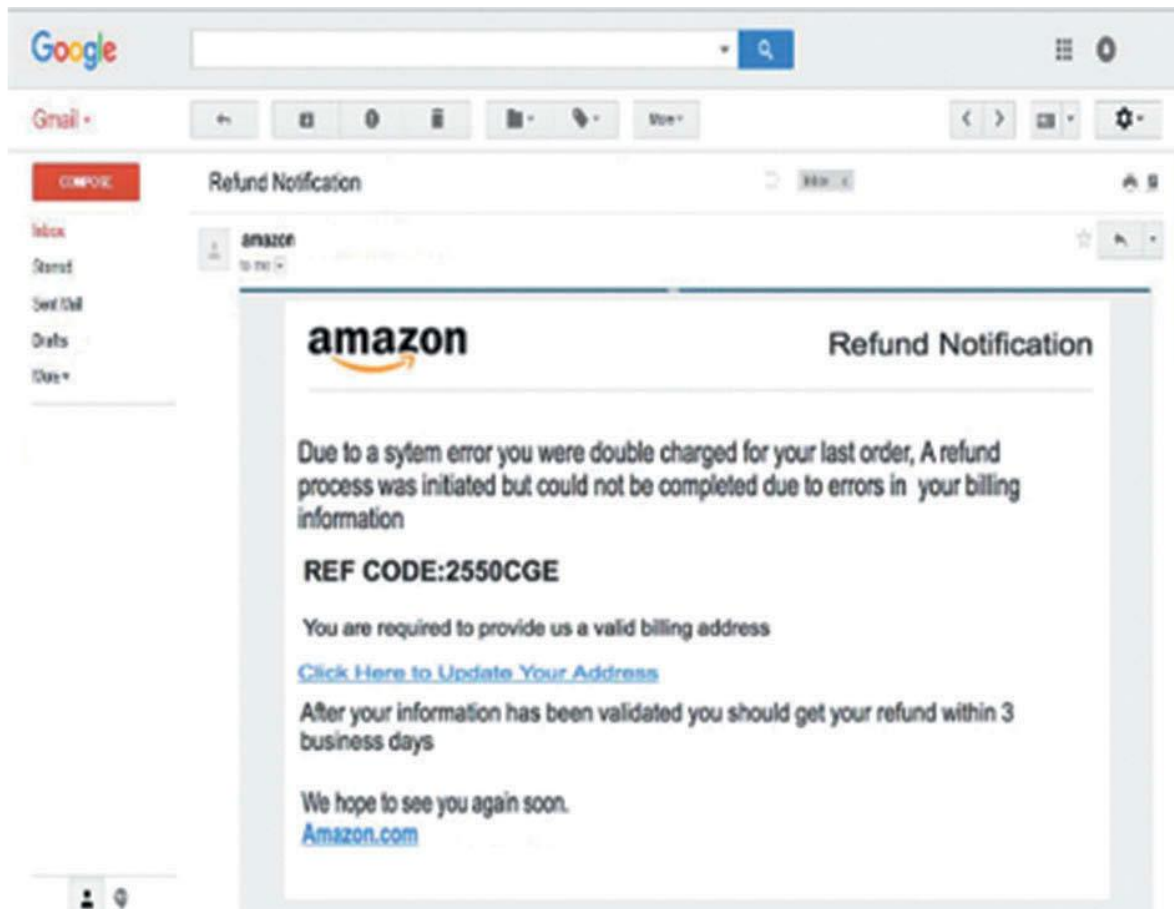


Figure 17: Securix email test (Onashoga et al., 2019)

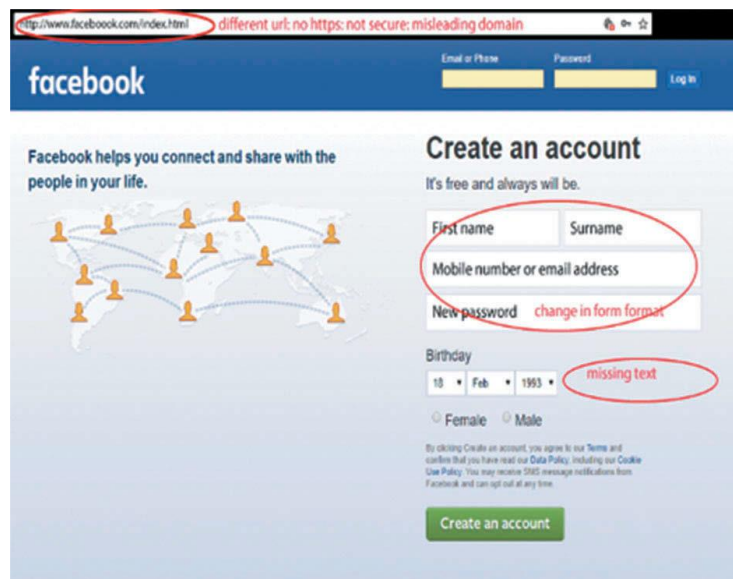


Figure 18: Securix website test (Onashoga et al., 2019)

#### 2.5.4 Are Phishing Games Effective?

What evidence is there that games and gamification work for learning more generally? Reviews of gamification in education have been positive with Zainuddin et al.'s review of 47 studies noting most showed "improvements" in "learning achievements" (Zainuddin et al., 2020). Similarly, Bai et al.'s review of 24 studies concluded that there is "an overall significant medium effect size in favor of gamification over learning without gamification" (Bai et al., 2020). Meanwhile, the two most recent surveys of cyber security training games found the evidence promising but stopped short of all out endorsement. Tioh et al. spoke of "generally positive early indications" that have not yet been "conclusively" proven (Tioh et al., 2017) while Hendrix et al. were similarly positive but expressed regret at small sample sizes and the absence of reported effect sizes in a number of studies (Hendrix et al., 2016).

##### 2.5.4.1 Learning Outcomes And Methods Of Evaluation In Phishing Games

By far the most dominant metric for evaluating phishing training more generally has been click-through rates. In Jampen et al.'s survey of training efficacy it is used by the vast majority of the papers in their review. As we discuss in 3.1, this approach has some disadvantages in viewing user vulnerability as binary (click/not click) and not recognising the difference, for example, between a user that clicks and one that clicks *and then* enters sensitive data. However, not only is this way of quantifying vulnerability easily measured at scale but it also allows easy comparison to a vast literature that uses the same metric.

Regarding learning outcomes measurement, of our 7 phishing games Anti-Phishing Phil, What.Hack and No Phish all present users with a binary safe/not safe choice when comparing websites (Anti-Phishing Phil), emails (What.Hack) and URLs (NoPhish) that allows some comparability to this wider "click-rate" evidence base for phishing training. A Bird's Life, Smells Phishy and Phishy all used quizzes that give results that are perhaps richer but are less comparable to the wider literature. Learning outcomes evaluation in Securix is limited to a qualitative survey asking users how much they felt they learned.

As with the gamification of security training in general, support for hypothesis H1 and the effectiveness of these phishing games is promising but not yet conclusive. The most well-known



game, Anti-Phishing Phil, saw an 18% improvement in participants' ability to distinguish 10 legitimate websites from 10 phishing sites (Sheng et al., 2007). Importantly, though, when Anti-Phishing Phil was tested as a condition in the What.Hack study, the authors found no significant improvement in participants. What.Hack, itself, meanwhile, saw participants' ability to distinguish phishing emails from legitimate ones improve by 36.7% (Wen et al., 2019). In Kunz et al.'s evaluation of Canova et al.'s game NoPhish the results are also promising with participant ability to distinguish legitimate and phishing URLs improved relative to a pre-game test for six out of seven types of phishing tactics (Kunz et al., 2016). A Bird's Life also saw healthy improvements with 67% of participants showing improvement in the pre and post-game phishing quiz (Weanquoi et al., 2018). Meanwhile, a usability study of the boardgame Smells Phishy found that, while prior to the game half of the participants could describe phishing and explain some phishing countermeasures, after exposure to the game all participants could do this (Baslyman and Chiasson, 2016). Another usability study, Securix, unfortunately only reports the qualitative results of a survey where 80% of players said they learned a lot (Onashoga et al., 2019). Testing of Phishy showed promising results with the number of participants giving 7-9 correct answers in a phishing URL quiz increasing from 3086 pre-test to 4350 post-test (Gokul et al., 2018).

#### 2.5.4.2 Do Users Enjoy Phishing Games?

The evaluation of these phishing games also suggests that users enjoy gamification. Over 95% of Phishy players agreed "the game was fun" (Gokul et al., 2018), 88% of participants in A Bird's Life agreed "the game was enjoyable to play" (Weanquoi et al., 2018) and 74% of Securix players agreed that "I think I would like using this game often" (Onashoga et al., 2019). When players of Smells Phishy were asked to what extent (1-5 with 5 being strongly agree) they agreed with "the game was fun", the mean answer was 4.6 (Baslyman and Chiasson, 2016). Players of What.Hack found it both more engaging than traditional training and would be more likely to recommend it to a friend (Wen et al., 2019). In the original study, Anti-Phishing Phil found 50% of users rating the "fun level" of the game as "very good or excellent" in contrast to 29% for traditional training (Sheng et al., 2007). It should be noted, however, that, when used as a condition in What.Hack, Anti-Phishing Phil was not rated as more engaging than traditional

training by users and they were no more likely to recommend it to a friend (Wen et al., 2019). The evaluation of NoPhish, sadly, contains none of these engagement metrics (Kunz et al., 2016).

## 2.5.5 Some Worries About Phishing Games

### 2.5.5.1 Underrepresentation Of People Of Retirement Age

The logistical realities of recruiting participants on campus or in the workplace mean most of these studies samples tend to under represent people of retirement age. The otherwise excellent Anti-Phishing Phil study (Sheng et al., 2007), for example, had no participants over the age of 34 in two out of three of their conditions. Smells Phishy, meanwhile, had no participants over the age of 44 (Baslyman and Chiasson, 2016). The evaluation of NoPhish by (Kunz et al., 2016) had participants as old as 56 but the mean age was still 28.54 (SD 10.79). Composed of students, faculty, banking employees and children, Securix contains no one of retirement age or over (Onashoga et al., 2019). The age of participants in What.Hack (Wen et al., 2019) and A Bird's Life (Weanquoi et al., 2018) is not mentioned, though it is stated that all were students. Because Phishy's participants were all employees of the Tata company, seniors were under represented with less than 1% of the sample over 50.

### 2.5.5.2 Problematic Comparisons To Traditional Training

When we look for comparisons with the efficacy of existing training to support H1, we have only two studies: What.Hack and Anti-Phishing Phil. In Bird's Life, Phishy, Smells Phishy (because it is a usability study), Securix (again a usability study) and NoPhish there is no direct comparison to a non-gamified condition.

Anti-Phishing Phil's 18% improvement is impressive next to the 8% improvement from the condition meant to represent traditional training. It is, however, less impressive next to the 15% improvement from the group using a non-gamified tutorial based upon the game's content (Sheng et al., 2007). This 3% lead looks even more tenuous given Anti-Phishing Phil's failure to outperform traditional training (both getting no significant improvement) when it was used as one of the control groups in the What.Hack game study. The What.Hack game itself, however,



outperformed the non-improvement of traditional training Phishline by 36.7% (Wen et al., 2019).

It should also be noted that the comparisons with traditional training that we do have are inherently problematic. As discussed previously, where traditional training is successful a great deal of that success comes from its delivery in an embedded format. Embedded training is delivered immediately to the user after they fall for a simulated phishing test in the course of their normal workday. When gamified training is compared with traditional training, this embedded edge is usually lost. This is, of course, not the fault of experimenters. Comparing gamified and traditional training in an embedded setting is a huge logistical challenge. The absence of this comparison should, however, be noted. Embedded training taken out of context is a phish out of water and necessarily at a disadvantage in any comparison. Not only do we need more evidence for the efficacy of gamified phishing education but we also need more data to show conclusively that the results are better than what we would get with traditional *embedded* training.

Sadly, games and gamification researchers find themselves in a Catch 22 regarding proper A/B comparisons with traditional training. On one horn of the dilemma, efforts to make rich engaging games make proper A/B testing impossible. If we take the comparison between What.Hack and Phishline, for example, the two conditions are so different that it is unclear whether different outcomes reflect different game elements or different content. Here Anti-Phishing Phil is to be lauded for having a condition where traditional training uses the educational content of the game. Even here, though, we are far from a strict A/B test because, even if we accept game components are responsible for improved outcomes, as Jampen et al. point out, we can't isolate which game mechanic is responsible (Jampen et al., 2020). If we are to make real progress in reducing user phishing risk with gamified education, we will need more studies that isolate individual game mechanics. This, however, brings us to the other horn of the dilemma. The gamified condition in a strict A/B test would be so stripped of its gameness that the result will, at best, tell us about gamification but not about the strength of full blown games. Going forward we will need both more testing of full blown games and more tests of gamified training that try to assess the contribution of individual game mechanics.

### 2.5.5.3 Retention: Do Users Remember The Content Of Games?

In comparing games and gamification to traditional training, we also need more data on users' skill/knowledge retention over time if we are to test our H2 hypothesis. Due presumably to the logistical challenges involved, many of the games reviewed here voice their desire to run such longitudinal studies but **so far none have**. As Caputo et al. note, these challenges are particularly acute with field studies where the turnover of many organisations' staff means it's hard to follow individuals over time (Caputo et al., 2014).

Retention data is something that, as Jampen et al. note, is also lacking in research on traditional embedded training where again we find many authors suggesting it but very few implementing it (Jampen et al., 2020). Some notable exceptions include Kumaraguru who, in field studies, found no real loss in retention for embedded training at both 7 days (Kumaraguru et al., 2008) and 28 days (Kumaraguru et al., 2009) and Caputo et al. who found no effect for embedded training after 90 days though they concede that "training effects might be lost somewhere between Kumaraguru and his colleague's 28 days and our longer testing intervals" (Caputo et al., 2014). Interestingly Dodge et al. found the learning gains from initial training to have entirely evaporated after 10 days though some effects of additional training on the 10<sup>th</sup> day appeared to last till the 63<sup>rd</sup> when Dodge et al. saw a statistically significant improvement over a control group (Dodge et al., 2012). This is in line with the belief of many researchers, such as Schroeder, that for training to be effective it must be repeated regularly (Schroeder, 2017). How regular training should be has yet to be conclusively determined.

## 2.6 The Contribution Of This Study

Our study aims to explore the hypotheses and research questions laid out in 1.1. and in doing so fill some gaps in the existing literature. Specifically, our study will be one of the few to provide an A/B test between games and traditional training as well as being the first phishing game experiment to examine knowledge retention. The study will also contribute to the wider anti-phishing training literature where, as noted, retention studies exist but are few and mixed.

## 3 Methodology

### 3.1 Methodology Overview

Our online experiment used a between subjects design with participants randomly assigned to one of three training conditions. The learning objective was to teach conceptual knowledge (i.e. ‘knowing that’) about the difference between a URL’s root and sub-domains along with the procedural knowledge (i.e. ‘knowing how’) of spotting a link’s true root domain. Participants were assessed by their ability to classify URLs as “safe” or “unsafe.” Pre and post-training assessments took place immediately before and after training while retention assessment prompts were emailed one week later.

Participant performance on the first stage of the experiment, containing pre and post training assessments, was connected to the second retention stage through pseudo-anonymous ID numbers which replaced unique participant email addresses. Verifiable evidence of the data’s authenticity was provided by a separate email-to-id file. To reconcile audit and privacy requirements, this file was physically printed and soft copies destroyed.

Scores on the pre, post and retention assessments, where URLs were classified as safe or unsafe, acted as our dependent variable. Arguably, additional response options beyond safe/unsafe would have meant richer data and the relative lack of this is regrettable in the wider phishing training literature. Like focusing purely on click rates, this arguably risks a narrow view of users as simply liabilities rather than as assets who can help secure organizations by reporting suspicious emails. It also fails to adequately represent that breaches come in degrees and not a simple “breached/not breached” dichotomy. If two employees click on a link but the second enters data on the phishing website, the second case is more serious. Similarly, downloading a malicious attachment is bad but opening it is worse. This richness would, however, make our work less comparable to the existing literature which, as noted in 2.5.4.1, often uses safe/not safe type dichotomies.

The mode of training received was our independent variable. In the first condition users received relevant traditional training, in the second condition users received gamified training and in the third awareness condition users received irrelevant training. As a result, this third

awareness condition also functioned as a control. At the end of the first stage, after the post-training assessment, participants completed an exit survey containing demographic questions. The opportunity to give feedback was given both at the end of the first stage and after completion of the retention stage.

While phishing tactics include the use of IPs in addresses, deceptive sub-domains, lookalike domains, malicious attachments and more, we limited ourselves to deceptive sub-domains (e.g. google.business.com) to limit participation time and subject drop-offs.

## 3.2 Experimental Conditions

Our experiment contains three conditions

- Traditional Condition
- Gamified Training Condition
- Awareness (Control) Condition

### 3.2.1 Traditional Training Condition

The traditional training centred around guidance from Stichting Internet Domeinregistratie Nederland (SIDN) who control the .nl top level domain.

“Tip 3. Remember: the actual domain is at the end

To see what the actual domain is, look at everything between the https:// and the first / in the address. In our second example, that's 'www.example.nl.examplelogin.nl'. The actual domain is always the last part of that string. So you can see that if you click on our example URL, it'll take you to examplelogin.nl. If there isn't a /, read the last part of the URL first.” (SIDN, 2021)

This was paraphrased and then expanded on with examples, an analogy and a flowchart diagram. Participants were also given two practice examples (one safe, one unsafe) applying the rule and feedback on this practice. One of these practice examples can be seen in Figure 19. In contrast to the gamified condition, this feedback was the same whether or not the participant answered correctly in that it merely revealed and explained the correct answer. Traditional training materials can be seen in full in 7.2.

If you received some emails containing notifications about your Paypal account, would this link be safe to click on?

<https://www.account.paypal.com>

safe

not safe

Figure 19: Traditional training practice example

### 3.2.2 Gamified Training Condition

Users in the gamified condition received the same advice, practice materials and feedback as in the traditional condition but in a different format. The materials were embedded in a story where player choices determined points gained and narrative feedback from non-playing characters.

Subjects play a “Web Guardian” hired by the Deep Sea City Council’s Mayor to advise local fish on suspect emails they’ve received. The training content arrives in emails from their manager, Deep Sea Council’s Head of IT Priya Piranha, while practice URL examples arrive as cartoon fish who enter the player’s office, share their online experiences and ask for advice on a URL. Players must determine if the URLs are safe or unsafe and then receive feedback from their manager, Priya. Each successful classification of a URL accrues points and praise from Priya while incorrect classification earns gentle correction. With enough points, they ‘win’ the game by receiving the employee of the month award and a year’s supply of plankton. Insufficient points result in reassurance from the IT Manager and a new employee bonus of one month’s worth of plankton as consolation prize.

Figure 20 shows one of the practice examples while in Figure 21 we see a diagram of the game flow. The full game materials can be found in 7.4.



No sooner have you settled into your office than Alex swims in. Alex is excited about getting hard-to-find products online. Very much the community trendsetter, they are hoping to be the first local fish with trousers. You pause, struggling to picture this, but then remember the City Council's commitment to judgment-free advice. Steering clear of fashion dilemmas, you manoeuvre the conversation back to cyber security.

Alex has recently received some emails containing notifications about their Paypal account and wants to know if this link would be safe to click on?

<https://www.account.paypal.com>

safe

not safe

Figure 20: Feedback in the gamified condition

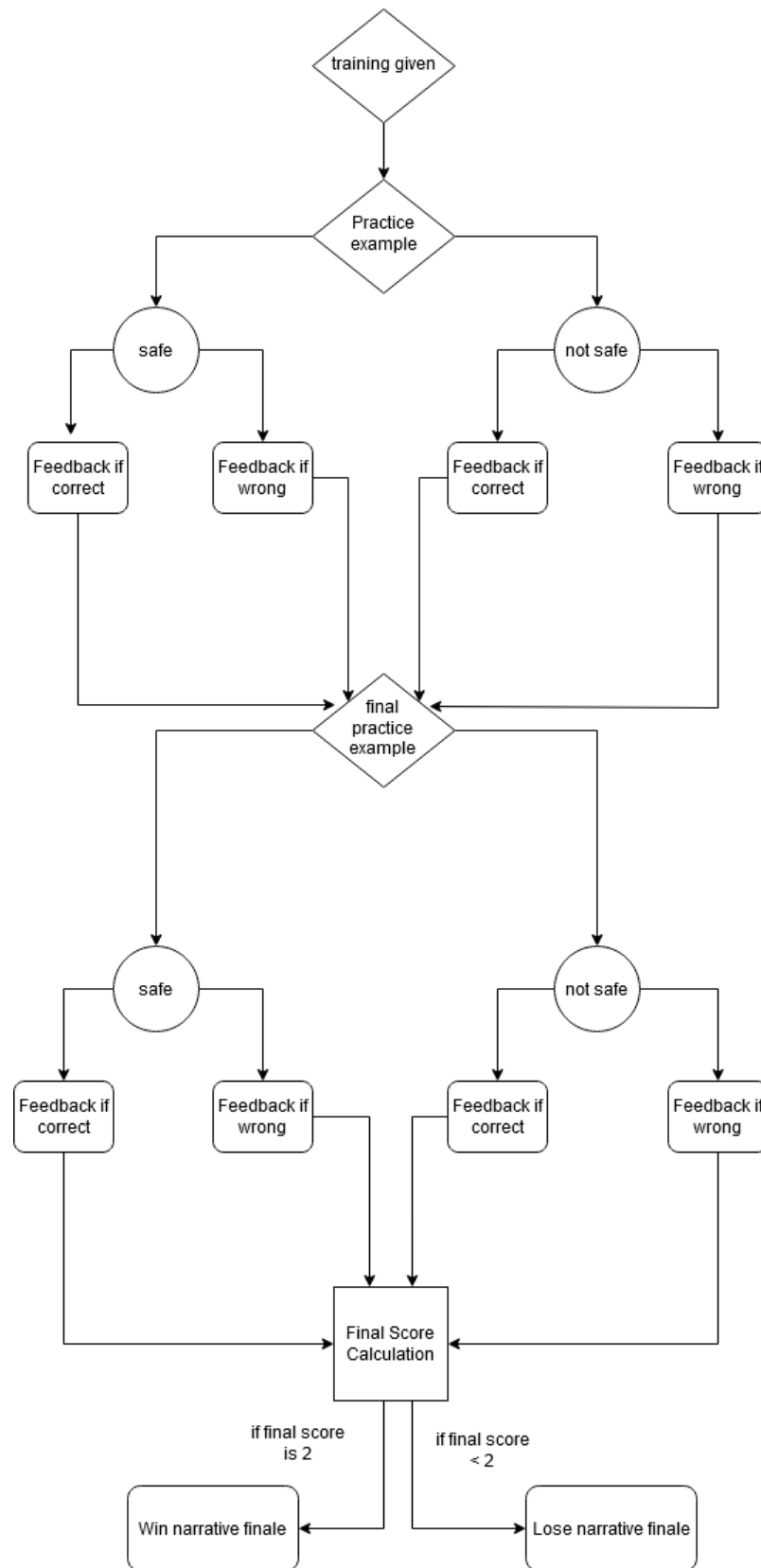


Figure 21: Gamified training condition structure

Deep Sea City is a long way from user inboxes and cartoon fish are not emails. Would it have been better to have chosen a more realistic inbox style game? It seems plausible that situated games, like What.Hack, where the context of learning and execution are the same, make for better learning. If we want people to recognise suspicious URLs in their inboxes, then the game would ideally be about managing an inbox as in What.Hack. However, as Wen et al. note (Wen et al., 2019), there is a trade-off between how engaging a game is and how situated it is. Even if inbox games are more pedagogically effective, they are often less fun because it's hard to make a realistic email simulation that is, as Wen et al. put it, “fun, educational and not tedious” (Wen et al., 2019). Less entertainment may mean less engagement and more security fatigue, leading to worse learning outcomes over the long term. A similar trade off exists around the use of timers in games, which we discuss in 3.3. Ultimately, we avoided an inbox style game to allow for a shorter, more entertaining game with a higher completion rate.

Early prototypes of the game were created on the Qualtrics platform and then iteratively improved following feedback from a small group of volunteers (excluded from the experiment proper) playing the game.

While Qualtrics is designed for scorable surveys not games, the logical structure of a survey lends itself well to ‘choose your own adventure’ style games where game and story progression is determined by the players' choices and accrued points. Players could complete the game on both mobile and desktop devices.

### 3.2.3 Awareness Condition

Awareness condition participants received an adaptation of the advice contained in the National Cyber Security Centre's (NCSC) infographic on spotting phishing emails (NCSC, 2020). While useful in everyday life, this did not explain how to read URLs and contained no practice examples or feedback. This training could not help in the post-training assessment and so functioned as a control group to isolate the effect of increasing awareness without increasing skill. Awareness materials can be seen in 7.3.



### 3.3 Pre-Training Assessment, Post-Training Assessment And Retention Assessment

In Figure 22 we see an example question presented to subjects during the three testing phases. They were given 16 such URLs (half safe, half unsafe) presented in a random order at each phase. To ensure assessment phases had an equal level of difficulty, a number generator was used to randomly distribute URLs to each of the conditions from an initial bank of 48 which can be seen at 7.5. Each URL question was accompanied by a visible thirteen second countdown to limit participation time and simulate a busy workday.

If you wanted to log into your UPS account, would it be safe to click this link?

[https://www.ups.delivery.net/gb/en/Home.page?WT.srch=1&WT.mc\\_id=ds\\_gclid:EAIaIQobChMIsKGVurDY8AIVB5eyCh36Wgc\\_EAAYASAAEgK-zfD\\_BwE:dscid:71700000050016000:searchterm:ups&gclid=EAIaIQobChMIsKGVurDY8AIVB5eyCh36Wgc\\_EAAYASAAEgK-zfD\\_BwE&gclsrc=aw.ds](https://www.ups.delivery.net/gb/en/Home.page?WT.srch=1&WT.mc_id=ds_gclid:EAIaIQobChMIsKGVurDY8AIVB5eyCh36Wgc_EAAYASAAEgK-zfD_BwE:dscid:71700000050016000:searchterm:ups&gclid=EAIaIQobChMIsKGVurDY8AIVB5eyCh36Wgc_EAAYASAAEgK-zfD_BwE&gclsrc=aw.ds)

Safe

Not safe

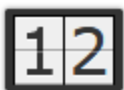


Figure 22: Assessment example

Similar artificial time pressures are found in many of the main academic anti-phishing games for the same reason. Examples include What.Hack (Wen et al., 2019), Anti-Phishing Phil (Sheng et al., 2007) and A Bird's Life (Weanquoi et al., 2018). One interesting exception is Phishy where the creators noted avoiding a timer to make their game more enjoyable (Gokul et al., 2018).

Timers are likely another example of the trade-offs to be made between realism and entertainment in anti-phishing games, as discussed in 3.2.2.

All safe URLs were real-life examples. While unsafe URLs were not clickable, additional steps were taken to ensure safety in case, as occurred in the pilot, some participants copy pasted links into the browser. Participants were explicitly warned not to copy and paste and unsafe URLs were tested in a sandboxed virtual machine just in case. Virtual machine testing comprised checks to ensure URLs either did not exist or belonged to safe but irrelevant companies. Secure.com, for example, in

<https://aol.secure.com/?src=guce-mail&lang=en-GB&done=https%3A%2F%2Fmail.aol.com%2Fwebmail-std%2Fen-gb%2Fsuite>

is a legitimate encryption company.

Participants were given at least 7 days to complete the retention assessment with earlier participants having more time. As Table 3 shows, participants completed the second retention assessment in 7 to 21 days with the mean completion 8.6 days, the median 7 and the standard deviation 2.86 days.

| Days taken to complete the retention assessment |        |       |                    |
|-------------------------------------------------|--------|-------|--------------------|
| Mean                                            | Median | Range | Standard Deviation |
| 8.6                                             | 7      | 7-21  | 2.86               |

Table 3: Days to complete retention stage

### 3.4 Recruitment Of Subjects

Since Phishing is a problem for the entire adult population, our recruitment extended beyond the university. Covid restrictions severely limited the availability and impact of offline advertising, so this was eschewed in favour of online channels. The experiment was advertised through our personal networks on Twitter, Facebook and LinkedIn as well as a forum for scams

awareness on Reddit. Some ways in which the Reddit group's inclusion may have been problematic are discussed in 6.2.3.2

Recruitment was primarily through the virtual snowball method with people encouraged not just to take part but to recommend the study to their own adult (18+) contacts. As we see in Table 4, this resulted in 193 people completing stage 1 with 61 in the traditional condition, 63 in the gamified condition and 69 in the awareness (control) condition. Of these, 109 returned for the retention stage with 28 in the traditional condition, 41 in the gamified condition and 40 in the awareness (control) condition.<sup>5</sup> As we can see in Table 2, this leaves us as the phishing game experiment with the second highest sample size behind Phishy with 8071 subjects and ahead of A Bird's Life with 100 subjects.

| Stage                                     | Traditional | Gamified | Awareness | Total Participants |
|-------------------------------------------|-------------|----------|-----------|--------------------|
| Stage 1                                   | 61          | 63       | 69        | 193                |
| Retention Stage<br>(Over 7 days<br>later) | 28          | 41       | 40        | 109                |

Table 4: Participant completion at each stage across conditions

While providing a good sample size, our use of the virtual snowball method created two sample quality problems not shared by other phishing game experiments which have recruited on campus or in the workplace. First, our sample does not represent a random selection from the population. Second, participants recommending the experiment to each other meant a lack of independent sampling and so the creation of certain clusters such as an unrepresentative 16% of participants coming from Ireland and 34% from the United Kingdom. All this is a normal, and acceptable, trade off when using the snowball method.

There are, however, some advantages to the virtual snowball method over traditional campus/workplace recruitment. As discussed in 3.5, our sample contains a good number of

---

<sup>5</sup> 120 participants completed the second stage but once those who had not completed stage 1 or not given the same email for both stages were removed this reduced to 109

retirement age persons in contrast to traditional recruitment centred on the campus and workplace which, as discussed in 2.5.5.1, often lack representation from this group.

### 3.5 Demographics

Our stage 1 post assessment exit survey asked for age, gender, country, self-perceived digital skill level and whether they had previously received anti-phishing training. Since experiments like ours often contain an unrepresentative number of students, we also asked participants if they were studying or had graduated in the last 12 months. Full demographics can be seen in Table 5.

|                                                               | Traditional % | Gamified % | Awareness % | Total % |
|---------------------------------------------------------------|---------------|------------|-------------|---------|
| <b>Age</b>                                                    |               |            |             |         |
| 18-27                                                         | 3.6%          | 7.8%       | 5.7%        | 17%     |
| 28-37                                                         | 4.7%          | 7.8%       | 9.8%        | 22%     |
| 38-47                                                         | 6.7%          | 3.1%       | 7.3%        | 17%     |
| 48-57                                                         | 2.1%          | 2.1%       | 2.1%        | 6%      |
| 58-67                                                         | 1.6%          | 5.2%       | 5.2%        | 12%     |
| 68-77                                                         | 6.2%          | 1.6%       | 2.6%        | 10%     |
| > 78                                                          | 0.0%          | 0.0%       | 0.5%        | 1%      |
| prefer not say                                                | 6.7%          | 5.2%       | 2.6%        | 15%     |
|                                                               |               |            |             |         |
| <b>Are you a student or recent graduate (last 12 months)?</b> |               |            |             |         |
| Yes                                                           | 7.8%          | 10.4%      | 9.3%        | 27%     |
| No                                                            | 23.3%         | 21.8%      | 25.9%       | 71%     |
| Prefer not say                                                | 0.5%          | 0.5%       | 0.5%        | 2%      |
|                                                               |               |            |             |         |
| <b>Gender</b>                                                 |               |            |             |         |
| Male                                                          | 18.7%         | 14.0%      | 17.1%       | 50%     |
| Female                                                        | 11.9%         | 17.1%      | 18.7%       | 48%     |

|                                                                 |       |       |       |     |
|-----------------------------------------------------------------|-------|-------|-------|-----|
| Non-binary                                                      | 0.5%  | 1.6%  | 0.0%  | 2%  |
| Prefer not say                                                  | 0.5%  | 0.0%  | 0.0%  | 1%  |
|                                                                 |       |       |       |     |
| <b>Previous training</b>                                        |       |       |       |     |
| Yes                                                             | 6.7%  | 8.3%  | 8.8%  | 24% |
| No                                                              | 24.4% | 23.8% | 26.4% | 75% |
| Prefer not say                                                  | 0.5%  | 0.5%  | 0.5%  | 2%  |
|                                                                 |       |       |       |     |
| <b>Country</b>                                                  |       |       |       |     |
| United Kingdom                                                  | 11.9% | 9.8%  | 17.1% | 39% |
| United States                                                   | 7.8%  | 7.3%  | 8.8%  | 24% |
| Ireland                                                         | 6.2%  | 5.2%  | 4.7%  | 16% |
| All other countries (each < 4 per condition)                    | 5.7%  | 10.4% | 5.2%  | 21% |
|                                                                 |       |       |       |     |
| <b>Digital Skills Self Report</b>                               |       |       |       |     |
| Above average                                                   | 14.5% | 19.7% | 13.0% | 47% |
| Average                                                         | 14.0% | 10.9% | 20.7% | 46% |
| Below average                                                   | 2.1%  | 2.1%  | 2.1%  | 6%  |
| Prefer not say                                                  | 1.0%  | 0.0%  | 0.0%  | 1%  |
|                                                                 |       |       |       |     |
| <b>Number of Essential Digital Skills "I can do" (max = 10)</b> |       |       |       |     |
| 10                                                              | 14.5% | 20.7% | 21.2% | 56% |
| 9                                                               | 7.3%  | 4.7%  | 5.7%  | 18% |
| 8                                                               | 4.7%  | 3.6%  | 3.6%  | 12% |
| 7                                                               | 2.1%  | 2.6%  | 1.6%  | 6%  |
| 6                                                               | 1.0%  | 0.5%  | 1.0%  | 3%  |
| < 6                                                             | 2.1%  | 0.5%  | 2.6%  | 5%  |

Table 5: Demographic breakdown of participants

Our sample contained a good range of ages (range 18-84, mean 42.7, SD 16.8) and while students/recent grads (27%) were overrepresented relative to the population, this was not as much of a problem as in similar studies that primarily recruited on campus.

Technical skill was measured in two ways. The first was by asking participants whether they rated their “digital skills” as above average, average or below average. The second way was by asking them how many statements from the “Life” section of the UK government’s Essential Digital Skills Framework (designed to measure digital inclusion) they felt applied to them (Department for Education, 2019). Ten questions were chosen with two from each of five themed areas, as seen in Table 6

Interestingly, given our online format, those without a full set of essential digital skills for life were actually overrepresented in our sample. In 2020 21% of the UK population reported not having the full set of Essential Digital Skills for Life (Lloyds Bank, 2020) and yet in our sample 44% reported not having all of the 10 we selected.

| Question                                                                                                                                            | Theme                            |
|-----------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------|
| I can activate pop-up blockers on my web browser to reduce the threat from malicious sites                                                          | Being safe and legal online      |
| I can apply privacy settings to Facebook (or other social media) to ensure only friends can see posts and shared content                            | Being safe and legal online      |
| I can send photographs and other documents to friends and family as an email attachment                                                             | Communicating                    |
| I can use word processing software to create a CV or a letter                                                                                       | Communicating                    |
| I can access information and content from different devices                                                                                         | Handling information and content |
| I can stream music from legal sites such as Spotify or Apple Music, or watch streamed movies from legal sources such as Netflix or Amazon Prime     | Handling information and content |
| I can find out how to do something by using a tutorial video such as those found on YouTube                                                         | Problem solving                  |
| I can use the help, FAQ section or chat facility of a manufacturer's website or other related content to work out how to fix an issue with a device | Problem solving                  |
| I can set up and use online and telephone banking through websites or Apps, keeping access information secure                                       | Transacting                      |
| I can set up online accounts for public services from my government                                                                                 | Transacting                      |

Table 6: Selected Essential Digital Skills For Life

### 3.6 Measuring Enjoyment

As context for H1, we tried to examine whether participants enjoy gamified more than traditional training. Though we did not directly ask how participants enjoyed their training condition, as in the literature discussed at 2.5.4.2, the optional feedback given by participants from both stage 1 and stage 2 (retention) was coded as either positive, negative or neutral. Assigning each of these a value (positive = 1, negative = -1 and neutral = 0), we constructed an enjoyment score for each condition. The result of this can be seen in 4.3 while limitations of the approach are discussed in 6.2.3.4.

### 3.7 Method Of Evaluation

We aimed to evaluate the most effective training condition in both the short (hypothesis H1) and longer (H2) term as well as whether sample demographics correlated with phishing vulnerability (Research Questions R1, R2, R3 and R4). To evaluate the training conditions regarding H1, **Post training assessment overall score / pre-training assessment overall score** was used to determine a correctness percentage showing how much participants learned.

As discussed in 3.3, scores themselves were determined by the correctness of safe/not safe classifications of URLs. In this we follow the lead of What.Hack, Anti-Phishing Phil and NoPhish in using a binary metric that allows easy comparison to the click-rate metric favoured by the wider phishing training evidence base.

To examine support for H2 and see what participants remembered after approximately one week, **retention training assessment overall score / pre-training assessment overall score** was used to show a retention percentage. The difference between correctness percentage and retention percentages showed how much information was lost.

While false negatives (failures to identify phish) obviously increase an organisation's risk, false positives (failures to identify legitimate email) also affect an organisation's productivity. We examined both with regard to H1. Users may not engage with important emails if they are worried they are unsafe. False positive percentages reflected what proportion of the 8 safe URLs were marked unsafe while false negative percentages showed what proportion of the 8 unsafe URLs were marked safe.



To see whether false negatives and false positives had improved from pre to post training in the first stage of the experiment, a **pre false minus post false** metric was used. If a user failed to classify a URL as either safe or unsafe within the 13 second timer, this was treated as neither a false positive nor a false negative.

Before analysing overall correctness, false positives and false negatives, we removed all participants (there were 16) with perfect scores on the pre-training assessment and our justification of this can be found in 6.2.2.5. These experts were **not** removed when looking at correlations where demographic variables (age, gender, student or recent graduate, country, previous training, self-perceived digital skills) were tested against pre-training assessment scores.

## 4 Results Of Our Study

Though we found evidence that anti-phishing training in general is effective, we could not find support for the H1 or H2 hypothesis. Relative to traditional training, gamified training did not significantly improve participants' immediate learning outcomes (H1) or their retention of what they learned (H2). This lack of support for H1 is the same whether we look at the overall correctness of URL classification, reduction in false negatives (marking unsafe URLs safe) or reduction in false positives (marking safe URLs unsafe). Users in both the gamified and traditional training conditions did, however, outperform users in the awareness raising (control) condition by a large and statistically significant margin.

Here we use sample mean values to report the overall learning outcomes for the short and longer term and then, to address our research questions, we examine any demographic correlations to pre-training assessment scores.

### 4.1 Overall Learning Outcomes

#### 4.1.1 Overall Correctness Of URL Classification (Hypothesis H1)

As shown in Figure 23, both the gamified and traditional training conditions showed statistically significant improvement in overall correctness from the pre-training assessment to the post-training assessment. Those in the gamified condition improved by 0.24 (Wilcoxon matched

pairs signed rank test,  $n = 56$ ,  $p < 0.01$ ) from 0.63 (SD = 0.13) to 0.87 (SD = 0.18) while participants in the traditional condition improved by 0.21 (Wilcoxon matched pairs signed rank test,  $n = 58$ ,  $p < 0.01$ ) from 0.63 (SD = 0.11) to 0.84 (SD = 0.19). Those in the awareness (control) condition actually did 0.04 worse on the post-training assessment (Paired T Test,  $n = 62$ ,  $p = 0.04$ ) from 0.62 (SD = 0.14) to 0.58 (SD = 0.19). Given it is the control condition, it is surprising that this is statistically significant but perhaps explainable by the frustration participants expressed about being given training that was not directly relevant to the test. If you feel you've been given useless training for a hard task, it's natural to stop trying as hard.

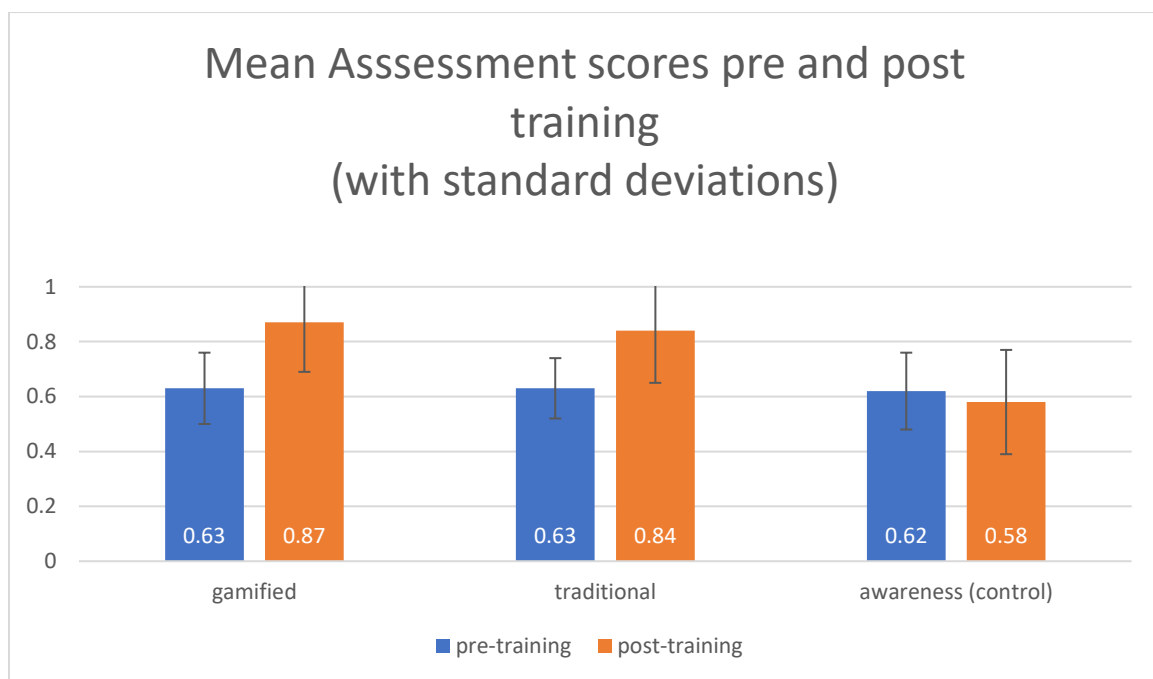


Figure 23: Assessment scores before and immediately after training

To test whether the difference in improvements between these conditions is statistically significant, we divided post assessment scores by pre assessment scores and used a one way ANOVA on the resulting figures. In doing so, we found a statistically significant difference between the three conditions ( $F(2, 173) = 32.07$ ,  $p < 0.01$ ). Using Tukey's multiple comparison test then showed a statistically significant difference between the awareness (control) condition and both the traditional and gamified conditions. The Tukey multiple comparison test did not, however, show a statistically significant difference between the traditional condition and the gamified condition. The gamified condition participants' 1.43 (SD = 0.40) was 0.49

greater than the awareness condition's 0.94 (SD = 0.28) and this was statistically significant ( $p < 0.01$ ). Similarly, the traditional condition (1.38 (SD = 0.41)) outperformed the awareness condition by 0.44 and this was also statistically significant ( $p < 0.01$ ). While the gamified condition showed a slight improvement of 0.05 over the traditional condition, this was not statistically significant ( $p = 0.75$ ). An analysis of overall correctness scores from the pre-training assessment to the post training assessment does not support the H1 hypothesis.

#### 4.1.2 False Positives And False Negatives (Hypothesis H1)

If we look at false positives (Figure 24) and false negatives (Figure 25), we see similar results to overall correctness with significant differences between both non-control conditions and awareness but little difference between gamified and traditional. There is also no support here for the H1 Hypothesis.

In the gamified condition, false negatives and false positives both showed statistically significant improvement. The gamified condition's false positives reduced by 0.30 (Wilcoxon matched-pairs signed rank test,  $n = 56$ ,  $p < 0.01$ ) from 0.45 (SD = 0.22) to 0.15 (SD = 0.26). False negatives in the gamified condition, meanwhile, reduced by 0.14 (Wilcoxon matched-pairs signed rank test,  $n = 56$ ,  $p < 0.01$ ) from 0.20 (SD = 0.18) to 0.06 (SD = 0.13). In the traditional condition false negatives and false positives also significantly improved with false positives falling by 0.25 (Wilcoxon matched-pairs signed rank test,  $n = 58$ ,  $p < 0.01$ ) from 0.45 (SD = 0.20) to 0.20 (SD = 0.26) and false negatives by 0.11 (Wilcoxon matched-pairs signed rank test,  $n = 58$ ,  $p < 0.01$ ) from 0.23 (SD = 0.18) to 0.12 (SD = 0.18). Both false positives and false negatives increased in the awareness group, though only the increase in false positives was statistically significant. The false positives increased in the awareness condition by 0.08 (Wilcoxon matched-pairs signed rank test,  $n = 62$ ,  $p = 0.01$ ) from 0.43 (SD = 0.20) to 0.51 (SD = 0.30) while false negatives increased by 0.04 (Paired T Test,  $n = 62$ ,  $p = 0.18$ ) from 0.26 (SD = 0.21) to 0.30 (SD = 0.22) while. As with the overall score decline in the awareness condition, the false positive increase might be attributable to participant frustration/fatigue about being given irrelevant training for a hard task.

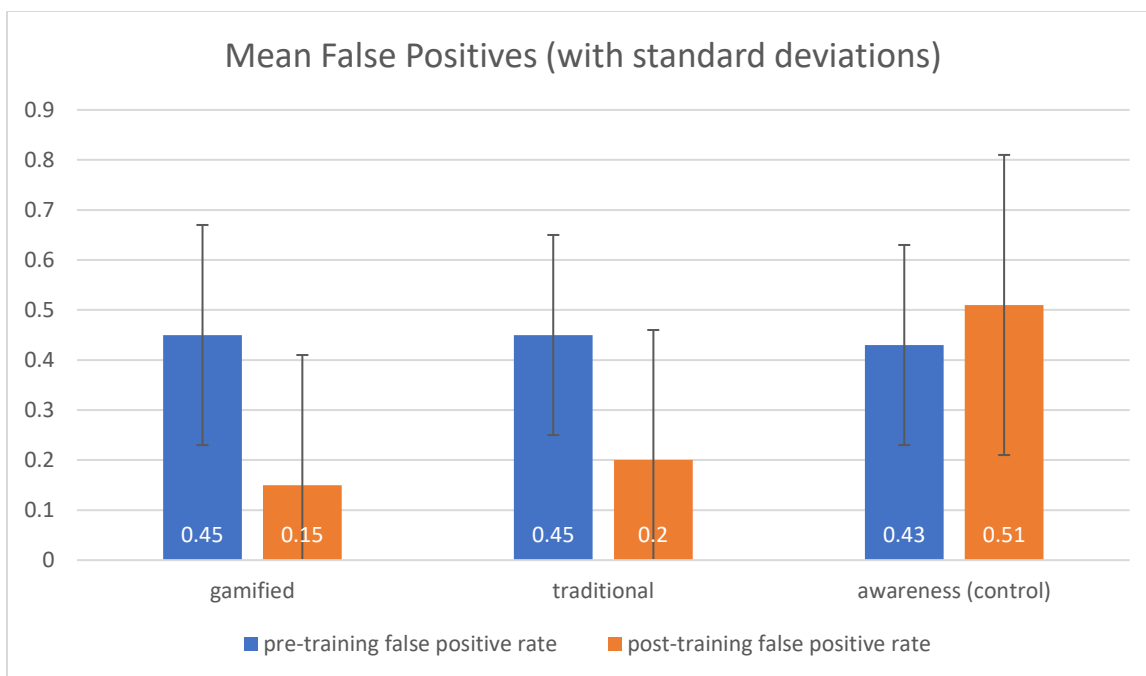


Figure 24: False positives

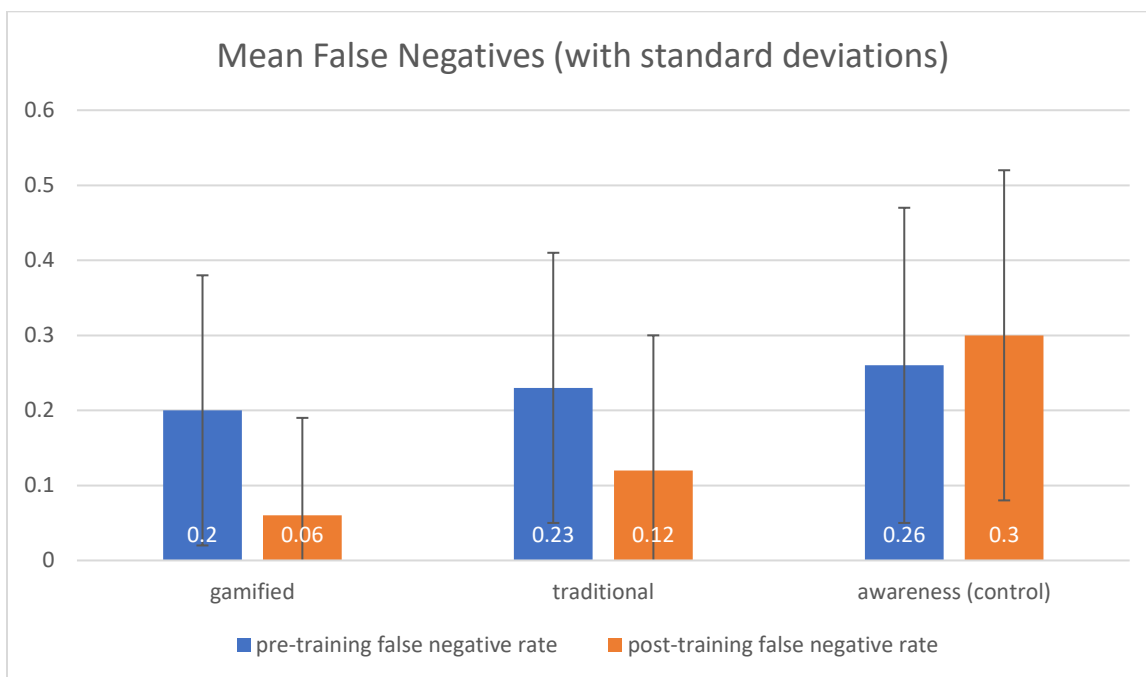


Figure 25: False negatives

To see if the difference in false positive change between the conditions was statistically significant, we subtracted the post-training false positive % from the pre-false positive % and

used a one way ANOVA on the resulting figures. Doing this, we found a statistically significant difference in false positive change between the groups ( $F(2, 173) = 35.98, p < 0.01$ ) with Tukey's multiple comparison test showing the advantages of both gamified and traditional conditions over the awareness condition were statistically significant but the difference between gamified and traditional training was not. Gamified false positives fell 0.37 more ( $p < 0.01$ ) than the awareness condition, while traditional false positives fell 0.33 more ( $p < 0.01$ ). False positives in the gamified condition fell 0.04 more than in traditional but this was not statistically significant ( $p = 0.64$ ).

Performing a similar analysis with Kruskal-Wallis, we found a statistically significant difference in false negative change between the groups (Kruskal-Wallis  $H = 22.90, p < 0.01$ ) with Dunn's multiple comparison test again showing an advantage of gamified and traditional over awareness along with no significant difference between gamified and traditional. The advantages of the gamified (0.18,  $p < 0.01$ ) and traditional conditions (0.15,  $p < 0.01$ ) over the awareness condition are both statistically significant. However, the advantage held by the gamified condition over the traditional condition is again small and not statistically significant (0.03,  $p > 0.999$ ).

#### 4.2 Retention Learning Outcomes (Hypothesis H2)

Since the awareness condition did not show any learning in the first place, it makes little sense to talk about retention but, for completeness, we mention that those in this condition continued to show no statistically significant change (-0.07) relative to their pre-training assessments (Paired t-test,  $n = 33, p = 0.06$ ).

As we see in Figure 26, participants in the gamified and traditional conditions remembered almost all of what they learned. Using a Mann-Whitney test, we found no statistically significant difference (Mann-Whitney  $U = 453.5, p = 0.83$ ) between the two conditions with the gamified condition remembering 0.98 (SD = 0.13) of what they learned and the traditional 0.97 (SD = 0.16) in the approximately 7 days between the post-training assessment and the retention assessment. There was, therefore, no support for hypothesis H2 that those in the gamified condition would show better retention. Examining conditions individually, we also found

neither the gamified loss (Paired t-test,  $n = 36$ ,  $p = 0.24$ ) nor the traditional loss (Wilcoxon matched-pairs signed rank test,  $n = 26$ ,  $p = 0.40$ ) were statistically significant.

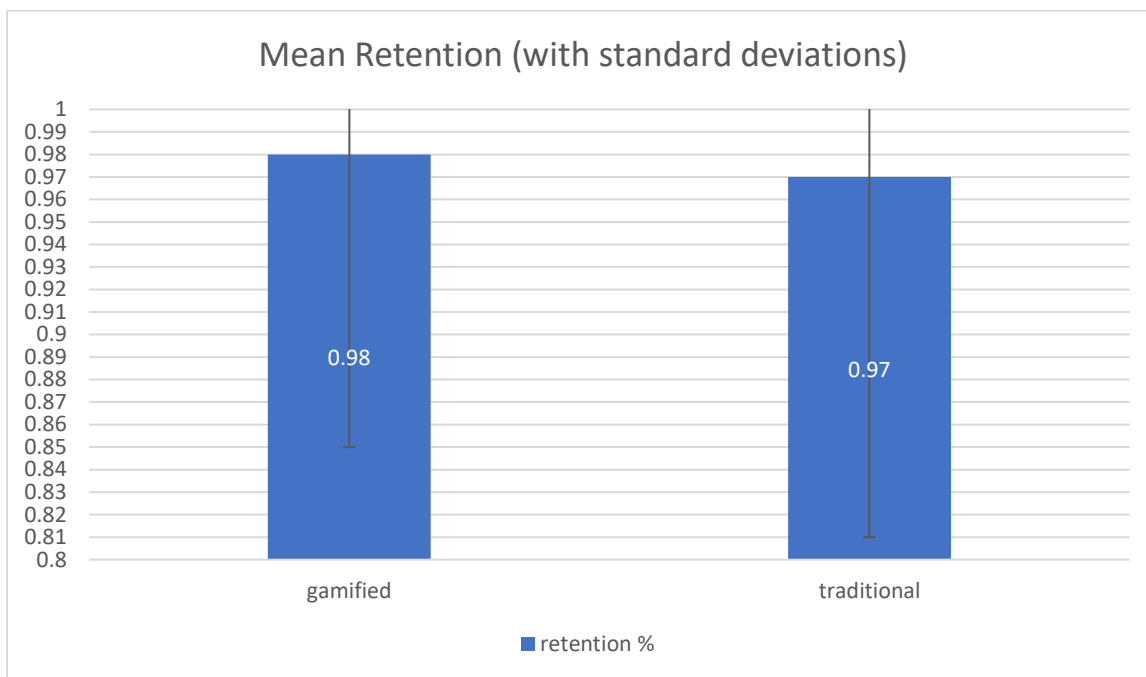


Figure 26: Retention of knowledge

### 4.3 Participant Enjoyment

As explained in 3.6, we indirectly measured participant enjoyment by coding the optional qualitative feedback as positive (1), negative (-1) or neutral (0). The results can be seen in both Figure 27 and Figure 28. Applying Kruskal-Wallis, we found a statistically significant difference between the three groups (Kruskal-Wallis  $H = 37.72$ ,  $p < 0.01$ ). In the subsequent Dunn's multiple comparison test, the traditional condition scored higher than the gamified condition (0.68 versus 0.61) though this was not statistically significant ( $p > 0.99$ ). Unsurprisingly, given the frustration of doing a test you haven't been trained for, both the gamified and traditional conditions were far more enjoyable than the awareness control (-0.38) and in both cases this difference was statistically significant (gamified  $p < 0.01$  and traditional  $p < 0.01$ ). The limitations of this approach are discussed in 6.2.3.4. As discussed in 5.3, these results run contrary to the existing literature discussed in 2.5.4.2.

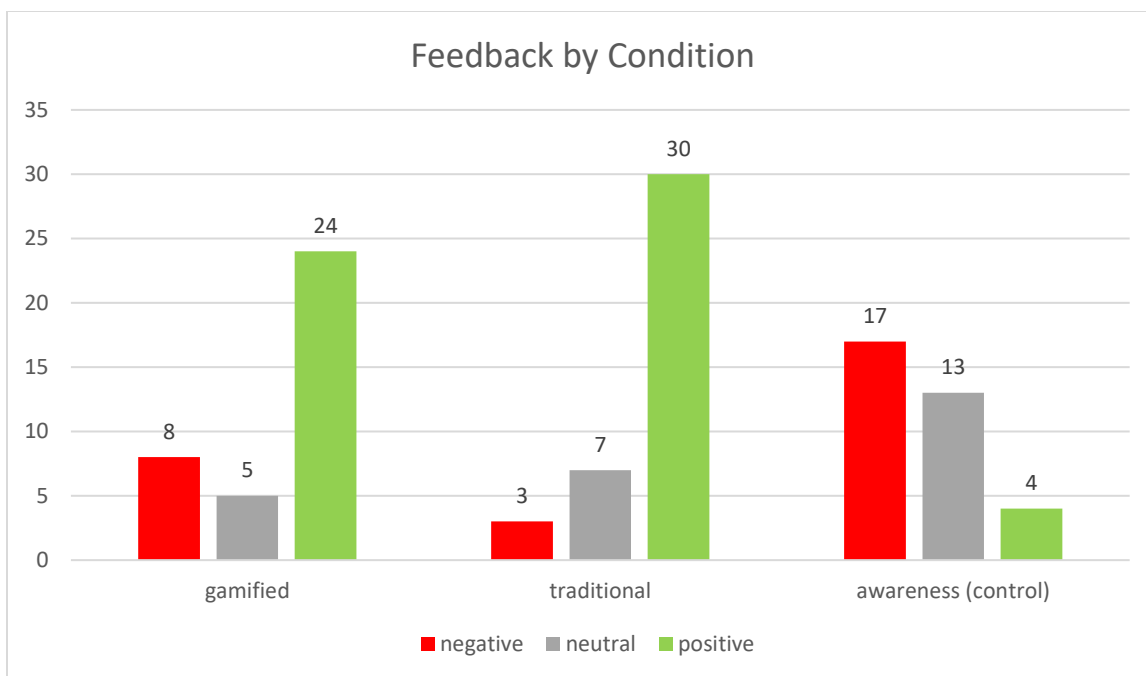


Figure 27: Feedback by Condition

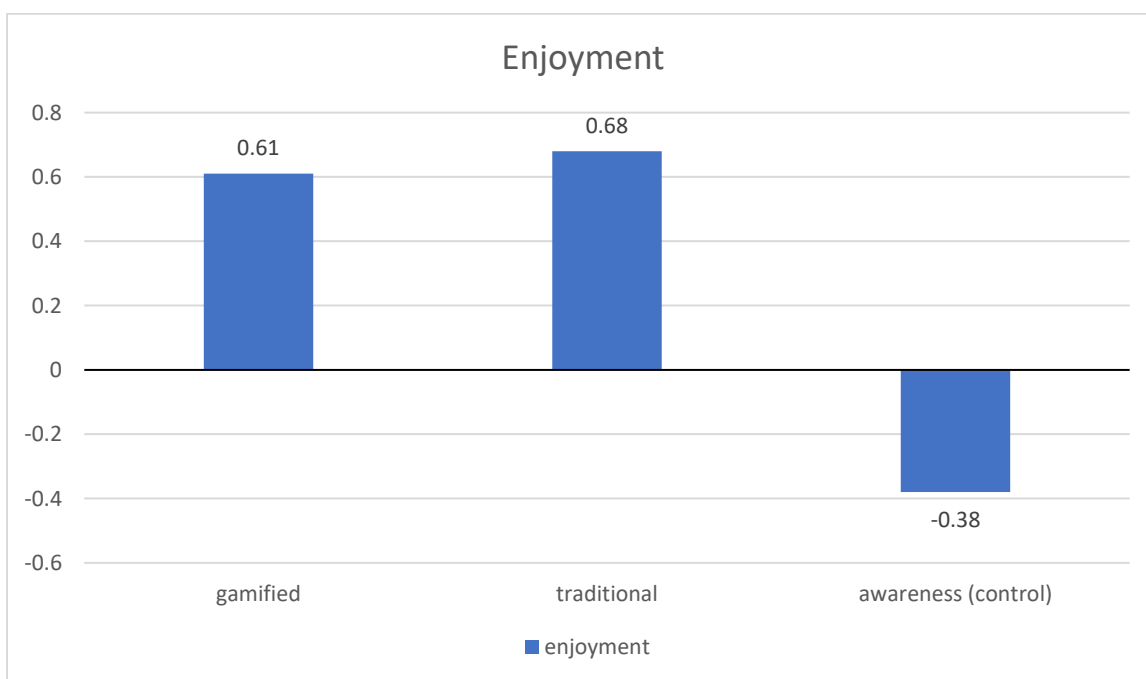


Figure 28: Enjoyment

## 4.4 Sample Demographic Correlations With Phishing Susceptibility

Here we report any correlations between demographic variables and pre-training assessment scores to determine which types of participants were more susceptible to phishing and explore the research questions set out in 1.1.

### 4.4.1 Age (R1)

We found a statistically significant negative correlation between participant age and performance on the pre-training assessment (Spearman rho = -0.27,  $n = 165$ ,  $p < 0.01$ ). The older participants got, the worse their performance got. This is in contrast to the inconclusive wider literature (discussed in 2.4.1) and we discuss this incongruity in 5.6.1.

### 4.4.2 Gender (R2)

We found no statistically significant correlation between participants' gender (Mann-Whitney U = 4161,  $n = 188$ ,  $p = 0.49$ ) and their performance on the pre-training assessment. As discussed at 5.6.2, this result is slightly at odds with the wider literature outlined at 2.4.2.

### 4.4.3 Technical Skill (R3)

We found a statistically significant positive correlation between technical skill and pre-training assessment scores. This was the case whether we measured by self-reported digital skill level (Spearman rho = 0.33,  $n = 191$ ,  $p < 0.01$ ) or by how many of the 10 Essential Digital Skills Framework abilities people reported having (Spearman rho = 0.34,  $n = 193$ ,  $p < 0.01$ ). This statistically significant correlation is repeated in the five Essential Digital Skills Framework themes with the biggest being Staying Safe, as seen in Table 7.

| Theme                      | Statistics                                  |
|----------------------------|---------------------------------------------|
| Overall (all 10 questions) | Spearman rho = 0.34, $n = 193$ , $p < 0.01$ |
| Communication              | Spearman rho = 0.20, $n = 193$ , $p < 0.01$ |
| Handling                   | Spearman rho = 0.28, $n = 193$ , $p < 0.01$ |
| Transacting                | Spearman rho = 0.19, $n = 193$ , $p < 0.01$ |
| Problem solving            | Spearman rho = 0.18, $n = 193$ , $p < 0.01$ |
| Staying safe               | Spearman rho = 0.33, $n = 193$ , $p < 0.01$ |

Table 7: Essential Digital Skills Framework correlations with phishing susceptibility



As discussed at 5.6.3, our findings are consistent with the literature which, as discussed in 2.4.3, strongly suggests those with higher technical skills are less susceptible to phishing.

#### 4.4.4 Country Of Origin (R4)

Our sample was too small for national breakdown except for the UK, the USA and Ireland where no significant differences were found between the countries (Kruskal-Wallis,  $H = 4.7$   $n = 152$   $p = 0.10$ ). As discussed in 5.6.4, this runs contrary to one study on this in the literature we outlined at 2.4.4.

#### 4.4.5 Student Or Recent Graduate

Those participants who were students or recent graduates (0.663) scored only marginally higher on the pre-training test than non-students/grads (0.657) and this difference was not statistically significant (Mann-Whitney  $U = 3450$ ,  $n = 190$ ,  $p = 0.59$ ). This is included not to speak to any literature but to check in case an overrepresentation of students was skewing our overall results. They were not.

#### 4.4.6 Previous Training

The 24% of participants with previous training performed only 0.04 better (0.69) on the pre-training assessment than those with no previous training (0.65) and this advantage was not statistically significant (Mann Whitney  $U = 2816$ ,  $n = 190$ ,  $p = 0.12$ ). To what extent this is consistent with the existing literature on retention is hard to determine without knowing when this training was received, though we discuss this in more depth at 5.6.5.

## 5 Discussion

### 5.1 Anti-Phishing Training Works

It was not our intention to test the efficacy of anti-phishing training in general. Despite room for improvement in training modes, the strong case made for training in the wider literature (see 2.3.2) seemed not to need further support. Nevertheless, that both our gamified *and* traditional training conditions showed significant improvement in short term learning outcomes when compared to the awareness (control) condition (see 4.1) adds to the case for training. This support would be stronger had we measured learning outcomes through simulated phishing but this was infeasible in an MSc project.

### 5.2 Users Seem To Remember Training

As noted in 2.5.5.3, the literature on training retention in general is sparse. We are then glad that our finding of no statistically significant knowledge erosion after 7 days helps address this evidentiary shortage. Finding no significant knowledge erosion at 7 days echoes the findings of Kumaraguru et al. (Kumaraguru et al., 2008) but sits uncomfortably with Dodge et al.'s finding of total erosion at 10 days of knowledge gained from initial training (Dodge et al., 2012). As we noted in 6.3.1, more research is needed to determine both when knowledge erosion begins and when it is complete. We would very much like to have helped answer when it is complete by using a longer retention timeline, but this was not workable in an MSc project.

### 5.3 Why Didn't We See Better Short Term Learning Outcomes With Gamification? (H1)

Contrary to our H1 hypothesis, the gamified condition did not show significantly better short term learning outcomes between the pre-training assessment and the post-training assessment. This was true for overall correctness of URL classification as well as false positives and negatives. Before discussing why, let's revisit the possible advantages of games and gamification as discussed in 2.5.2.

It may be the case that users may like gamified training more than traditional training. They may also engage more with materials they enjoy with this greater engagement and attention, leading to better learning outcomes. Greater enjoyment may also mean less security fatigue for users, possibly leading to greater tolerance for training workloads and potentially greater

compliance with security policies. In a world where bored users speed click their way through security training and show poor compliance with policies they see as pointless workflow obstacles, this is an attractive prospect. So why did we not see better learning outcomes for the gamified condition in our study?

Perhaps the H1 hypothesis is false and gamified training simply does not produce superior learning outcomes. If so, it likely fails in one of two ways. Either users don't enjoy gamified training as much as thought or greater enjoyment doesn't lead to greater engagement and attention.

As discussed in 2.5.4.2, users appear to enjoy gamified phishing training but perhaps participants did not enjoy our particular game as much as we had hoped. Sadly, this seems supported by coding of participant feedback as either positive, negative or neutral (see 4.3) with no more positive feedback in the gamified than in the traditional condition. Whether this was a failure in storytelling, humour or graphics (we used no sound or moving images) is unclear. Perhaps excepting NoPhish, our game was less immersive and had more primitive game mechanics than any of the other phishing games surveyed in 2.5.3. Even if gamification has positive effects, there may be a quality bar below which benefits are not seen. Given production costs, this bar may make effective gamification commercially infeasible for budget training providers.

However, as discussed in 6.2.3.4, sentiment coding of qualitative feedback is at best an indirect measure of enjoyment and with it we may have painted an inaccurate picture of how much participants enjoyed the training conditions. Assuming, for the sake of argument, participants enjoyed our game as much as hoped, why might this not have resulted in better learning outcomes?

While the literature discussed at 2.5.4, strongly suggests that enjoyment leads to greater learning outcomes, maybe *some* types of enjoyment may result in greater attention to things that do not increase learning. Users might, for example, pay great attention to the names and colours of the cartoon fish but no greater attention to the core training messages. It is possible

that this happened in our experiment and that greater attention was paid to things other than the core training message.

If misdirected attention was a problem, maybe this is because we gamified the wrong elements. To allow a rigorous A/B test, the core training message (containing the “two step rule” for reading URLs) was identical in both the gamified and traditional conditions. The only difference was in its context and mode of presentation with the gamified condition presenting it as a training guide emailed from head of IT Priya Piranha that you should use to try to win the game.

Perhaps if the core training message itself had been gamified, as opposed to merely being embedded within a game, the gamified condition users might have paid greater attention to the core training message and performed better than the traditional condition. The other phishing training games discussed in 2.5.3 appear to lean more towards gamifying the core training messages as opposed to simply embedding them within a game context.

#### 5.4 Why Didn't We See Better Learning Retention For The Gamified Condition?

There seem to be three plausible explanations for why we did not see better retention for the gamified condition as hypothesised in H2. Gamification may just not result in better retention, our own gamification may have been flawed or our timeline was too short.

That the timeline was not long enough is suggested by the lack of **any** statistically significant erosion of knowledge in the gamified **or** the traditional condition. To properly compare conditions, we need to look at the point where knowledge erosion starts for traditional training. We clearly did not reach this erosion point after approximately 7 days. To reach it, it is necessary to lengthen the timeline or increase the learning load which, in our study, was extremely small (one simple rule for reading URLs).

In our case, the small learning load and 7 day timeline resulted from pragmatic concerns. A longer gap between stage 1 and the retention stage was not feasible for an MSc project while, as discussed in 6.2.2.3, an increase in the learning load risks subject participation and drop off. Because subject drop off will be a problem for most other studies, we would encourage future researchers to focus on using longer timelines than 7 days.

In not finding knowledge erosion before 7 days, our results are consistent with the wider phishing training literature which we discussed in more depth in 2.5.5.3. The 7 day window has only been examined once before but Kumaraguru found no real knowledge erosion (Kumaraguru et al., 2008). How far beyond 7 days future researchers should go is unclear due to both the small number of studies and the variation in their findings. Kumaraguru also found no erosion at 28 days (Kumaraguru et al., 2009) while Dodge et al. found what looks like a total loss of learned knowledge from initial training at just 10 days (Dodge et al., 2012) and Caputo found total retention loss at 90 days (Caputo et al., 2014). Nevertheless, as the first phishing game to examine retention, we believe our results still represent a useful contribution to the literature.

## 5.5 Why Mere Awareness Is Not Enough

The lack of any improvement in our awareness condition underlines the fact that training must go beyond simply raising awareness. While heightened awareness of phishing risks is necessary for behaviour change, users also need specific skills like URL reading.

## 5.6 Demographic Correlations With Phishing Susceptibility

Here we consider correlations, or the lack of, between demographic variables and pre-training assessment scores.

### 5.6.1 Age (R1)

Regarding our R1 research question about the relationship between age and phishing susceptibility, our finding that older participants were more susceptible to phishing is both surprising and unsurprising. It is surprising when compared to the phishing literature on age (see 2.4.1) but not when considering this literature's limitations and the broader context involving age, technical skill and vulnerability.

As discussed in 2.4.1, only five of the 16 studies we looked at found older people more susceptible but very few of these studies included people of retirement age. Many included only students while those that included non-students were usually restricted to university staff and faculty or current employees of a company. As discussed in 2.5.5.1, this is also a major problem with the demographics of phishing game studies. By contrast, our own sample had

23% of participants over the age of 57, as shown in 3.5. If older people are not included in a study's sample, their vulnerability cannot be explored.

Looking beyond these problematic studies at the wider context, we should expect older people to be more susceptible to phishing because of correlations between technical skill and susceptibility and between age and technical skill. The literature on technical skill is, as discussed in 2.4.3, reasonably settled in finding phishing risk to reduce as technical skill increases. Given 46% of people over 65 do not have the full set of essential life digital skills (Lloyds Bank, 2020), we should then expect older people to be more vulnerable to phishing attacks. The issue is, however, far from settled and so we would welcome additional studies that include retired persons as we note in 6.3.4.

#### 5.6.2 Gender (R2)

Our R2 research question asked “is there a relationship between gender and phishing susceptibility?” Our finding of no significant correlation between gender and phishing susceptibility is somewhat at odds with the wider literature which, as discussed in 2.4.2, is mixed but leans slightly towards finding women more susceptible. Viewed another way, though our results are in good company with half of studies also finding no significant correlation. The inconclusive and mixed nature of this literature calls for more research as noted in 6.3.3.

#### 5.6.3 Technical Skill (R3)

Our R3 research question asked whether there was a relationship between technical skill and phishing susceptibility. Here, our finding that users with greater technical skill are less susceptible to phishing agrees with the wider literature discussed in 2.4.3.

This underlines the need for digital inclusion programs (teaching basic digital skills) to centre security in their training. Not doing so risks giving people, who have never gone online, just enough knowledge to make them susceptible to phishing. Emphasising security in these programs without negatively impacting learning is, however, challenging. There is always a risk of overwhelming new internet users with information or discouraging them from going online at all. When The Good Things Foundation (a national digital inclusion body) surveyed local digital inclusion centres, they found many saying that online safety resources were “very threat

heavy” and worrying that this “can deter people from going online or trying new things” (Stone et al., 2020). As noted in 6.3.5, we would welcome more research into how to solve this problem both from academics and those actively involved in such programs.

#### 5.6.4 Country of Origin (R4)

In answer to our R4 research question, the only countries with large enough samples for analysis were the UK, the USA and Ireland and here we found no significant difference in phishing susceptibility between them. This is contrary to Gopavaram et al.’s study where UK residents were more susceptible than USA residents (Gopavaram et al., 2021).

That there are so few studies addressing this question is regrettable, as discussed in 2.4.4. Many large multi-national companies deploy security awareness training to employees in different countries. If there are national difference in phishing susceptibility, they need to know in order to optimise their training regionally. As discussed in 6.3.6, we would encourage further research on national differences regarding both phishing susceptibility and effective training methods.

#### 5.6.5 Previous Training

That, as outlined in 4.4.6, our participants with previous training were not significantly less susceptible to phishing is concerning. However, without knowing what training was received and when, it is hard to know if the problem is training quality or just the passage of time. Participants may have been given training that was suboptimal or just too long ago for them to remember. The problem is, in our view, more likely to be in the type of training received.

Our reason for thinking this is that most publicly available security awareness advice is problematic. In an expansive survey of publicly available advice online, Mossano et al. found that “information on how to check for the destination of a link before clicking it or how to check the domain of a webpage before entering sensitive data was missing completely from almost all of the analysed webpages” (Mossano et al., 2020). Given how much even technical users struggle with reading URLs (Albakry et al., 2020) this is regrettable. We can only hope that internal training is of a higher standard than what is publicly available. Given that most commercially available training material is behind paywalls, we leave it to better resourced

researchers to investigate. We would encourage training creators to focus on link reading and are making a free copy of our gamified module available to assist with this. It can be found at [https://hwsml.eu.qualtrics.com/jfe/form/SV\\_3g5lmw87sGwTy3Y](https://hwsml.eu.qualtrics.com/jfe/form/SV_3g5lmw87sGwTy3Y)

## 6 Conclusion, Reflections And Suggestions For Future Research

### 6.1 Conclusion

We found evidence that anti-phishing training works and that users remember it well after a week. We did not, however, find support for our H1 hypothesis, that the gamified anti-phishing training would show better short term learning outcomes than traditional training, or our H2 hypothesis, that the gamified condition would show better learning retention. Our research questions explored the relationship between phishing susceptibility and Age (R1), Gender (R2), Technical Skill (R3) and Country of Origin (R4) respectively. Regarding R1, among our participants we found the older they were the more likely they were to be susceptible to phishing. On the question of Gender (R2), we found no correlation with phishing susceptibility while, regarding Technical Skill (R3), our results echo the existing literature in finding susceptibility to rise for those with fewer digital skills. Of national differences in phishing susceptibility (R4), we found no significant differences between the UK, USA and Ireland. In adding the first study of learning retention for phishing games, we believe we have left the gamified phishing training literature better than we found it. The overall picture remains promising but inconclusive, so we call for further study.

### 6.2 Reflections

#### 6.2.1 Potentially Confounding Variables

The biggest potentially confounding variable was participants engaging in extra phishing training between the first and second stage of the experiment. However, since only 7 out of the 109 who completed the second (retention) stage reported taking extra training, we determine this not to have been a significant factor.

Participants' familiarity with the brand in question may also have affected their ability to classify URLs. Those outside the UK, for example, may have little contact with .co.uk domains



and not know the BBC uses this. They might find .co.uk suspicious and be more inclined to think it unsafe. To mitigate this, we limited ourselves to what we felt were globally recognised brands (e.g. Apple, Google, FedEx) and only used .com. In spite of our efforts, some participants reported unfamiliarity with the brands in feedback and felt that this affected their ability to assess the URLs.

Here we have sympathy with participants. Given that Microsoft uses not only microsoft.com but also office.com it is, for example, not inconceivable that Apple might use <https://apple.macbook.com/shop/sign> which was one of our examples of an unsafe URL. The only way one would know that macbook.com is not used would be through brand familiarity. Apple may have been a particularly poor choice of brand given the sizable number of Android users who will have no engagement with it but this problem applies to many other brands. We are not sure what solution to recommend to future researchers that would not result in different participants being given different URLs to assess. Perhaps the best that can be done to mitigate the problem is to pre-test brand familiarity in a pilot study and then use only the most familiar brands for URL assessment.

### 6.2.2 Changes From The Proposal

There have been many changes from the proposal methodology. Let's examine the reasons behind these.

#### 6.2.2.1 Removal Of Police From The Story

Perhaps the biggest change was from a story centred around policing 'bad fish' to one centred on protecting 'good fish'. The reason for this was ethical but it also contains methodological advantages. We previously raised concerns that such a storyline might risk glorifying police harassment or trivialising the experiences of people who have experienced it. In the proposal we suggested mitigating this with a game mechanic where players would *lose* points for harassing innocent fish. On reflection and consideration of reviewer comments on the proposal, however, we decided it was best to simply remove police from the story.

As well as eliminating the ethical issue, our switch to a story where the player protects the good fish of Deep Sea City from scams has a methodological advantage. In the original story there

was a worry that the particular cartoon fish image might bias URL classification with fish that look ‘bad’ or ‘innocent’ nudging players to classify a URL as unsafe or safe respectively. When the player is, instead, protecting the fish from the URL, this bias problem disappears.

#### 6.2.2.2 Change Of Retention Period From Two Weeks To One

The proposal promised that the retention assessment would take place two weeks after training but this was changed to one week. This was done to allow more time for analysis and write up as well as to limit participation time and drop-off. As discussed in 2.5.5.3, the few previous studies looking at retention have not found statistically significant knowledge erosion prior to 28 days. However, given the small number of these retention studies, we felt enough might be lost in one week to see a difference across training conditions. In the end, however, our results confirmed the findings of the sparse literature in showing no statistically significant erosion of knowledge in those 7 days. As a result, it seems it was too early to look for differences in retention between the conditions and this may partly be a function of the small learning load. It is unclear when knowledge erosion begins but, as discussed in 5.4, it appears to be at some point *after* one week. Knowledge erosion of our learning load may begin between one and two weeks or much later, like Kumaraguru’s 28 days (Kumaraguru et al., 2009) or Caputo et al.’s 90 days (Caputo et al., 2014). Without rerunning the experiment, we cannot know.

#### 6.2.2.3 Removal Of Lookalike Domains From Training And Focus On Malicious Sub-domains

The original proposal promised training and assessment of two tricks for disguising URLs: lookalike domains (e.g. gooogole.com) and malicious sub-domains (e.g. google.login.com). Early pilot testing of the training module showed unacceptably high completion times, so we removed lookalike domains to limit participation time and drop-off.

#### 6.2.2.4 Removal Of Answer Dependent Feedback From The Traditional Condition

The original proposal claimed the traditional condition feedback for practice examples would, as in the gamified condition, be different depending on the player’s answer. On reflection, however, we limited traditional condition feedback to simply revealing the answer and it did

not mention whether the player got the practice example right. This was done to accentuate the difference in interactivity with the gamified condition.

#### 6.2.2.5 Removal Of “Experts” Who Scored 100% On The Pre-Training Assessment

We removed 16 subjects with perfect pre-training assessment scores when testing H1 and H2. This is, we believe, both methodologically justifiable and with precedent in the literature. If these experts’ scores failed to improve from pre to post and retention test, this would simply be because they have no room for further improvement. The danger is that their non-improvement might contribute to the perception of an ineffective training condition. Precedence for this screening process in the literature can be found in the evaluation of Anti-Phishing Phil where a pre-training questionnaire was similarly used to remove “experts” (Sheng et al., 2007) and also in the evaluation of What.Hack where participants were screened to remove those who had taken cyber security modules (Wen et al., 2019).

### 6.2.3 Mistakes And Missed Opportunities

#### 6.2.3.1 Formulation Of Hypotheses And Research Question

It is unquestionable that the project would have benefited from a more public and explicit statement of the hypotheses and research question early on. This would answer worries about cherry picking but would also have provided a clearer guiding light for all later work. Since this is a problem for science more generally, resources now exist for the public preregistration of hypotheses such as at the Open Science Foundation <https://www.cos.io/initiatives/prere>. We regret not making use of these and would encourage other MSc students to do so.

#### 6.2.3.2 Possible Sampling Bias From The Scams Group

While recruiting from the Scams subreddit group helped us to a healthy sample size, there are worries that it may also have lowered our sample quality. Specifically, people who belong to such groups may be unusually knowledgeable about scams. This may cause problems when exploring our research questions regarding correlations with phishing susceptibility. However, since participants from Reddit were randomly assigned to a condition, like everyone else, we do not think them problematic regarding the assessment of H1 and H2.

#### 6.2.3.3 Not Asking About Previous Training Timelines

As mentioned in 5.6.5, we implemented a proposal reviewer's suggestion to ask subjects whether they had received previous training but did not ask when this training took place. Our reason for this was to simplify the exit survey and limit participation time and drop-offs. We now see this as a mistake. When those with previous training failed to show significantly more phishing resilience than those without, we could not be sure whether this was more likely the result of bad training or simply knowledge erosion. We would encourage future researchers to have 'yes' answers to 'any previous training?' trigger a sub question asking whether this was in the past week, month, 3 months, 6 months or year. Asking the exact date would produce better data but would add significantly to participant time and so risk drop-off. This trade-off between exit survey simplicity and data richness occurs in many places and individual researchers will have to draw their own lines.

#### 6.2.3.4 Not Asking How Participants Enjoyed Their Training Condition

As discussed in 2.5.2, gamification advocates claim users enjoy gamified training more than traditional formats. This greater entertainment value is claimed to result in better learning outcomes in the short term and lower security fatigue in the long term. Given the centrality of this claim, we should have directly asked participants how much they enjoyed the training as other phishing game studies have done like Anti-Phishing Phil (Sheng et al., 2007) and What.Hack (Wen et al., 2019). Our attempt to gain some measure of participant enjoyment by quantitatively coding participant feedback as either positive, negative or neutral is suboptimal and only indirectly assesses a self-selecting portion of participants i.e. those who gave feedback. Less than half of participants opted to give feedback at both stages. In stage one 84/192 participants gave feedback while in the 2<sup>nd</sup> stage 42/109 participants gave feedback. A direct enjoyment question would have allowed the formulation and testing of additional hypotheses, including the claim that gamification will result in more enjoyment as well as the claim that greater enjoyment results in better learning outcomes.

#### 6.2.3.5 Not Testing Participants' Sentiments Towards IT Security Before And After Training

Advocates of gamification talk of a longer term reduction of security fatigue but this claim was not tested by our study because we failed to measure security fatigue before and after with

questions. Exactly what questions should be asked to capture this phenomenon is unclear though insofar as no one has yet answered the call from Cram et al. for the development of “an instrument to quantitatively measure security fatigue” (Cram et al., 2020). We join Cram et al. in thinking this to be a fruitful line of future research. In the meantime, an alternative is to, like Cram et al., quantitatively code the qualitative answers to open-ended questions about how users feel about security policies in their organisation.

### 6.3 Summary Of Main Suggestions For Future Research

#### 6.3.1 Do More Training Retention Research (H2)

Having highlighted the shortage of the training retention research in both 2.5.5.3 and 5.4, we recommend more research in this area especially for phishing games. In particular, we recommend timelines beyond 7 days and heavier learning loads in order to determine when knowledge erosion begins and is complete. Retention studies in field settings with staff would be particularly welcome. Despite Caputo et al.’s worries about staff turnover (Caputo et al., 2014), we believe this is entirely feasible over a 3 or 6 month period assuming organisations with historically low staff turnover like the UK Police who have a one year staff retention rate of 94% well above the national average (Office for National Statistics (ONS), 2019).

#### 6.3.2 Test Gamified Training With Actual Phish

The current literature, including our work, measures the learning outcomes with assessments but it would be interesting to see games tested with the same sort of simulated phish that traditional training has sometimes been measured against. This is an acid test that gamified training must face if its evidentiary base is to ever go beyond ‘promising’.

#### 6.3.3 A Meta-Analysis Of Gender And Phishing Susceptibilities (R2)

While excellent meta-analyses of anti-phishing training research exists such as Jampen et al. (Jampen et al., 2020) that cover gender, the literature would benefit from a meta-analysis devoted solely to the relationship between gender and phishing susceptibility. It is possible that a close look at the different methodologies used in this literature would explain its mixed nature (see 2.4.2) and offer resolution to the question.

#### 6.3.4 More Studies Involving People Of Retirement Age (R1)

Older persons are, as discussed in 5.6.1, underrepresented in the anti-phishing training studies. Considering a wider literature suggesting their special vulnerability, this lack is worrying and more studies focusing on this population and looking at the most effective training for them would be welcomed.

#### 6.3.5 More Research On Integrating Security Training With Digital Inclusion

As discussed in 5.6.3, integrating security training into digital inclusion without creating another barrier to digital access is a pressing challenge that requires input from both academics and digital inclusion practitioners.

#### 6.3.6 More International Research

As discussed in 2.4.4, given multi-national organisations with geographically diverse workforces, the lack of studies comparing national phishing susceptibility is problematic. Since multi-nationals like Tata have already conducted global anti-phishing training experiments (see 2.5.3.5 and (Gokul et al., 2018)), this is entirely feasible and just needs attention to the geographical variables that Gokul et al. sadly omitted.

## 7 Appendices

### 7.1 Consent Letter And Form

Dear Potential Participant,

I'm Peter Kirwan a Computer Systems Management student at Heriot-Watt University. Thank you for considering participating in this experiment which will help me complete my MSc dissertation research on the effectiveness of online safety training.

The experiment has four stages:

The first three stages, done today, will take about 10 minutes. The fourth stage follow up in one week will take less than 5 minutes.

Stage 1. A pre-training assessment of your ability to spot scam email links. This contains 16 questions in a randomised order. You will have 13 seconds to answer each one. If you do not provide an answer after 13 seconds, you will be moved on to the next question. This time limit is designed to simulate a busy work environment.

Stage 2. Short training in how to spot scam links. You will be randomly assigned to one of three training modules one of which involves a game about fish.

Stage 3. A post-training assessment of your ability to spot scam links and an optional demographics section where we ask for information like your age, gender, and digital skill level.

Stage 4. A follow up assessment one week later. You will be sent an email invitation to this from [noreply@qualtrics-research.com](mailto:noreply@qualtrics-research.com).

This is the data we will collect during the experiment and why we need it

| Item                                          | Reason for collection                                                            |
|-----------------------------------------------|----------------------------------------------------------------------------------|
| Email address                                 | To allow follow up testing in one week                                           |
| Your overall and per question scores          | To measure the effectiveness of the different training modules                   |
| Whether you are employed or a recent graduate | To assess how representative the group of study respondents is of the population |
| Age                                           | To assess how representative the group of study respondents is of the population |
| Gender                                        | To assess how representative the group of study respondents is of the population |
| Your digital skill level                      | To assess how representative the group of study respondents is of the population |

|                                          |                                                                |
|------------------------------------------|----------------------------------------------------------------|
| Whether you previously received training | To measure the effectiveness of the different training modules |
|------------------------------------------|----------------------------------------------------------------|

If you have any problems, questions or concerns feel free to contact me on [pdk2000@hw.ac.uk](mailto:pdk2000@hw.ac.uk) or my supervisor, Dr Mike Just, at [m.just@hw.ac.uk](mailto:m.just@hw.ac.uk)

Thanks for your consideration

Peter Kirwan

By choosing 'consent' I agree to take part in this study.

- I undertake participation in full knowledge of the tasks required of me which have been explained in writing.
- I am over 18.
- I understand I am free to withdraw my participation at any time at which point any data collected will be deleted within 24 hours.
- I also understand that all data collected as a result of my participation will be linked to my email address to allow for a follow up test.
- I understand that I have the right of erasure (deletion) regarding this data and that I can request this at any time by emailing [pdk2000@hw.ac.uk](mailto:pdk2000@hw.ac.uk).
- I also understand that I am hereby advised not to multitask while undertaking this experiment on a mobile device.
  - Consent [proceeds to study]
  - I do not consent [exits]



## 7.2 Traditional Training Content

### 7.2.1 Traditional Training Educational Content

#### What Are Phishing Links?

Email scammers try to trick people into clicking unsafe "phishing" links (links are also known as URLs) to deliver malware or steal sensitive information.

Scam emails have a number of suspicious "red flags" but the most important is the link's true destination which scammers will try to obscure.

---

#### The Malicious Subdomain Trick

This is one way they obscure the destination.

Here's an example:

<https://www.bbc.example.com>

We might think this goes to the BBC website but it actually goes to example.com. To understand why let's look at link structure.

---

#### Root Domains and Subdomains

You need to know your root domains from your subdomains.

Many safe sites use subdomains. Here's a safe Facebook link with the **root domain** (facebook.com) underlined in red while the **subdomain** (business) is in blue italics.

[https://\*business\*.facebook.com](https://business.facebook.com) (safe)

You can think of the root domain as a website's house and subdomains as rooms inside it.

Nothing stops me from calling a room in my house "10 Downing Street." Similarly, I can call a subdomain whatever I like. Scammers take advantage of this by naming subdomains (rooms) after trusted root domains (houses) to trick people into confusing a room for a house.

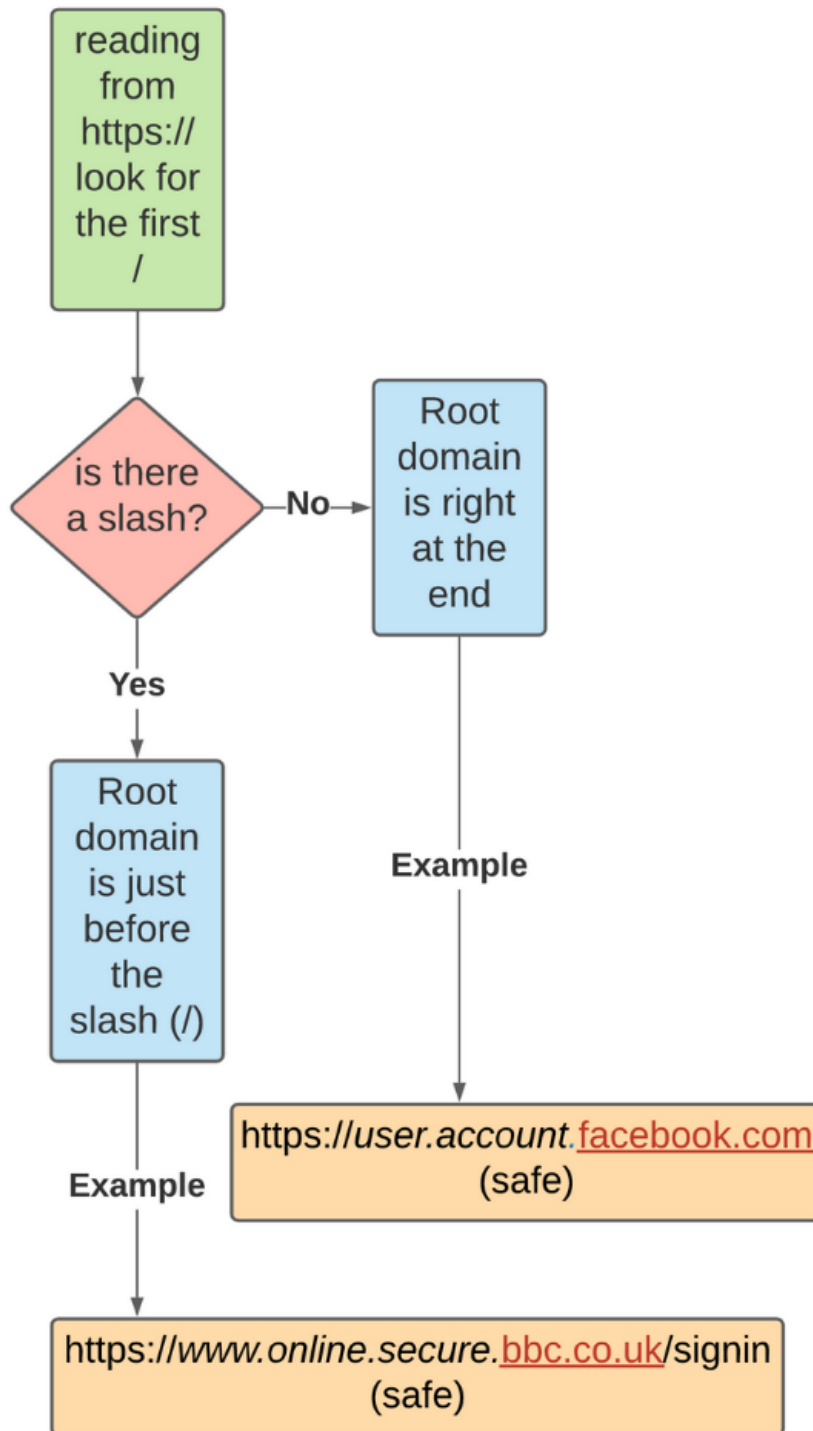
Consider another example. Again the root domain is red underlined and the subdomain is blue italicised.

<https://facebook.friends.com/profile/account/login> (unsafe)

The scammer wants us to see "facebook" and think this is the root domain when it's really a subdomain called "facebook" inside the friends.com root domain.

---

Quickly Find the Root Domain: The Two Step URL Reading Rule (see diagram)



## Dealing With Long Links And Multiple Subdomains

Some links are long. Really long. Like this real, safe Dell customer log in link

<https://www.dell.com/Identity/global/LoginOrRegister/1b579a27-dbf3-4b0e-8e87-d3d7b356bc72?c=uk&l=en&r=emea&s=corp&~ck=mn&redirectUrl=https%3A%2F%2Fwww.dell.com%2Fen-uk&pn=LoginOrRegister&feir=1>

However, scammers will often use length to obscure the root domain or will introduce multiple subdomains like so:

<https://secure.user.account.site.com>.

Calm application of the two step rule will, however, quickly reveal the root domain regardless of link length or the number of subdomains.

Don't read the whole link, **just the root domain.**

### 7.2.2 Traditional Training Practice And Feedback (Example)

**If you received some emails containing notifications about your Paypal account, would this link be safe to click on?**

**<https://www.account.paypal.com>**

safe

not safe

This link is safe. It has a subdomain but remember legitimate links also use subdomains.

Remember the second part of our URL reading rule.

We start reading from the `https://` looking for the first slash (/). Since there isn't one, we look at the end of the link to confirm `paypal.com` as the root domain.

`https://www.account.paypal.com`

If the link had been

`https://www.paypal.account.com`

it would **not** have been safe because the root domain is `account.com`

Practise another example

## 7.3 Awareness Training Educational Content

### **Please read the following**

#### **Tell tale signs of phishing**

Spotting a phishing email is becoming increasingly difficult, and even the most careful user can be tricked. Here are some tell tale signs that could indicate a phishing attempt.

Is the email addressed to you by name, or does it refer to 'valued customer', or 'friend' or 'colleague'? This can be a sign that the sender does not actually know you, and that it is part of a phishing scam.

Others will try and create official-looking emails by including logos and graphics. Is the design (and quality) what you'd expect?

Does the email contain a veiled threat that asks you to act urgently? Be suspicious of words like 'send these details within 24 hours' or 'you have been a victim of crime, click here immediately.'

Look at the sender's name and email address. Does it sound legitimate, or is it trying to mimic someone you know?

Your bank (or any other official source) should never ask you to supply personal information in an email. If you need to check, call them directly.

If it sounds too good to be true, it probably is. It's most unlikely that someone will offer you designer trainers for £10, or codes to access films for free.

Be aware that, while all of these are potential red flags, you should not take the absence of any one flag as a sign of authenticity. For example, some scam emails/websites contain poor logos and graphics but others are extremely polished.

Please click 'begin post-training assessment' to see if your score has improved

Contains public sector information licensed under the Open Government Licence v3.0. Adapted from materials on the National Centre for Cyber Security website. <https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/>

[Begin post-training assessment](#)

## 7.4 Gamified Training Condition Content

### 7.4.1 Gamified Intro

You have been assigned to the "gamified" training block where you will learn about email scams through a game about fish. The game begins below.



Times are changing in Deep Sea City.

Unprecedented infrastructure roll out means many underwater citizens are going online for the first time to email, shop, bank, socially network and more. It's an exciting time.

The Mayor worries that, given the digital inexperience of fish, some may be vulnerable to cyber-crime. To protect them the Mayor has hired "Web Guardians" including you. You must advise fish about particular links and keep them safe while letting them visit legitimate websites. See if your judgement is good enough to win employee of the month!

[Meet your manager](#)



An email has come in from Priya Piranha, the Head of IT

Virgin

75%



Welcome aboard  
Guardians **Inbox**



Priya Piranha

to me



Good Morning Guardians,

Welcome to the team! I wanted to give you a few tips to help you protect local fish, so I put together this short guide. I hope you find it useful. I'm sure you'll do great.

All the best  
Priya Piranha - Head of IT

Reply

Forward

[Read Priya's Guide](#)



#### 7.4.2 Gamified Training Condition Educational Content

### **Priya's Guide to Phishing (Scam) Links**

#### What Are Phishing Links?

Email scammers try to trick people into clicking unsafe "phishing" links (links are also known as URLs) to deliver malware or steal sensitive information.

Scam emails have a number of suspicious "red flags" but the most important is the link's true destination which scammers will try to obscure.

---

#### The Malicious Subdomain Trick

This is one way they obscure the destination.

Here's an example:

<https://www.bbc.example.com>

We might think this goes to the BBC website but it actually goes to example.com. To understand why let's look at link structure.

## Root Domains and Subdomains

You need to know your root domains from your subdomains.

Many safe sites use subdomains. Here's a safe Facebook link with the **root domain** (facebook.com) underlined in red while the **subdomain** (business) is in blue italics.

[https://\*business\*.facebook.com](https://business.facebook.com) (safe)

You can think of the root domain as a website's house and subdomains as rooms inside it.

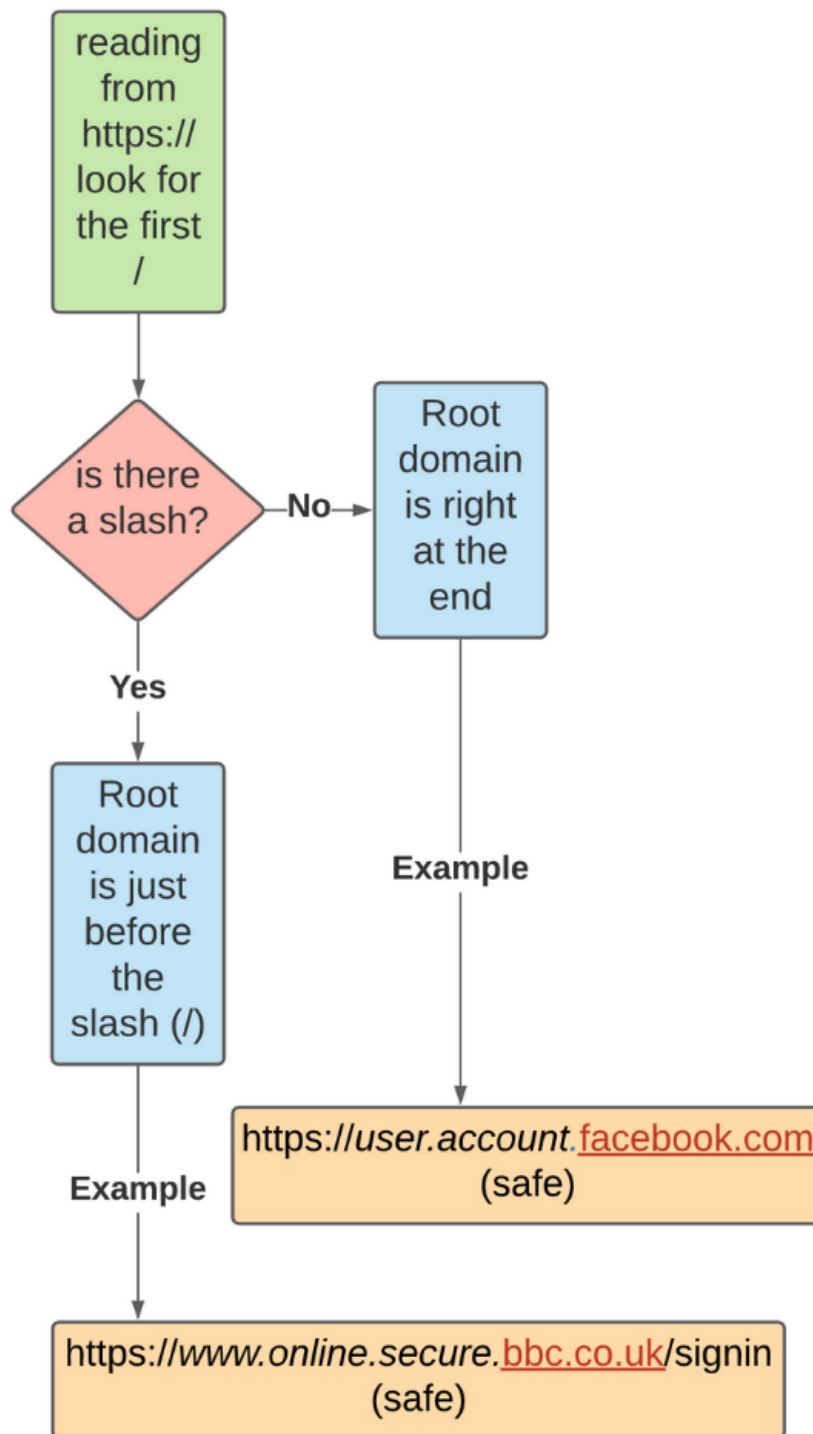
Nothing stops me from calling a room in my house "10 Downing Street." Similarly, I can call a subdomain whatever I like. Scammers take advantage of this by naming subdomains (rooms) after trusted root domains (houses) to trick people into confusing a room for a house.

Consider another example. Again the root domain is red underlined and the subdomain is blue italicised.

[https://\*facebook\*.friends.com/profile/account/login](https://facebook.friends.com/profile/account/login) (unsafe)

The scammer wants us to see "facebook" and think this is the root domain when it's really a subdomain called "facebook" inside the friends.com root domain.

### Quickly Find the Root Domain: The Two Step URL Reading Rule (see diagram)



This rule is adapted from material by the SIDN organisation (Stichting Internet Domeinnaamregistratie Nederland)

## Dealing With Long Links And Multiple Subdomains

Some links are long. Really long. Like this real, safe Dell customer log in link

<https://www.dell.com/Identity/global/LoginOrRegister/1b579a27-dbf3-4b0e-8e87-d3d7b356bc72?c=uk&l=en&r=emea&s=corp&~ck=mn&redirectUrl=https%3A%2F%2Fwww.dell.com%2Fen-uk&pn=LoginOrRegister&feir=1>

However, scammers will often use length to obscure the root domain or will introduce multiple subdomains like so:

<https://secure.user.account.site.com>.

Calm application of the two step rule will, however, quickly reveal the root domain regardless of link length or the number of subdomains.

Don't read the whole link, **just the root domain.**

Meet your first client

### 7.4.3 Gamified Training Practice And Feedback (Example)



No sooner have you settled into your office than Alex swims in. Alex is excited about getting hard-to-find products online. Very much the community trendsetter, they are hoping to be the first local fish with trousers. You pause, struggling to picture this, but then remember the City Council's commitment to judgment-free advice. Steering clear of fashion dilemmas, you manoeuvre the conversation back to cyber security.

Alex has recently received some emails containing notifications about their Paypal account and wants to know if this link would be safe to click on?

<https://www.account.paypal.com>

safe

not safe

Feedback if practice answer is correct

Another message from Priya from IT



Virgin

65%



Client Review: Alex

Inbox



**Priya Piranha**

to me



Morning Guardian,

Well spotted! Thanks to your advice  
Alex was able to log in and update  
their Paypal contact information.  
There are now no barriers to their  
clothing purchases ...

Let's recap on why the link is safe. It  
has a subdomain but remember  
legitimate links also use subdomains.

Remember the second part of our URL reading rule.

We start reading from the `https://` looking for the first slash (/). Since there isn't one, we look at the end of the link to confirm `paypal.com` as the root domain.

`https://www.account.paypal.com`

If the link had been

`https://www.paypal.account.com`

it would **not** have been safe because the root domain is `account.com`

All the best  
Priya P

↩ Reply

➡ Forward

Meet another client



Feedback is practice answer is not correct

Another message from Priya Piranha from IT



Virgin

60%



Client Review: Alex

Inbox



**Priya Piranha**

to me



Morning Guardian,

It's always better to err on the side of caution but this link was actually safe. It has a subdomain but remember legitimate links also use subdomains.

Remember the second part of our URL reading rule.



We start reading from the `https://` looking for the first slash (/). Since there isn't one, we look at the end of the link to confirm `paypal.com` as the root domain.

`https://www.account.paypal.com`

If the link had been

`https://www.paypal.account.com`

it would not have been safe because the root domain is `account.com`

Anyway there's no harm done and Alex's clothing purchases have not been disrupted ...

All the best  
Priya P

↩ Reply

➡ Forward

Meet another client

#### 7.4.4 Gamified Win Condition (if player classifies both example URLs correctly)

It's the end of your first month as a Web Guardian and you arrive in the office to another email from Priya



Virgin 31%



Employee of the month  
award **Inbox**



**Priya Piranha**  
to me



Morning Guardian,

Congratulations! You've done such a great job protecting our local fish that I've recommended you to the Mayor for employee of the month.

This comes with a year's supply of Plankton. HR has informed me that you are not, in fact, a fish but who doesn't like free food right?!

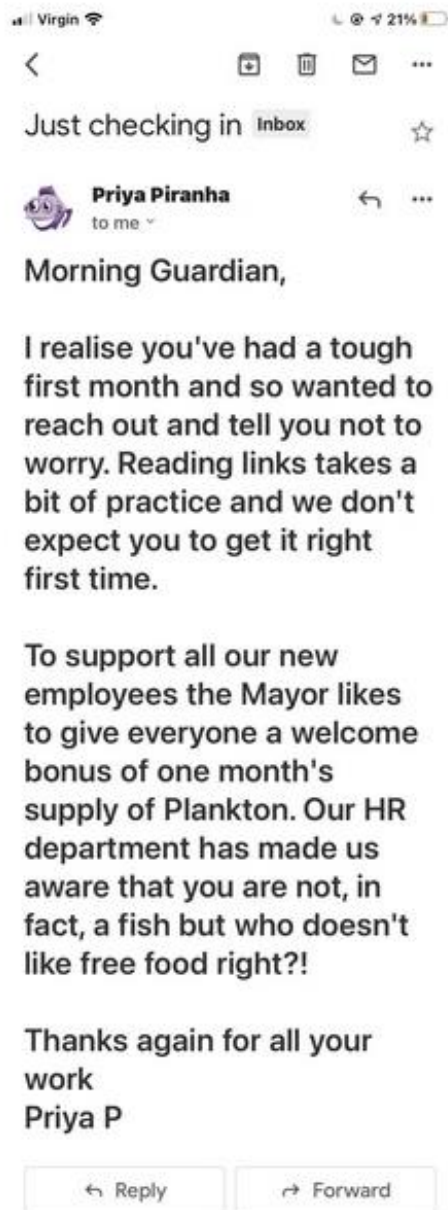
Thanks again for all your work  
**Priya P**

← Reply

→ Forward

## 7.4.5 Gamified Lose Condition (if player failed to correctly classify both example URLs)

It's the end of your first month as a Web Guardian and you arrive in the office to another email from Priya



## 7.5 Assessment Questions

| brand   | type   | url                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|---------|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| air bnb | safe   | <a href="https://www.airbnb.com/?_set_bev_on_new_domain=1621617036_ZDY5OTJkNGQzMmYz">https://www.airbnb.com/?_set_bev_on_new_domain=1621617036_ZDY5OTJkNGQzMmYz</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| amazon  | unsafe | <a href="https://www.amazon-com.store.com/gp/css/homepage.html?ref_=nav_youraccount_btn">https://www.amazon-com.store.com/gp/css/homepage.html?ref_=nav_youraccount_btn</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| amazon  | safe   | <a href="https://www.amazon.com/ap/signin?openid.pape.max_auth_age=0&amp;openid.return_to=https%3A%2F%2Fwww.amazon.com%2F%3F_encoding%3DUTF8%26ref_%3Dnav_ya_signin&amp;openid.identity=http%3A%2F%2Fspecs.openid.net%2Fauth%2F2.0%2Fidentifier_select&amp;openid.assoc_handle=gbflex&amp;openid.mode=checkid_setup&amp;openid.claimed_id=http%3A%2F%2Fspecs.openid.net%2Fauth%2F2.0%2Fidentifier_select&amp;openid.ns=http%3A%2F%2Fspecs.openid.net%2Fauth%2F2.0&amp;">https://www.amazon.com/ap/signin?openid.pape.max_auth_age=0&amp;openid.return_to=https%3A%2F%2Fwww.amazon.com%2F%3F_encoding%3DUTF8%26ref_%3Dnav_ya_signin&amp;openid.identity=http%3A%2F%2Fspecs.openid.net%2Fauth%2F2.0%2Fidentifier_select&amp;openid.assoc_handle=gbflex&amp;openid.mode=checkid_setup&amp;openid.claimed_id=http%3A%2F%2Fspecs.openid.net%2Fauth%2F2.0%2Fidentifier_select&amp;openid.ns=http%3A%2F%2Fspecs.openid.net%2Fauth%2F2.0&amp;</a> |
| amazon  | unsafe | <a href="https://amazon.warehouse.com/">https://amazon.warehouse.com/</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| aol     | unsafe | <a href="https://login.aol.mail.com/?lang=en-gb&amp;intl=uk">https://login.aol.mail.com/?lang=en-gb&amp;intl=uk</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| aol     | unsafe | <a href="https://aol.secure.com/?src=guce-mail&amp;lang=en-GB&amp;done=https%3A%2F%2Fmail.aol.com%2Fwebmail-std%2Fen-gb%2Fsuite">https://aol.secure.com/?src=guce-mail&amp;lang=en-GB&amp;done=https%3A%2F%2Fmail.aol.com%2Fwebmail-std%2Fen-gb%2Fsuite</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| aol     | safe   | <a href="https://login.aol.com/?src=guce-mail&amp;lang=en-GB&amp;done=https%3A%2F%2Fmail.aol.com%2Fwebmail-std%2Fen-gb%2Fsuite">https://login.aol.com/?src=guce-mail&amp;lang=en-GB&amp;done=https%3A%2F%2Fmail.aol.com%2Fwebmail-std%2Fen-gb%2Fsuite</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| apple   | safe   | <a href="https://secure4.store.apple.com/shop/signIn?c=aHR0cHM6Ly93d3cuYXBwbGUuY29tL3wxYW9zZTQyMmM4Y2NkMTc4NWJhN2U2ZDI2NWVmYWU3NWl4YTJhZGlyYzAwZQ&amp;r=SCDHYHP7CY4H9XK2H&amp;s=aHR0cHM6Ly93d3cuYXBwbGUuY29tL3wxYW9zZTQyMmM4Y2NkMTc4NWJhN2U2ZDI2NWVmYWU3NWl4YTJhZGlyYzAwZQ">https://secure4.store.apple.com/shop/signIn?c=aHR0cHM6Ly93d3cuYXBwbGUuY29tL3wxYW9zZTQyMmM4Y2NkMTc4NWJhN2U2ZDI2NWVmYWU3NWl4YTJhZGlyYzAwZQ&amp;r=SCDHYHP7CY4H9XK2H&amp;s=aHR0cHM6Ly93d3cuYXBwbGUuY29tL3wxYW9zZTQyMmM4Y2NkMTc4NWJhN2U2ZDI2NWVmYWU3NWl4YTJhZGlyYzAwZQ</a>                                                                                                                                                                                                                                                                                                                                                                                         |
| apple   | unsafe | <a href="https://apple.macbook.com/shop/signIn">https://apple.macbook.com/shop/signIn</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| apple   | unsafe | <a href="https://www.apple.privacy.com/login">https://www.apple.privacy.com/login</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

|             |        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-------------|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| booking.com | safe   | <a href="https://account.booking.com/sign-in?op_token=EgVvYXV0aClDagoUdk8xS2Jsazd4WDI0VW4yY3BaTFMSCWF1dGhvcml6ZRo1aHR0cHM6Ly9zZWN1cmUuYm9va2luZy5jb20vbG9naW4uaHRtbD9vcD1vYXV0aF9yZXR1cm4q_AFVcm9CMFducEhJNEtra3FjTm1LZlZNSHRBdVBHa2lDM3pwcNvVWEh1SWhCb2p6R2JkSTJTR1IRRMl0OFhzejdVWkxKbGtNN184b0hudC1LLUdMZUxYZG5tZ01nU1o2Y2NyNDVBQkNGNnF3YjFNb2JNcUZjeV9XT0Mxam1hQzdiTkN4U3RpN1hQYk4zRm5PUTE0WTdxaXdTa2FzdmE0Y1dZY0tCMjdmdXVsQVZsSUIQbkNLVE5NQk0zMV85OTdhVmc0UU14LS02UjBRSDJUYkVjQXBINWh4aHRkN3R3VDh5TkpJN2Fab0duSTFuSWJZS1dndy1vemoyZGV3VWRCBGNvZGUqFgiOyBlwqYjZk-XvJDoAQgBYw9GfhQY">https://account.booking.com/sign-in?op_token=EgVvYXV0aClDagoUdk8xS2Jsazd4WDI0VW4yY3BaTFMSCWF1dGhvcml6ZRo1aHR0cHM6Ly9zZWN1cmUuYm9va2luZy5jb20vbG9naW4uaHRtbD9vcD1vYXV0aF9yZXR1cm4q_AFVcm9CMFducEhJNEtra3FjTm1LZlZNSHRBdVBHa2lDM3pwcNvVWEh1SWhCb2p6R2JkSTJTR1IRRMl0OFhzejdVWkxKbGtNN184b0hudC1LLUdMZUxYZG5tZ01nU1o2Y2NyNDVBQkNGNnF3YjFNb2JNcUZjeV9XT0Mxam1hQzdiTkN4U3RpN1hQYk4zRm5PUTE0WTdxaXdTa2FzdmE0Y1dZY0tCMjdmdXVsQVZsSUIQbkNLVE5NQk0zMV85OTdhVmc0UU14LS02UjBRSDJUYkVjQXBINWh4aHRkN3R3VDh5TkpJN2Fab0duSTFuSWJZS1dndy1vemoyZGV3VWRCBGNvZGUqFgiOyBlwqYjZk-XvJDoAQgBYw9GfhQY</a> |
| capital one | safe   | <a href="https://verified.capitalone.com/auth/signin">https://verified.capitalone.com/auth/signin</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| dropbox     | safe   | <a href="https://www.dropbox.com/login">https://www.dropbox.com/login</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| ebay        | unsafe | <a href="https://signin.ebay.shopping.com/ws/eBayISAPI.dll?SignIn">https://signin.ebay.shopping.com/ws/eBayISAPI.dll?SignIn</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| ebay        | safe   | <a href="https://signin.ebay.com/ws/eBayISAPI.dll?SignIn&amp;UsingSSL=1&amp;siteid=3&amp;co_partnerId=2&amp;pageType=2561280&amp;ru=https%3A%2F%2Fwww.ebay.co.uk%2Fmys%2Fhome%3Fsource%3DGBH">https://signin.ebay.com/ws/eBayISAPI.dll?SignIn&amp;UsingSSL=1&amp;siteid=3&amp;co_partnerId=2&amp;pageType=2561280&amp;ru=https%3A%2F%2Fwww.ebay.co.uk%2Fmys%2Fhome%3Fsource%3DGBH</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| efax        | safe   | <a href="https://portal.efax.com/myaccount/login">https://portal.efax.com/myaccount/login</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| efax        | unsafe | <a href="https://portal.efax.global.com/myaccount/login">https://portal.efax.global.com/myaccount/login</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| facebook    | unsafe | <a href="https://www.facebook.user.net">https://www.facebook.user.net</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| facebook    | unsafe | <a href="https://facebook.com.abc.com/login">https://facebook.com.abc.com/login</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| facebook    | safe   | <a href="https://www.facebook.com/login/?privacy_mutation_token=eyJ0eXBlljowLCJjcmVhdGlvbI90aW1lIjoxNjlxNTE2MDIzLCJjYWxsc2l0ZV9pZCI6Mzg5MjI5MDc5NTc1OTQ2fQ%3D%3D">https://www.facebook.com/login/?privacy_mutation_token=eyJ0eXBlljowLCJjcmVhdGlvbI90aW1lIjoxNjlxNTE2MDIzLCJjYWxsc2l0ZV9pZCI6Mzg5MjI5MDc5NTc1OTQ2fQ%3D%3D</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| fedex       | unsafe | <a href="https://www.fe.dex.com/en-gb/signin?CMP=KNC-1001972-2-1-950-1000000-EMEA-GB-EN-PPCGBBRAND000GO&amp;gclid=EAIaIqobChMIroWVgrTY8AIVR_gYCh3kZQ5jEAAYASAAEgKhipD_BwE">https://www.fe.dex.com/en-gb/signin?CMP=KNC-1001972-2-1-950-1000000-EMEA-GB-EN-PPCGBBRAND000GO&amp;gclid=EAIaIqobChMIroWVgrTY8AIVR_gYCh3kZQ5jEAAYASAAEgKhipD_BwE</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |

|           |        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|-----------|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| fedex     | safe   | <a href="https://www.fedex.com/en-gb/open-account.html?CMP=KNC-1001972-2-1-950-1000000-EMEA-GB-EN-PPCGBBRAND000GO&amp;gclid=EAlaIqObChMIroWVgrTY8AIVR_gYCh3kZQ5jEAAYASAAEgKhiPD_BwE">https://www.fedex.com/en-gb/open-account.html?CMP=KNC-1001972-2-1-950-1000000-EMEA-GB-EN-PPCGBBRAND000GO&amp;gclid=EAlaIqObChMIroWVgrTY8AIVR_gYCh3kZQ5jEAAYASAAEgKhiPD_BwE</a>                                                                                                                                                                                                                                                         |
| fedex     | safe   | <a href="https://www.fedex.com/en-gb/login?loc=en_GB&amp;returnto=https%3A%2F%2Fwww.fedex.com%2Fgb%2Fen%2FHome.page">https://www.fedex.com/en-gb/login?loc=en_GB&amp;returnto=https%3A%2F%2Fwww.fedex.com%2Fgb%2Fen%2FHome.page</a>                                                                                                                                                                                                                                                                                                                                                                                         |
| google    | unsafe | <a href="https://google.acccount-drive-google.com/ServiceLogin/signinchooser?service=wise&amp;passive=1209600&amp;continue=https%3A%2F%2Fdrive.google.com%2Fdrive%2Fmy-drive&amp;followup=https%3A%2F%2Fdrive.google.com%2Fdrive%2Fmy-drive&amp;flowName=GlifWebSignIn&amp;flowEntry=ServiceLogin">https://google.acccount-drive-google.com/ServiceLogin/signinchooser?service=wise&amp;passive=1209600&amp;continue=https%3A%2F%2Fdrive.google.com%2Fdrive%2Fmy-drive&amp;followup=https%3A%2F%2Fdrive.google.com%2Fdrive%2Fmy-drive&amp;flowName=GlifWebSignIn&amp;flowEntry=ServiceLogin</a>                             |
| google    | unsafe | <a href="https://accounts.signin.com/google/v2/identifier?service=wise&amp;passive=true&amp;continue=http%3A%2F%2Fdrive.google.com%2F%3Futm_source%3Den&amp;utm_medium=button&amp;utm_campaign=web&amp;utm_content=gotodrive&amp;usp=gttd&amp;ltmpl=drive&amp;flowName=GlifWebSignIn&amp;flowEntry=ServiceLogin">https://accounts.signin.com/google/v2/identifier?service=wise&amp;passive=true&amp;continue=http%3A%2F%2Fdrive.google.com%2F%3Futm_source%3Den&amp;utm_medium=button&amp;utm_campaign=web&amp;utm_content=gotodrive&amp;usp=gttd&amp;ltmpl=drive&amp;flowName=GlifWebSignIn&amp;flowEntry=ServiceLogin</a> |
| google    | unsafe | <a href="https://google.images.com/signin/v2/identifier?hl=en&amp;passive=true&amp;continue=https%3A%2F%2Fimages.google.co.uk%2F&amp;ec=GAZAAG&amp;flowName=GlifWebSignIn&amp;flowEntry=ServiceLogin">https://google.images.com/signin/v2/identifier?hl=en&amp;passive=true&amp;continue=https%3A%2F%2Fimages.google.co.uk%2F&amp;ec=GAZAAG&amp;flowName=GlifWebSignIn&amp;flowEntry=ServiceLogin</a>                                                                                                                                                                                                                       |
| google    | unsafe | <a href="https://www.google.login.com/secure">https://www.google.login.com/secure</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| google    | safe   | <a href="https://mail.google.com/mail/user?lang=en">https://mail.google.com/mail/user?lang=en</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| linkedin  | safe   | <a href="https://www.linkedin.com/login?fromSignIn=true&amp;trk=guest_homepage-basic_nav-header-signin">https://www.linkedin.com/login?fromSignIn=true&amp;trk=guest_homepage-basic_nav-header-signin</a>                                                                                                                                                                                                                                                                                                                                                                                                                   |
| linkedin  | unsafe | <a href="https://www.linkedin.networking.com/login?fromSignIn=true&amp;trk=guest_homepage-basic_nav-header-signin">https://www.linkedin.networking.com/login?fromSignIn=true&amp;trk=guest_homepage-basic_nav-header-signin</a>                                                                                                                                                                                                                                                                                                                                                                                             |
| microsoft | unsafe | <a href="https://www.microsoft.account.com/en-gb/?wa=wsignin1.0">https://www.microsoft.account.com/en-gb/?wa=wsignin1.0</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| netflix   | safe   | <a href="https://www.netflix.com/login">https://www.netflix.com/login</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |

|                   |        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|-------------------|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| netflix           | unsafe | <a href="https://www.netflix.watch.com/gb/login">https://www.netflix.watch.com/gb/login</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| paypal            | safe   | <a href="https://www.paypal.com/signin?country.x=US&amp;locale.x=en_US&amp;langTgl=en">https://www.paypal.com/signin?country.x=US&amp;locale.x=en_US&amp;langTgl=en</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| samsung           | safe   | <a href="https://account.samsung.com/accounts/v1/Samsung_com_UK/signInGate?response_type=code&amp;client_id=84hg4924k6&amp;locale=en_GB&amp;countryCode=GB&amp;redirect_uri=https:%2F%2Fwww.samsung.com%2Faemapi%2Fv6%2Fdata-login%2FafterLogin.uk.json&amp;state=GLBfxir8gypt8k&amp;goBackURL=https:%2F%2Fwww.samsung.com%2Fuk%2F&amp;scope=">https://account.samsung.com/accounts/v1/Samsung_com_UK/signInGate?response_type=code&amp;client_id=84hg4924k6&amp;locale=en_GB&amp;countryCode=GB&amp;redirect_uri=https:%2F%2Fwww.samsung.com%2Faemapi%2Fv6%2Fdata-login%2FafterLogin.uk.json&amp;state=GLBfxir8gypt8k&amp;goBackURL=https:%2F%2Fwww.samsung.com%2Fuk%2F&amp;scope=</a>                                                                                                                                                                                                                                                                   |
| save the children | unsafe | <a href="https://www.save.the.children.now.org/donate">https://www.save.the.children.now.org/donate</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| save the children | safe   | <a href="https://support.savethechildren.org/site/Donation2?df_id=1620&amp;1620.donation=form1">https://support.savethechildren.org/site/Donation2?df_id=1620&amp;1620.donation=form1</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| t-mobile          | safe   | <a href="https://account.t-mobile.com/signin/v2/?redirect_uri=https:%2F%2Fwww.t-mobile.com%2Fsignin&amp;scope=TMO_ID_profile%2520associated_lines%2520billing_information%2520associated_billing_accounts%2520extended_lines%2520token%2520openid%2520vault&amp;client_id=MYTMO&amp;access_type=ONLINE&amp;response_type=code&amp;approval_prompt=auto&amp;prompt=select_account&amp;state=eyJpbmRlbnQiOiJMb2dpbilsImJvb2ttYXJrVXJsIjoiaHR0cHM6Ly9teS50LW1vYmIsZS5jb20ifQ">https://account.t-mobile.com/signin/v2/?redirect_uri=https:%2F%2Fwww.t-mobile.com%2Fsignin&amp;scope=TMO_ID_profile%2520associated_lines%2520billing_information%2520associated_billing_accounts%2520extended_lines%2520token%2520openid%2520vault&amp;client_id=MYTMO&amp;access_type=ONLINE&amp;response_type=code&amp;approval_prompt=auto&amp;prompt=select_account&amp;state=eyJpbmRlbnQiOiJMb2dpbilsImJvb2ttYXJrVXJsIjoiaHR0cHM6Ly9teS50LW1vYmIsZS5jb20ifQ</a>           |
| t-mobile          | unsafe | <a href="https://t-mobile.signal.fiveg.com/signin/v2/?redirect_uri=https:%2F%2Fwww.t-mobile.com%2Fsignin&amp;scope=TMO_ID_profile%2520associated_lines%2520billing_information%2520associated_billing_accounts%2520extended_lines%2520token%2520openid%2520vault&amp;client_id=MYTMO&amp;access_type=ONLINE&amp;response_type=code&amp;approval_prompt=auto&amp;prompt=select_account&amp;state=eyJpbmRlbnQiOiJMb2dpbilsImJvb2ttYXJrVXJsIjoiaHR0cHM6Ly9teS50LW1vYmIsZS5jb20ifQ">https://t-mobile.signal.fiveg.com/signin/v2/?redirect_uri=https:%2F%2Fwww.t-mobile.com%2Fsignin&amp;scope=TMO_ID_profile%2520associated_lines%2520billing_information%2520associated_billing_accounts%2520extended_lines%2520token%2520openid%2520vault&amp;client_id=MYTMO&amp;access_type=ONLINE&amp;response_type=code&amp;approval_prompt=auto&amp;prompt=select_account&amp;state=eyJpbmRlbnQiOiJMb2dpbilsImJvb2ttYXJrVXJsIjoiaHR0cHM6Ly9teS50LW1vYmIsZS5jb20ifQ</a> |
| unicef            | safe   | <a href="https://www.unicef.org/donate/?utm_source=uukask&amp;utm_medium=support_unicef_website&amp;utm_campaign=donation">https://www.unicef.org/donate/?utm_source=uukask&amp;utm_medium=support_unicef_website&amp;utm_campaign=donation</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |

|               |        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|---------------|--------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| UPS           | unsafe | <a href="https://www.ups.delivery.net/gb/en/Home.page?WT.srch=1&amp;WT.mc_id=ds_gclid:EAlalQobChMIsKGVurDY8AIVB5eyCh36Wgc_EAAYASAAEgK-zfD_BwE:dscid:71700000050016000:searchterm:ups&amp;gclid=EAlalQobChMIsKGVurDY8AIVB5eyCh36Wgc_EAAYASAAEgK-zfD_BwE&amp;gclsrc=aw.ds">https://www.ups.delivery.net/gb/en/Home.page?WT.srch=1&amp;WT.mc_id=ds_gclid:EAlalQobChMIsKGVurDY8AIVB5eyCh36Wgc_EAAYASAAEgK-zfD_BwE:dscid:71700000050016000:searchterm:ups&amp;gclid=EAlalQobChMIsKGVurDY8AIVB5eyCh36Wgc_EAAYASAAEgK-zfD_BwE&amp;gclsrc=aw.ds</a> |
| ups           | safe   | <a href="https://www.ups.com/lasso/login?loc=en_US&amp;returnto=https%3A%2F%2Fwww.ups.com%2Fus%2Fen%2FHome.page">https://www.ups.com/lasso/login?loc=en_US&amp;returnto=https%3A%2F%2Fwww.ups.com%2Fus%2Fen%2FHome.page</a>                                                                                                                                                                                                                                                                                                                 |
| western union | unsafe | <a href="https://www.westernunion.money.com">https://www.westernunion.money.com</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| western union | safe   | <a href="https://www.westernunion.com/gb/en/web/user/login">https://www.westernunion.com/gb/en/web/user/login</a>                                                                                                                                                                                                                                                                                                                                                                                                                           |
| xerox         | safe   | <a href="https://accountmanagement.services.xerox.com/sites/customerportal#Home_Dispatcher-Display">https://accountmanagement.services.xerox.com/sites/customerportal#Home_Dispatcher-Display</a>                                                                                                                                                                                                                                                                                                                                           |
| yahoo         | unsafe | <a href="https://yahoo.login.com/?intl=us&amp;.lang=en-US&amp;src=ym&amp;activity=mail-direct&amp;pspid=159600001&amp;done=https%3A%2F%2Fmail.yahoo.com%2Fd&amp;add=1">https://yahoo.login.com/?intl=us&amp;.lang=en-US&amp;src=ym&amp;activity=mail-direct&amp;pspid=159600001&amp;done=https%3A%2F%2Fmail.yahoo.com%2Fd&amp;add=1</a>                                                                                                                                                                                                     |
| yahoo         | safe   | <a href="https://login.yahoo.com/manage_account?.lang=en-GB&amp;src=homepage&amp;pspid=2023392312&amp;activity=ybar-signin&amp;signin=true&amp;done=https%3A%2F%2Fuk.yahoo.com%2F%3Fp%3Dus&amp;eid=100">https://login.yahoo.com/manage_account?.lang=en-GB&amp;src=homepage&amp;pspid=2023392312&amp;activity=ybar-signin&amp;signin=true&amp;done=https%3A%2F%2Fuk.yahoo.com%2F%3Fp%3Dus&amp;eid=100</a>                                                                                                                                   |
| zoom          | unsafe | <a href="https://www.zoom.connect.com/signin">https://www.zoom.connect.com/signin</a>                                                                                                                                                                                                                                                                                                                                                                                                                                                       |



## 8 References

- Akhawe, D., Felt, A.P., 2013. Alice in warningland: A large-scale field study of browser security warning effectiveness, in: 22nd USENIX Security Symposium USENIX Security 13. pp. 257–272.
- Albakry, S., Vaniea, K., Wolters, M.K., 2020. What is this URL's Destination? Empirical Evaluation of Users' URL Reading, in: Proceedings of the 2020 CHI Conference on Human Factors in Computing Systems. Presented at the CHI '20: CHI Conference on Human Factors in Computing Systems, ACM, Honolulu HI USA, pp. 1–12.  
<https://doi.org/10.1145/3313831.3376168>
- Al-Hamar, M., Dawson, R., Al-Hamar, J., 2011. The need for education on phishing: a survey comparison of the UK and Qatar. *Campus-Wide Information Systems* 28, 308–319.  
<https://doi.org/10.1108/10650741111181580>
- Anandpara, V., Dingman, A., Jakobsson, M., Liu, D., Roinestad, H., 2007. Phishing IQ tests measure fear, not ability, in: International Conference on Financial Cryptography and Data Security. Springer, pp. 362–366.
- Anawar, S., Kunasegaran, D.L., Mas'ud, M.Z., Zakaria, N.A., 2019. Analysis of phishing susceptibility in a workplace: a big-five personality perspectives. *J Eng Sci Technol* 14, 2865–2882.
- Bai, S., Hew, K.F., Huang, B., 2020. Does gamification improve student learning outcome? Evidence from a meta-analysis and synthesis of qualitative data in educational contexts. *Educational Research Review* 30, 100322.  
<https://doi.org/10.1016/j.edurev.2020.100322>
- Baslyman, M., Chiasson, S., 2016. "Smells Phishy?": An Educational Game about Online Phishing Scams, in: 2016 APWG Symposium on Electronic Crime Research (ECrime). p. 11.
- Benenson, Z., Gassmann, F., Landwirth, R., 2017. Unpacking spear phishing susceptibility, in: International Conference on Financial Cryptography and Data Security. Springer, pp. 610–627.
- Canova, G., Volkamer, M., Bergmann, C., Borza, R., 2014. NoPhish: An Anti-Phishing Education App, in: Mauw, S., Jensen, C.D. (Eds.), *Security and Trust Management, Lecture Notes in Computer Science*. Springer International Publishing, Cham, pp. 188–192.  
[https://doi.org/10.1007/978-3-319-11851-2\\_14](https://doi.org/10.1007/978-3-319-11851-2_14)
- Caputo, D.D., Pfleeger, S.L., Freeman, J.D., Johnson, M.E., 2014. Going Spear Phishing: Exploring Embedded Training and Awareness. *IEEE Security Privacy* 12, 28–38.  
<https://doi.org/10.1109/MSP.2013.106>
- Carella, A., Kotsoev, M., Truta, T.M., 2017. Impact of security awareness training on phishing click-through rates, in: 2017 IEEE International Conference on Big Data (Big Data). Presented at the 2017 IEEE International Conference on Big Data (Big Data), pp. 4458–4466. <https://doi.org/10.1109/BigData.2017.8258485>
- Carr, M., Shahandashti, S.F., 2020. Revisiting Security Vulnerabilities in Commercial Password Managers, in: Hölbl, M., Rannenberg, K., Welzer, T. (Eds.), *ICT Systems Security and*

- Privacy Protection, IFIP Advances in Information and Communication Technology. Springer International Publishing, Cham, pp. 265–279. [https://doi.org/10.1007/978-3-030-58201-2\\_18](https://doi.org/10.1007/978-3-030-58201-2_18)
- Chainalysis, 2021. The 2021 Crypto Crime Report. Chainalysis.
- Choo, C.W., 2013. Information culture and organizational effectiveness. *International Journal of Information Management* 33, 775–779.
- Cialdini, R.B., 2007. Influence: The psychology of persuasion. Harper Business (Revision Edition).
- Costa, D.L., Kahn, M.E., 2013. Energy conservation “nudges” and environmentalist ideology: Evidence from a randomized residential electricity field experiment. *Journal of the European Economic Association* 11, 680–702.
- Cram, W.A., Proudfoot, J.G., D’Arcy, J., 2020. When enough is enough: Investigating the antecedents and consequences of information security fatigue. *Information Systems Journal* 31. <https://doi.org/10.1111/isj.12319>
- Cyber Awareness Posters [WWW Document], 2019. . MetaCompliance. URL <https://www.metacompliance.com/resources/cyber-awareness-posters/> (accessed 4.5.21).
- De Bona, M., Paci, F., 2020. A real world study on employees’ susceptibility to phishing attacks, in: *Proceedings of the 15th International Conference on Availability, Reliability and Security, ARES ’20*. Association for Computing Machinery, New York, NY, USA, pp. 1–10. <https://doi.org/10.1145/3407023.3409179>
- Department for Education, 2019. Essential Digital Skills Framework [WWW Document]. GOV.UK. URL <https://www.gov.uk/government/publications/essential-digital-skills-framework> (accessed 5.31.21).
- Diaz, A., Sherman, A.T., Joshi, A., 2020. Phishing in an academic community: A study of user susceptibility and behavior. *Cryptologia* 44, 53–67.
- Dodge, R., Coronges, K., Rovira, E., 2012. Empirical benefits of training to phishing susceptibility, in: *IFIP International Information Security Conference*. Springer, pp. 457–464.
- Dou, Z., Khalil, I., Khreishah, A., Al-Fuqaha, A., Guizani, M., 2017. Systematization of Knowledge (SoK): A Systematic Review of Software-Based Web Phishing Detection. *IEEE Communications Surveys Tutorials* 19, 2797–2819. <https://doi.org/10.1109/COMST.2017.2752087>
- Evers, J., 2006. Security expert: User education is pointless. *ZDNet*. URL <https://www.zdnet.com/article/security-expert-user-education-is-pointless/> (accessed 2.21.21).
- Ferreira, A., Teles, S., 2019. Persuasion: How phishing emails can influence users and bypass security measures. *International Journal of Human-Computer Studies* 125, 19–31. <https://doi.org/10.1016/j.ijhcs.2018.12.004>
- Flores, W.R., Holm, H., Nohlberg, M., Ekstedt, M., 2015. Investigating personal determinants of phishing and the effect of national culture. *Information and Computer Security* 23, 178–199. <http://dx.doi.org.ezproxy1.hw.ac.uk/10.1108/ICS-05-2014-0029>
- Francia, G., Thornton, D., Trifas, M., Bowden, T., 2014. Chapter 5 - Gamification of Information Security Awareness Training, in: Akhgar, B., Arabnia, H.R. (Eds.), *Emerging Trends in ICT Security*. Morgan Kaufmann, Boston, pp. 85–97. <https://doi.org/10.1016/B978-0-12-411474-6.00005-0>

- Gokul, C., Pandit, S., Vaddepalli, S., Tupsamudre, H., Banahatti, V., Lodha, S., 2018. Phishy a serious game to train enterprise users on phishing awareness, in: *Proceedings of the 2018 Annual Symposium on Computer-Human Interaction in Play Companion Extended Abstracts*. pp. 169–181.
- Gopavaram, S., Dev, J., Grobler, M., Kim, D., Das, S., Camp, L.J., 2021. Cross-National Study on Phishing Resilience. Presented at the *Proceedings of the Workshop on Usable Security and Privacy (USEC)*, Social Science Research Network, Rochester, NY.
- Gordon, W.J., Wright, A., Aiyagari, R., Corbo, L., Glynn, R.J., Kadakia, J., Kufahl, J., Mazzone, C., Noga, J., Parkulo, M., Sanford, B., Scheib, P., Landman, A.B., 2019a. Assessment of Employee Susceptibility to Phishing Attacks at US Health Care Institutions. *JAMA Netw Open* 2, e190393. <https://doi.org/10.1001/jamanetworkopen.2019.0393>
- Gordon, W.J., Wright, A., Glynn, R.J., Kadakia, J., Mazzone, C., Leinbach, E., Landman, A., 2019b. Evaluation of a mandatory phishing training program for high-risk employees at a US healthcare system. *Journal of the American Medical Informatics Association* 26, 547–552. <https://doi.org/10.1093/jamia/ocz005>
- Gragg, D., 2003. A multi-level defense against social engineering. SANS Reading Room.
- Greene, K.K., Steves, M., Theofanos, M., Kostick, J., 2018. User context: an explanatory variable in phishing susceptibility, in: *In Proc. 2018 Workshop Usable Security*.
- Greitzer, F.L., Li, W., Laskey, K.B., Lee, J., Purl, J., 2021. Experimental Investigation of Technical and Human Factors Related to Phishing Susceptibility. *Trans. Soc. Comput.* 4, 8:1-8:48. <https://doi.org/10.1145/3461672>
- Grilli, M.D., McVeigh, K.S., Hakim, Z.M., Wank, A.A., Getz, S.J., Levin, B.E., Ebner, N.C., Wilson, R.C., 2020. Is this phishing? Older age is associated with greater difficulty discriminating between safe and malicious emails. *The journals of gerontology. Series B, Psychological sciences and social sciences* XX, 1–5. <https://doi.org/10.1093/geronb/gbaa228>
- Halevi, T., Memon, N., Nov, O., 2015. Spear-phishing in the wild: A real-world study of personality, phishing self-efficacy and vulnerability to spear-phishing attacks. *Phishing Self-Efficacy and Vulnerability to Spear-Phishing Attacks* (January 2, 2015).
- Hanus, B., Wu, Y.A., Parrish, J., 2021. Phish Me, Phish Me Not. *Journal of Computer Information Systems* 0, 1–11. <https://doi.org/10.1080/08874417.2020.1858730>
- Hendrix, M., Al-Sherbaz, A., Victoria, B., 2016. Game based cyber security training: are serious games suitable for cyber security training? *International Journal of Serious Games* 3.
- Henshel, D., Sample, C., Cains, M., Hoffman, B., 2016. Integrating cultural factors into human factors framework and ontology for cyber attackers, in: *Advances in Human Factors in Cybersecurity*. Springer, pp. 123–137.
- Heriot-Watt University (Edinburgh Campus), 2020. *School of Mathematical & Computer Sciences: Postgraduate Program Handbook*.
- HHS.gov, 2009. Summary of the HIPAA Security Rule [WWW Document]. HHS.gov. URL <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html> (accessed 4.5.21).
- Hong, K.W., Kelley, C.M., Tembe, R., Murphy-Hill, E., Mayhorn, C.B., 2013. Keeping up with the Joneses: Assessing phishing susceptibility in an email task, in: *Proceedings of the Human Factors and Ergonomics Society Annual Meeting*. SAGE Publications Sage CA: Los Angeles, CA, pp. 1012–1016.

- IBM, 2021. Cost of a Data Breach Report 2020 | IBM [WWW Document]. URL <https://www.ibm.com/security/digital-assets/cost-data-breach-report/> (accessed 2.8.21).
- Iuga, C., Nurse, J.R.C., Erola, A., 2016. Baiting the hook: factors impacting susceptibility to phishing attacks. *Human-centric computing and information sciences* 6, 1–20. <https://doi.org/10.1186/s13673-016-0065-2>
- Jackson, C., Simon, D.R., Tan, D.S., Barth, A., 2007. An Evaluation of Extended Validation and Picture-in-Picture Phishing Attacks, in: Dietrich, S., Dhamija, R. (Eds.), *Financial Cryptography and Data Security, Lecture Notes in Computer Science*. Springer, Berlin, Heidelberg, pp. 281–293. [https://doi.org/10.1007/978-3-540-77366-5\\_27](https://doi.org/10.1007/978-3-540-77366-5_27)
- Jagatic, T.N., Johnson, N.A., Jakobsson, M., Menczer, F., 2007. Social phishing. *Communications of the ACM* 50, 94–100.
- Jampen, D., Gür, G., Sutter, T., Tellenbach, B., 2020. Don't click: towards an effective anti-phishing training. A comparative literature review. *Hum. Cent. Comput. Inf. Sci.* 10, 1–41. <https://doi.org/10.1186/s13673-020-00237-7>
- Karumbaiah, S., Wright, R.T., Durcikova, A., Jensen, M.L., 2016. Phishing training: a preliminary look at the effects of different types of training, in: *Proceedings of the 11th Pre-ICIS Workshop on Information Security and Privacy*. pp. 1–10.
- KnowBe4, 2020. 2020 Phishing By Industry Benchmarking Report [WWW Document]. URL <https://info.knowbe4.com/phishing-by-industry-benchmarking-report>
- Komanduri, S., Shay, R., Cranor, L.F., Herley, C., Schechter, S., 2014. Telepathwords: Preventing weak passwords by reading users' minds, in: *Proceedings of the 23rd USENIX Security Symposium*. pp. 591–606.
- Kumaraguru, P., Cranshaw, J., Acquisti, A., Cranor, L., Hong, J., Blair, M.A., Pham, T., 2009. School of phish: a real-world evaluation of anti-phishing training, in: *Proceedings of the 5th Symposium on Usable Privacy and Security*. pp. 1–12.
- Kumaraguru, P., Rhee, Y., Acquisti, A., Cranor, L.F., Hong, J., Nunge, E., 2007a. Protecting people from phishing: the design and evaluation of an embedded training email system, in: *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*. pp. 905–914.
- Kumaraguru, P., Rhee, Y., Sheng, S., Hasan, S., Acquisti, A., Cranor, L.F., Hong, J., 2007b. Getting users to pay attention to anti-phishing education: evaluation of retention and transfer, in: *Proceedings of the Anti-Phishing Working Groups 2nd Annual ECrime Researchers Summit*. pp. 70–81.
- Kumaraguru, P., Sheng, S., Acquisti, A., Cranor, L.F., Hong, J., 2010. Teaching Johnny not to fall for phish. *ACM Transactions on Internet Technology (TOIT)* 10, 1–31.
- Kumaraguru, P., Sheng, S., Acquisti, A., Cranor, L.F., Hong, J., 2008. Lessons from a real world evaluation of anti-phishing training, in: *2008 ECrime Researchers Summit*. IEEE, pp. 1–12.
- Kunz, A., Volkamer, M., Stockhardt, S., Palberg, S., Lottermann, T., Piegert, E., 2016. Nophish: evaluation of a web application that teaches people being aware of phishing attacks. *Informatik* 2016.
- Lee, Y., Saxe, J., Harang, R., 2020. CATBERT: Context-Aware Tiny BERT for Detecting Social Engineering Emails. *arXiv:2010.03484 [cs]*.

- Li, W., Lee, J., Purl, J., Greitzer, F., Yousefi, B., Laskey, K., 2020. Experimental investigation of demographic factors related to phishing susceptibility, in: Proceedings of the 53rd Hawaii International Conference on System Sciences.
- Lin, T., Capecci, D., Ellis, D., Rocha, H., Dommaraju, S., Oliveira, D., Ebner, N., 2019. Susceptibility to Spear-Phishing Emails: Effects of Internet User Demographics and Email Content. *ACM transactions on computer-human interaction* 26, 1–28.  
<https://doi.org/10.1145/3336141>
- Lloyds Bank, 2020. Essential Digital Skills - Lloyds Bank [WWW Document]. URL <https://www.lloydsbank.com/banking-with-us/whats-happening/consumer-digital-index/essential-digital-skills.html> (accessed 7.16.21).
- Mayhorn, C.B., Nyeste, P.G., 2012. Training users to counteract phishing. *Work* 41, 3549–3552.
- McGill, T., Thompson, N., 2021. Exploring potential gender differences in information security and privacy. *Information & Computer Security ahead-of-print*.  
<https://doi.org/10.1108/ICS-07-2020-0125>
- Mohebzada, J.G., El Zarka, A., BHOjani, A.H., Darwish, A., 2012. Phishing in a university community: Two large scale phishing experiments, in: 2012 International Conference on Innovations in Information Technology (IIT). IEEE, pp. 249–254.
- Moody, G.D., Galletta, D.F., Dunn, B.K., 2017. Which phish get caught? An exploratory study of individuals' susceptibility to phishing. *European Journal of Information Systems* 26, 564–584. <https://doi.org/10.1057/s41303-017-0058-x>
- Moore, S., 2021. Gartner Forecasts Worldwide Security and Risk Management Spending to Exceed \$150 Billion in 2021. Gartner. URL <https://www.gartner.com/en/newsroom/press-releases/2021-05-17-gartner-forecasts-worldwide-security-and-risk-managem> (accessed 8.9.21).
- Mossano, M., Vaniea, K., Aldag, L., Duzgun, R., Mayer, P., Volkamer, M., 2020. Analysis of publicly available anti-phishing webpages: contradicting information, lack of concrete advice and very narrow attack vector, in: 2020 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW). Presented at the 2020 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW), IEEE, Genoa, Italy, pp. 130–139.  
<https://doi.org/10.1109/EuroSPW51379.2020.00026>
- NCSC, 2020. Phishing-attacks-dealing-suspicious-emails-infographic.pdf [WWW Document]. Phishing attacks: dealing with suspicious emails. URL <https://www.ncsc.gov.uk/files/Phishing-attacks-dealing-suspicious-emails-infographic.pdf> (accessed 7.11.21).
- Nielsen, J., 2004. User Education Is Not the Answer to Security Problems. Nielsen Norman Group. URL <https://www.nngroup.com/articles/security-and-user-education/> (accessed 2.21.21).
- O'Connor, A.M., Judges, R.A., Lee, K., Evans, A.D., 2021. Can adults discriminate between fraudulent and legitimate e-mails? Examining the role of age and prior fraud experience. *Journal of Elder Abuse & Neglect* 33, 181–205.  
<https://doi.org/10.1080/08946566.2021.1934767>
- Office for National Statistics (ONS), 2019. Is staff retention an issue in the public sector? Office for National Statistics.

- Onashoga, A.S., Ojo, O.E., Soyombo, O.O., 2019. Securix: a 3D game-based learning approach for phishing attack awareness. *Journal of Cyber Security Technology* 3, 108–124. <https://doi.org/10.1080/23742917.2019.1624011>
- Parsons, K., McCormac, A., Pattinson, M., Butavicius, M., Jerram, C., 2013. Phishing for the truth: A scenario-based experiment of users' behavioural response to emails, in: *IFIP International Information Security Conference*. Springer, pp. 366–378.
- Pattinson, M., Jerram, C., Parsons, K., McCormac, A., Butavicius, M., 2012. Why do some people manage phishing e-mails better than others? *Information Management & Computer Security* 20, 18–28. <https://doi.org/10.1108/09685221211219173>
- Peswani, S., 2018. Safelinks Protection Outlook - Can you and should you disable it? The Windows Club. URL <https://www.thewindowsclub.com/safelinks-protection-outlook> (accessed 4.5.21).
- PhishMe, 2017. Enterprise Phishing Resiliency and Defense Report 2017 [WWW Document]. URL <https://cofense.com/wp-content/uploads/2017/11/Enterprise-Phishing-Resiliency-and-Defense-Report-2017.pdf> (accessed 5.4.21).
- Rastenis, J., Ramanauskaitė, S., Janulevičius, J., Čenys, A., 2019. Credulity to Phishing Attacks: A Real-World Study of Personnel with Higher Education, in: *2019 Open Conference of Electrical, Electronic and Information Sciences (EStream)*. IEEE, pp. 1–5.
- Roepke, R., Koehler, K., Drury, V., Schroeder, U., Wolf, M.R., Meyer, U., 2020. A Pond Full of Phishing Games - Analysis of Learning Games for Anti-Phishing Education, in: *Hatzivasilis, G., Ioannidis, S. (Eds.), Model-Driven Simulation and Training Environments for Cybersecurity, Lecture Notes in Computer Science*. Springer International Publishing, Cham, pp. 41–60. [https://doi.org/10.1007/978-3-030-62433-0\\_3](https://doi.org/10.1007/978-3-030-62433-0_3)
- Rutter, J., 2020. "Nudge Unit." The Institute for Government. URL <https://www.instituteforgovernment.org.uk/explainers/nudge-unit> (accessed 2.18.21).
- Sarno, D.M., Lewis, J.E., Bohil, C.J., Neider, M.B., 2020. Which Phish Is on the Hook? Phishing Vulnerability for Older Versus Younger Adults. *Hum Factors* 62, 704–717. <https://doi.org/10.1177/0018720819855570>
- Schroeder, J., 2017. Persistent Training, in: *Schroeder, J. (Ed.), Advanced Persistent Training : Take Your Security Awareness Program to the Next Level*. Apress, Berkeley, CA, pp. 25–32. [https://doi.org/10.1007/978-1-4842-2835-7\\_4](https://doi.org/10.1007/978-1-4842-2835-7_4)
- Sheng, S., Holbrook, M., Kumaraguru, P., Cranor, L.F., Downs, J., 2010. Who falls for phish? A demographic analysis of phishing susceptibility and effectiveness of interventions, in: *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*. pp. 373–382.
- Sheng, S., Magnien, B., Kumaraguru, P., Acquisti, A., Cranor, L.F., Hong, J., Nunge, E., 2007. Anti-phishing phil: the design and evaluation of a game that teaches people not to fall for phish, in: *Proceedings of the 3rd Symposium on Usable Privacy and Security*. pp. 88–99.
- SIDN, 2021. URL check? | Cybersecurity | SIDN [WWW Document]. SIDN - The company behind .nl. URL <https://www.sidn.nl/en/how-to-spot-a-fake-url> (accessed 7.11.21).
- Sophos, 2021a. 2021 Threat Report [WWW Document]. URL <https://www.sophos.com/en-us/medialibrary/pdfs/technical-papers/sophos-2021-threat-report.pdf> (accessed 2.8.21).
- Sophos, 2021b. The State of Ransomware 2021. Sophos.

- Stajano, F., Wilson, P., 2011. Understanding scam victims: seven principles for systems security. *Communications of the ACM* 54, 70–75.
- Stone, D.E., Llewellyn, J., Chambers, J., 2020. Digital inclusion and online safety for adults in the UK: The Good Things Foundation.
- Sunstein, C., Thaler, R., 2008. *Nudge: Improving decisions about health, wealth, and happiness*. Springer.
- Taib, R., Yu, K., Berkovsky, S., Wiggins, M., Bayl-Smith, P., 2019. Social engineering and organisational dependencies in phishing attacks, in: *IFIP Conference on Human-Computer Interaction*. Springer, pp. 564–584.
- Thaler, R.H., Benartzi, S., 2004. Save more tomorrow<sup>TM</sup>: Using behavioral economics to increase employee saving. *Journal of political Economy* 112, S164–S187.
- Tidy, J., 2020a. Google blocking 18m coronavirus scam emails every day. BBC News. URL <https://www.bbc.com/news/technology-52319093> (accessed 4.5.21).
- Tidy, J., 2020b. How hackers extorted \$1.14m from University of California, San Francisco. BBC News. URL <https://www.bbc.com/news/technology-53214783> (accessed 4.5.21).
- Tioh, J., Mina, M., Jacobson, D.W., 2017. Cyber security training a survey of serious games in cyber security, in: *2017 IEEE Frontiers in Education Conference (FIE)*. Presented at the 2017 IEEE Frontiers in Education Conference (FIE), pp. 1–5. <https://doi.org/10.1109/FIE.2017.8190712>
- Ur, B., Kelley, P.G., Komanduri, S., Lee, J., Maass, M., Mazurek, M.L., Passaro, T., Shay, R., Vidas, T., Bauer, L., 2012. How does your password measure up? The effect of strength meters on password creation, in: *Proceedings of the USENIX Security Symposium*. pp. 65–80.
- VanEpps, E.M., Downs, J.S., Loewenstein, G., 2016. Calorie Label Formats: Using Numeric and Traffic Light Calorie Labels to Reduce Lunch Calories. *Journal of Public Policy & Marketing* 35, 26–36. <https://doi.org/10.1509/jppm.14.112>
- Verizon, 2020. 2020 Data Breach Investigations Report [WWW Document]. URL <https://enterprise.verizon.com/en-gb/resources/reports/dbir/> (accessed 2.8.21).
- Vishwanath, A., Harrison, B., Ng, Y.J., 2018. Suspicion, cognition, and automaticity model of phishing susceptibility. *Communication Research* 45, 1146–1166.
- Vishwanath, A., Herath, T., Chen, R., Wang, J., Rao, H.R., 2011. Why do people get phished? Testing individual differences in phishing vulnerability within an integrated, information processing model. *Decision Support Systems* 51, 576–586.
- Waldo Rocha Flores, Hannes Holm, Gustav Svensson, Göran Ericsson, 2014. Using phishing experiments and scenario-based surveys to understand security behaviours in practice. *Information management & computer security* 22, 393–. <https://doi.org/10.1108/IMCS-11-2013-0083>
- Weanquoi, P., Johnson, J., Zhang, J., 2018. Using a game to improve phishing awareness. *Journal of Cybersecurity Education, Research and Practice* 2018, 2.
- Wen, Z.A., Lin, Z., Chen, R., Andersen, E., 2019. What.Hack: Engaging Anti-Phishing Training Through a Role-playing Phishing Simulation Game, in: *Proceedings of the 2019 CHI Conference on Human Factors in Computing Systems*. Presented at the CHI '19: CHI Conference on Human Factors in Computing Systems, ACM, Glasgow Scotland Uk, pp. 1–12. <https://doi.org/10.1145/3290605.3300338>

- Yang, W., Xiong, A., Chen, J., Proctor, R.W., Li, N., 2017. Use of phishing training to improve security warning compliance: evidence from a field experiment, in: Proceedings of the Hot Topics in Science of Security: Symposium and Bootcamp. pp. 52–61.
- Zainuddin, Z., Chu, S.K.W., Shujahat, M., Perera, C.J., 2020. The impact of gamification on learning and instruction: A systematic review of empirical evidence. *Educational Research Review* 30, 100326. <https://doi.org/10.1016/j.edurev.2020.100326>
- Zielinska, O.A., Tembe, R., Hong, K.W., Ge, X., Murphy-Hill, E., Mayhorn, C.B., 2014. One phish, two phish, how to avoid the internet phish: Analysis of training strategies to detect phishing emails, in: Proceedings of the Human Factors and Ergonomics Society Annual Meeting. SAGE Publications Sage CA: Los Angeles, CA, pp. 1466–1470.